



CYBER; CRA; Essential cybersecurity requirements for routers, modems intended for the connection to the internet, and switches

CAUTION:

Exercising one of the Principles of international standardization – Openness – and taking it to a different level, ETSI is piloting informal public consultations of the vertical standards in support of the Cyber Resilience Act at a much earlier stage than it is usual in the standardization world. In this context, please keep in mind that the standard draft herein is an INTERIM DRAFT, which expectably will be subject to substantial changes before its target publication date in the second semester of 2026.

Disclaimer

This **INTERIM DRAFT** document is provided for information and is for future development work within the ETSI Technical Committee CYBER EUSR Working Group (CYBER-EUSR) only. ETSI and its Members accept no liability for any further use/implementation of this Specification. Approved and published specifications and reports shall be obtained exclusively via the ETSI Documentation Service at <http://www.etsi.org/standards-search>

Commenting guidelines

Your comments to improve this early draft are very welcomed. To ensure the effectiveness of your contribution, please make sure to include the following elements in your comment:

1. Clear identification of the section of the draft your comment is referring to.
2. Objective proposal to delete content, add content or substitute content.
3. Concrete contribution (exact content you suggest including in the draft as an addition to, or in substitution of, existing content).
4. Brief rationale to justify the proposal (e.g. why the suggested content should be added an/or the existing content should be deleted or substituted). Please note that comments without concrete contributions will be noted but not acted upon by ETSI CYBER-EUSR. We trust and value your expertise and therefore expect you to take this opportunity to proactively contribute to solving the issues you find while analysing this early draft.

How to comment

To comment or provide feedback on the present interim draft please visit <https://labs.etsi.org/rep/stan4cra/en-304-627> and submit your comments as “issues” following the guidelines provided on this site. Alternatively, you may also send your comments to: cybersupport@etsi.org using the “[ETSI Commenting Format for Open Consultation.xlsx](#)” available in <https://docbox.etsi.org/CYBER/EUSR/Open>

1
2
3

ReferenceDEN/CYBER-EUS-0013

Keywords

CRA; Cybersecurity; router, modem, switch

4

ETSI650 Route des Lucioles
F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B
Association à but non lucratif enregistrée à la
Sous-préfecture de Grasse (06) N° w061004871

Important notice

The present document can be downloaded from the
[ETSI Search & Browse Standards](#) application.

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on [ETSI deliver](#) repository.

Users should be aware that the present document may be revised or have its status changed,
this information is available in the [Milestones listing](#).

If you find errors in the present document, please send your comments to
the relevant service listed under [Committee Support Staff](#).

If you find a security vulnerability in the present document, please report it through our
[Coordinated Vulnerability Disclosure \(CVD\)](#) program.

Notice of disclaimer & limitation of liability

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.

No recommendation as to products and services or vendors is made or should be implied.
In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

Copyright Notification

No part may be reproduced or utilized in any form or by any means, electronic or mechanical, including photocopying and microfilm except as authorized by written permission of ETSI.

The content of the PDF version shall not be modified without the written authorization of ETSI.

The copyright and the foregoing restriction extend to reproduction in all media.

© ETSI 2025.
All rights reserved.

Contents

5			
6	Intellectual Property Rights		8
7	Foreword.....		8
8	Modal verbs terminology.....		8
9	Executive summary.....		9
10	Introduction.....		9
11	1 Scope		10
12	2 References		10
13	2.1 Normative references		10
14	2.2 Informative references.....		10
15	3 Definition of terms, symbols and abbreviations		12
16	3.1 Terms.....		12
17	3.2 Symbols.....		13
18	3.3 Abbreviations.....		13
19	4 Product context		14
20	4.1 Intended purpose related to foreseen use		14
21	4.2 Routers		14
22	4.3 Modems intended for connection to the internet.....		14
23	4.4 Switches		14
24	4.5 Product functions.....		15
25	4.5.1 Product overview		15
26	4.5.2 Network traffic forwarding and routing.....		15
27	4.5.3 Access control and security policy enforcement		15
28	4.5.4 Configuration and management.....		16
29	4.5.5 Monitoring and diagnostics.....		16
30	4.6 Product architecture.....		16
31	4.7 Operational environment.....		16
32	4.7.1 Introduction		16
33	4.7.2 Residential deployments.....		17
34	4.7.3 Small and medium enterprise deployments		17
35	4.7.4 Enterprise and data centre deployments.....		17
36	4.7.5 Critical infrastructure and industrial deployments.....		17
37	4.7.6 Service provider and carrier networks.....		17
38	4.7.7 Cloud and virtualized environments.....		18
39	4.8 Risk assessment framework.....		18
40	4.8.1 Introduction		18
41	4.8.2 Risk factors.....		18
42	4.8.2.1 Baseline risk factors.....		18
43	4.8.2.2 Management access risk factors.....		19
44	4.8.2.3 Management operational risk factors		20
45	4.8.2.4 Protocol implementation risk factors.....		20
46	4.8.2.5 Data operations risk factors.....		21
47	4.8.3 Risk factor assessment.....		21
48	4.8.3.1 General		21
49	4.8.3.2 Content requirements.....		21
50	4.8.3.3 Completeness		22
51	4.8.3.4 Maintenance of the risk factor assessment.....		22
52	4.8.4 Undeclared or misdeclared risk factors		22
53	4.8.5 Mapping table: Requirements to risk factors		22
54	4.9 Users.....		23
55	4.10 Reasonably foreseeable use cases.....		24
56	4.10.1 Introduction		24
57	4.10.2 Consumer premises equipment		24
58	4.10.2.1 Description		24
59	4.10.2.2 Typical deployment characteristics		24

60	4.10.2.3	Security considerations.....	24
61	4.10.3	Small business network infrastructure.....	24
62	4.10.3.1	Description	24
63	4.10.3.2	Typical deployment characteristics	25
64	4.10.3.3	Security considerations.....	25
65	4.10.4	Enterprise managed network infrastructure	25
66	4.10.4.1	Description	25
67	4.10.4.2	Typical deployment characteristics	25
68	4.10.4.3	Security considerations.....	25
69	4.10.5	Internet-facing enterprise edge devices.....	26
70	4.10.5.1	Description	26
71	4.10.5.2	Typical deployment characteristics	26
72	4.10.5.3	Security considerations.....	26
73	4.10.6	Service provider network infrastructure.....	26
74	4.10.6.1	Description	26
75	4.10.6.2	Typical deployment characteristics	26
76	4.10.6.3	Security considerations.....	27
77	4.10.7	Critical infrastructure network devices	27
78	4.10.7.1	Description	27
79	4.10.7.2	Typical deployment characteristics	27
80	4.10.7.3	Security considerations.....	27
81	4.10.8	Virtualized network functions.....	27
82	4.10.8.1	Description	27
83	4.10.8.2	Typical deployment characteristics	28
84	4.10.8.3	Security considerations.....	28
85	4.11	Context summary.....	28
86	5	Cybersecurity requirements.....	28
87	5.1	General.....	28
88	5.2	Secure by design.....	29
89	5.2.1	General	29
90	5.2.1.1	Requirements	29
91	5.3	No known exploitable vulnerabilities	29
92	5.3.1.1	General	29
93	5.3.1.2	Requirements	29
94	5.4	Secure by default configuration.....	29
95	5.4.1	[DEFAULT] Secure by default configuration.....	29
96	5.4.1.1	General	29
97	5.4.1.2	Requirements	29
98	5.4.2	[RESET] Factory reset	30
99	5.4.2.1	General	30
100	5.4.2.2	Requirements	30
101	5.5	Security Updates.....	30
102	5.5.1	[UPDATE] Update mechanisms.....	30
103	5.5.1.1	General	30
104	5.5.1.2	Requirements	30
105	5.6	Access Control.....	31
106	5.6.1	[AUTH-1] Authentication.....	31
107	5.6.1.1	General	31
108	5.6.1.2	Requirement.....	31
109	5.6.2	[AUTH-2] Authorization.....	32
110	5.6.2.1	General	32
111	5.6.2.2	Requirements	32
112	5.6.3	[AUTH-3] Authenticated session lifecycle.....	32
113	5.6.3.1	General	32
114	5.6.3.2	Requirements	32
115	5.6.4	[AUTH-4] Protocol access control	33
116	5.6.4.1	General	33
117	5.6.4.2	Requirements	33
118	5.7	Data Protection	33
119	5.7.1	General	33
120	5.7.2	Requirements	33

121	5.8	Availability and Resilience	34
122	5.8.1	General	34
123	5.8.2	Requirements	34
124	5.9	Attack Surface and Mitigation	34
125	5.9.1	[INTEGRITY] System integrity and boot process	34
126	5.9.1.1	General	34
127	5.9.1.2	Requirements	34
128	5.9.2	[PACKET] Default packet disposition	35
129	5.9.2.1	General	35
130	5.9.2.2	Requirements	35
131	5.9.3	[EXPOSURE] Interface and service exposure minimization	35
132	5.9.3.1	General	35
133	5.9.3.2	Requirements	35
134	5.10	Monitoring and Logging	35
135	5.10.1.1	General	35
136	5.10.1.2	Requirements	36
137	5.11	Data Management	36
138	5.11.1	[TRANSFER] Secure data export and transfer	36
139	5.11.1.1	General	36
140	5.11.1.2	Requirements	36
141	6	Vulnerability Handling Requirements	36
142	6.1	General	36
143	6.2	Vulnerability identification and documentation	37
144	6.2.1	General	37
145	6.2.1.1	Input	37
146	6.2.1.2	Requirements	37
147	6.2.1.3	Output	37
148	6.2.1.4	Assessment criteria	37
149	6.3	Vulnerability Remediation	37
150	6.3.1	General	37
151	6.3.1.1	Input	37
152	6.3.1.2	Requirements	37
153	6.3.1.3	Output	37
154	6.3.1.4	Assessment criteria	37
155	6.4	Security testing and review	37
156	6.4.1	General	37
157	6.4.1.1	Input	37
158	6.4.1.2	Requirements	37
159	6.4.1.3	Output	37
160	6.4.1.4	Assessment criteria	37
161	6.5	Vulnerability disclosure	38
162	6.5.1	General	38
163	6.5.1.1	Input	38
164	6.5.1.2	Requirements	38
165	6.5.1.3	Output	38
166	6.5.1.4	Assessment criteria	38
167	6.6	Coordinated vulnerability disclosure policy	38
168	6.6.1	General	38
169	6.6.1.1	Input	38
170	6.6.1.2	Requirements	38
171	6.6.1.3	Output	38
172	6.6.1.4	Assessment criteria	38
173	6.7	Vulnerability reporting mechanisms	38
174	6.7.1	General	38
175	6.7.1.1	Input	38
176	6.7.1.2	Requirements	38
177	6.7.1.3	Output	38
178	6.7.1.4	Assessment criteria	38
179	6.8	Update distribution	38
180	6.8.1	General	38
181	6.8.1.1	Input	38

182	6.8.1.2	Requirements	38
183	6.8.1.3	Output	38
184	6.8.1.4	Assessment criteria	38
185	6.9	Security advisory and user guidance	39
186	6.9.1	General	39
187	6.9.1.1	Input	39
188	6.9.1.2	Requirements	39
189	6.9.1.3	Output	39
190	6.9.1.4	Assessment criteria	39
191	7	Assessing cybersecurity requirement compliance	39
192	7.1	General	39
193	7.2	Secure by Design	39
194	7.3	No known exploitable vulnerabilities	39
195	7.4	Secure by Default Configuration	39
196	7.4.1	[DEFAULT] Secure by default configuration	39
197	7.4.1.1	Requirement assessments	39
198	7.4.2	[RESET] Factory reset	46
199	7.4.2.1	Requirement assessments	46
200	7.4.3	[UPDATE] Update mechanisms	49
201	7.4.3.1	Requirement assessments	49
202	7.5	Access Control	54
203	7.5.1	[AUTH-1] Authentication	54
204	7.5.1.1	Requirement assessments	54
205	7.5.2	[AUTH-2] Authorization	59
206	7.5.2.1	Requirement assessments	59
207	7.5.3	[AUTH-3] Authenticated session lifecycle	62
208	7.5.3.1	Requirement assessments	62
209	7.5.4	[AUTH-4] Protocol access control	67
210	7.5.4.1	Requirement assessments	67
211	7.6	Data Protection	71
212	7.6.1.1	Requirement assessments	71
213	7.7	Availability and Resilience	74
214	7.7.1.1	Requirement assessments	74
215	7.8	Attack Surface and Mitigation	77
216	7.8.1	[INTEGRITY] System integrity and boot process	77
217	7.8.1.1	Requirement assessments	77
218	7.8.2	[PACKET] Default packet disposition	81
219	7.8.2.1	Requirement assessments	81
220	7.8.3	[EXPOSURE] Interface and service exposure minimization	83
221	7.8.3.1	Requirement assessments	83
222	7.9	Monitoring and Logging	85
223	7.9.1.1	Requirement assessments	85
224	7.10	Data Management	88
225	7.10.1	[TRANSFER] Secure data export and transfer	88
226	7.10.1.1	Requirement assessments	88
227	8	Annex A (informative): Relationship between the present document and the requirements of EU	
228		Regulation (EU) 2024/2847 – the Cyber Resilience Act	93
229	9	Annex B (informative): Threat landscape and security considerations	98
230	9.1	General	98
231	9.2	Threat agent characterization	98
232	9.2.1	Threat distribution across network exposure levels	98
233	9.2.2	Threat patterns associated with management models	99
234	9.2.3	Threats arising from capability-based conditions	99
235	9.2.4	Advanced persistent threats and emerging attack vectors	100
236	9.2.4.1	Nation-state actors and Advanced Persistent Threat groups	100
237	9.2.4.2	Supply chain infiltration threats	101
238	9.2.4.3	Zero-day exploit markets and commercialization	101
239	9.3	Vulnerability analysis	101
240	9.3.1	Attack scenario analysis	102
241	9.3.2	Condition-based threat exposure	102

242 9.3.2.1.1.1.1.1 Annex <L+1> (informative): Maximum measurement uncertainty104

243 9.3.2.1.1.1.1.2 Annex <L+2> (normative or informative): Title of annex.....105

244 10 <L+2.1> First clause of the

245 annex.....105

246 10.1 <L+2.1.1>First subdivided clause of the

247 annex 105

248 10.1.1.1.1.1.1.1 Annex <L+3> (informative): Bibliography106

249 10.1.1.1.1.1.1.2 Annex <L+4> (informative): Change history.....107

250 11 History108

251

252

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the [ETSI IPR online database](#).

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

1.1.1.1.1 Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.

Foreword

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cybersecurity (TC CYBER) and is now submitted for the combined Public Enquiry and Vote phase of the ETSI EN Approval Procedure.

The present document has been prepared in response to the Commission's standardisation request C(2025)618 [i.3] to provide, in additions to its other uses, one voluntary means of conforming to the essential requirements of Regulation (EU) 2024/2847 [i.2] known as the Cyber Resilience Act (CRA). It corresponds to the new deliverable in line 27 of Annex I of the standardisation request.

Once the present document is cited in the Official Journal of the European Union under Regulation (EU) 2024/2847 [i.2], conformance with the normative clauses of the present document given in the table in Annex A confers, to products with digital elements in the scope of the present document, a presumption of conformity with the corresponding essential requirements of that Regulation and associated EFTA regulations.

Proposed national transposition dates	
Date of latest announcement of this EN (doa):	3 months after ETSI publication
Date of latest publication of new National Standard or endorsement of this EN (dop/e):	6 months after doa
Date of withdrawal of any conflicting National Standard (dow):	18 months after doa

Modal verbs terminology

In the present document **"shall"**, **"shall not"**, **"should"**, **"should not"**, **"may"**, **"need not"**, **"will"**, **"will not"**, **"can"** and **"cannot"** are to be interpreted as described in clause 3.2 of the [ETSI Drafting Rules](#) (Verbal forms for the expression of provisions).

"must" and **"must not"** are **NOT** allowed in ETSI deliverables except when used in direct citation.

Executive summary

[TODO: Overview of content and guidelines on how to use this standard].

Introduction

This Harmonised European Standard defines cybersecurity requirements applicable to routers, modems intended for the connection to the internet, and switches, as identified in Annex III, Class I, point 12 of Regulation (EU) 2024/2847 [i.1], the Cyber Resilience Act, there after referred to as “CRA”.

The present document supports compliance with Regulation (EU) 2024/2847, the Cyber Resilience Act, specifically addressing the essential cybersecurity requirements defined in Annex I, Parts I and II. The mapping of the minimum Cyber Resilience Act requirements with the technical requirements of the present document are explicitly detailed in Annex A.

Requirements in the present document implement a risk-based approach through conditional applicability to ensure security measures proportionate to deployment context and threat exposure. The requirements apply to all deployment forms of routers, modems intended for connection to the internet, and switches when used for their intended purpose of establishing and managing network connectivity, including standalone physical appliances, integrated multi-function products, virtualized network functions, and software-defined networking implementations.

1 Scope

The present document specifies essential cybersecurity requirements and assessment criteria for products with digital elements comprising routers, modems intended for connection to the internet, and switches, as set out in CRA [i.1] Annex III, Class I, point 12.

The document addresses the essential cybersecurity requirements of CRA [i.1] Annex I, Part I and Part II.

NOTE: The term "internet" as used in this standard refers to any public network infrastructure accessible beyond organizational boundaries. Public networks are those accessible to multiple organizations or the general public, while private networks operate under single organizational control.

Whether deployed as dedicated hardware, virtual machines, containerized applications, or cloud-native network functions, routers, modems intended for connection to the internet, and switches fall within the scope of this standard when they provide management capabilities. This applies when their intended purpose or reasonably foreseeable use involves processing, forwarding, or managing network traffic between devices, network segments, or between public and private networks.

NOTE: Unmanaged products that operate with fixed functionality and provide no configuration interface or administrative access are excluded from the scope of this standard, as they lack the necessary interfaces to implement the security controls specified herein.

The present document does not specify functional conformance requirements for networking protocols, nor does it address performance specifications, quality of service metrics, or protocol interoperability testing. However, security controls governing the implementation of networking protocols and vulnerability management for those implementations remain within scope.

2 References

2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the [ETSI docbox](#).

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents are necessary for the application of the present document.

- [1] CEN CENELEC EN 40 000-1-3 “Cybersecurity requirements for products with digital elements – Vulnerability Handling”
- [2] HORIZONTAL STANDARDS TO BE REFERENCED NORMATIVELY IF AND WHEN AVAILABLE AND APPROPRIATE
- [3] OTHER RELEVANT CRA VERTICAL STNADARDS (firewalls, network interfaces, operating systems, etc).
- [x] <Standard Organization acronym> <document number> (<version number>): "<Title>".

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

349 The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader's
350 understanding but are not required for conformance to the present document.

351 [i.1] Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on
352 horizontal cybersecurity requirements for products with digital elements and amending
353 Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber
354 Resilience Act) (Text with EEA relevance)

355 [Regulation - 2024/2847 - EN - EUR-Lex](#)

356 [i.2] Commission Implementing Regulation (EU) **.../...of XXX** on the technical description of the
357 categories of important and critical products with digital elements pursuant to Regulation (EU)
358 2024/2847 of the European Parliament and of the Council (Text with EEA relevance)

359 [i.3] C(2025)618 – Standardisation request M/606: Commission Implementing decision of 3.2.2025 on
360 a standardisation request to the European Committee for Standardisation (CEN), the European
361 Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications
362 Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU)
363 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal
364 cybersecurity requirements for products with digital elements and amending Regulations (EU) No
365 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)

366 https://ec.europa.eu/growth/tools-databases/enorm/mandate/606_en

367 [i.4] NIST Cybersecurity Framework (CSF) 2.0

368 [i.5] NIST SP 800-63-4 Digital Identity Guidelines

369 [i.6] NIST SP 800-153 Guidelines for Securing Wireless Local Area Networks (WLANs)

370 [i.7] NIST Special Publication 800-53, Security and Privacy Controls for Information Systems and
371 Organizations (Rev. 5)

372 [i.8] NIST Special Publication 800-189 Resilient Interdomain Traffic Exchange: BGP Security and
373 DDoS Mitigation

374 [i.9] ISO/IEC 15408-1:2022 Information security, cybersecurity and privacy protection — Evaluation
375 criteria for IT security

376 [i.10] ISO/IEC 27035-1:2023 Information technology — Information security incident management

377 [i.11] ISO/IEC 15408-1 Information security, cybersecurity and privacy protection — Evaluation criteria
378 for IT security (Common Criteria)

379 [i.12] ISO/IEC 19790:2025 Information security, cybersecurity and privacy protection — Security
380 requirements for cryptographic modules

381 [i.13] ISO/IEC 24759:2025 Information security, cybersecurity and privacy protection — Test
382 requirements for cryptographic modules

383 [i.14] ISO/IEC 16500-6:1999: "Information technology Generic digital audio-visual systems"

384 [i.15] BSI TR-03148: "Secure Broadband Router"

385 [i.16] ETSI EN 303 645 V2.1.1 (2020-06): "CYBER; Cyber Security for Consumer Internet of Things:
386 Baseline Requirements "

387 [i.17] Broadband Forum, TR-069 Amendment 6 (July 2018): "CPE WAN Management Protocol
388 (CWMP)."

389 [i.18] Broadband Forum, TR-369 Issue 1 Amendment 3 (April 2023): "User Services Platform (USP)."

3 [i.19] IETF, RFC 6241 (June 2011): “Network Configuration Protocol (NETCONF).” Definition of terms, symbols and abbreviations

3.1 Terms

For the purposes of the present document, the following terms apply:

audit event: A timestamped record of security-relevant activities including authentication attempts, configuration changes, system events, and administrative actions, formatted in a structured manner suitable for monitoring and forensic analysis.

broadcast loop: network condition where broadcast frames continuously circulate between interconnected devices without a defined termination point, causing network degradation or failure through excessive bandwidth consumption and processing overhead.

critical security parameter: security-related confidential information whose disclosure or modification can compromise the security of the product.

EXAMPLE: Secret cryptographic keys, authentication values such as passwords, PINs, private components of certificates. debug interface: physical interface used by the manufacturer to communicate with the product during development or to perform triage of issues with the product and that is not used as part of the consumer-facing functionality

logical interface: virtual interface used to communicate with the product at a logical layer.

NOTE 1: Typically, the semantic, syntactic, and symbolic attributes of information flows for logical interfaces are specified. The are alternative definitions for logical interfaces e.g. in ISO/IEC 16500-6:1999 [i.11] that utilize this property.

NOTE 2: A logical interface may utilize a network interface to exchange information with remote endpoints.

network interface: physical interface that can be used to access the functionality of router, modem or switch via a network.

private network: closed network within a home or an organization that is not directly accessible by the general public and is generally controlled by or on behalf of the user.

public network: a publicly accessible network like the internet and is usually not under control of the user.

router: a product with digital elements that establishes and controls the flow of data between different networks, including IP-based but not limited, by selecting paths or routes using routing protocol mechanisms and algorithms, typically operating at the network layer.

NOTE 1: Includes but is not limited to wired and wireless routers, virtual routers and routers with or without modems.

modem intended for connection to the internet: a hardware product with digital elements that uses digital modulation and demodulation techniques to convert analogue signals from and to digital signals.

NOTE 1: Includes but is not limited to fibre modems, Digital Subscriber Line (DSL) modems, cable (DOCSIS) modems, satellite modems and cellular modems.

session identifier entropy: represents the complexity of special inputs of a cryptographic algorithm used to encrypt the session.

NOTE 1: It measures the randomness and unpredictability in session identifier generation, typically expressed in bits, representing the difficulty of guessing or predicting valid session identifiers.

switch: a product with digital elements that provides connectivity between attached devices through frame forwarding mechanisms implemented and operated at the data link layer, and that have a management plane.

NOTE 1: includes but is not limited to managed switches, smart switches, multilayer switches, virtual security switches, programmable switches for software-defined networking and bridges such as wireless access points.

firmware: software stored in non-volatile memory that controls product operation.

NOTE 1: Firmware includes boot sequences, operating system components, network protocol implementations, and management interfaces.

NOTE 2: Firmware may include persistent configuration data essential for product operation.

secure-by-default configuration: configuration in which the product satisfies requirements in clause 5.4.1.

3.2 Symbols

For the purposes of the present document, the [following] symbols [given in ... and the following] apply:

3.3 Abbreviations

For the purposes of the present document, the following abbreviations apply:

API	Application Programming Interface
ARP	Address Resolution Protocol
CRA	Cyber Resilience Act
CVD	Coordinated Vulnerability Disclosure
CSAF	Common Security Advisory Framework
DDoS	Distributed Denial of Service
DHCP	Dynamic Host Configuration Protocol
DSL	Digital Subscriber Line
DNS	Domain Name System
ENISA	European Union Agency for Cybersecurity
EU	European Union
HTTP	HyperText Transfer Protocol
ICMP	Internet Control Message Protocol
IEEE	Institute of Electrical and Electronics Engineers
IETF	Internet Engineering Task Force
IoT	Internet of Things
IP	Internet Protocol
ISO	International Organization for Standardization
JTAG	Joint Test Action Group
LAN	Local Area Network
MAC	Media Access Control
MPCVD	Multi-Party Coordinated Vulnerability Disclosure
MPLS	Multi-Protocol Label Switching
NIST	National Institute of Standards and Technology
NTP	Network Time Protocol
NMS	Network Management System
OSI	Open Systems Interconnection
OTP	One-Time Password
OWASP	Open Web Application Security Project
RF	Radio Frequency
SBOM	Software Bill of Materials
SE	Secure Elements
SOHO	Small Office / Home Office
SSH	Secure shell, cryptographic network protocol
SSID	Service Set Identifier
STRIDE	Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege
SWD	Serial Wire Debug
TEE	Trusted Execution Environment
UART	Universal Asynchronous Receiver-Transmitter
UI	User Interface

485	VLAN	Virtual Local Area Network
486	VPN	Virtual Private Network
487	WAN	Wide Area Network
488	WPS	Wi-Fi Protected Setup

489 4 Product context

490 4.1 Intended purpose related to foreseen use

491 Network products comprising routers, modems intended for connection to the internet, and switches form the
 492 fundamental building blocks of digital communications. These products enable connectivity and facilitate
 493 communication across public and private network infrastructures by implementing essential functions such as traffic
 494 routing, network address translation, and packet forwarding. Their position at network boundaries and interconnection
 495 points makes them essential for connectivity and attractive targets for malicious actors seeking to compromise network
 496 integrity, confidentiality, or availability.

497 The security posture of these products directly impacts all connected systems and data flows. A compromised product
 498 may enable attackers to intercept communications, redirect traffic, deny service to legitimate users, or launch attacks on
 499 other network segments. The widespread deployment of these products across consumer, enterprise, and critical
 500 infrastructure environments necessitates security requirements that scale appropriately to different risk contexts while
 501 maintaining baseline protections.

502 These products operate continuously with varying degrees of user interaction and management complexity. Modems
 503 intended for connection to the internet may function with minimal configuration after initial setup, whereas routers and
 504 managed switches require ongoing administration of routing policies, access controls, and network segmentation.
 505 Despite these operational differences, all three product types share common security-critical characteristics: they
 506 process substantial volumes of network traffic, maintain operational state, and implement multiple network protocols
 507 that interoperate.

508 Routers utilize dynamic routing protocols and maintain extensive state information about network topology and paths.
 509 Modems intended for connection to the internet bridge between different physical layer technologies while increasingly
 510 incorporating routing and security functions. Switches track MAC address associations and VLAN memberships while
 511 enforcing port-level security policies. This range of operational complexity, from data link layer (Layer 2 of the OSI
 512 model) forwarding to advanced traffic analysis, requires security measures that protect the fundamental traffic
 513 forwarding function while appropriately securing management interfaces and advanced features based on product
 514 capability and deployment context.

515 4.2 Routers

516 Routers are products with digital elements that establish and control data flow between different networks by selecting
 517 paths using routing protocol mechanisms and algorithms, typically operating at the network layer.

518 This category includes wired and wireless routers, virtual routers, and routers with or without modems.

519 4.3 Modems intended for connection to the internet

520 Modems intended for connection to the internet are hardware products with digital elements that use digital modulation
 521 and demodulation techniques to convert signals between analogue and digital formats for communication with public
 522 networks.

523 This category includes fibre modems, Digital Subscriber Line (DSL) modems, cable (DOCSIS) modems, satellite
 524 modems, and cellular modems.

525 4.4 Switches

526 Switches are products with digital elements that provide connectivity between networked devices through packet
 527 forwarding mechanisms and include a management plane, typically implemented at the data link or network layer.

528 This category includes managed switches, smart switches, multilayer switches, virtual switches, programmable switches
 529 for software-defined networking, and bridges such as wireless access points.

4.5 Product functions

4.5.1 Product overview

Products implement a multi-plane architecture based on the separation of data, control, and management planes as described in ITU-T Y.2011 and in IETF RFC 7426.

The data plane, also termed the forwarding plane, handles high-speed processing of network traffic according to established policies and routing decisions. This plane employs specialized hardware including application-specific integrated circuits or network processors optimized for packet processing operations.

The control plane manages routing protocols, builds and maintains forwarding tables, and determines packet forwarding paths through the network.

The management plane provides interfaces for product configuration, monitoring, and maintenance, including command-line interfaces, web-based management consoles, and programmatic APIs.

The physical architecture encompasses network interfaces supporting various media types and speeds, from gigabit Ethernet ports (IEEE 802.3 standards family) to high-speed fibre optic connections. Processing subsystems include central processing units for control and management functions, specialized network processors or ASICs for data plane operations, and memory subsystems comprising volatile memory for operational data and non-volatile storage for firmware and configuration. Physical interfaces for local management include console ports, USB interfaces for configuration backup and restoration, and out-of-band management interfaces enabling remote administration when primary network connections are unavailable.

Products enable digital communications across interconnected systems. These functions shall remain operational and secure throughout the product lifecycle to maintain network integrity and availability.

4.5.2 Network traffic forwarding and routing

Products receive network packets, make forwarding decisions based on destination addresses or routing policies, and transmit packets toward their destinations. This includes maintaining routing or forwarding tables, processing routing protocol updates, calculating optimal paths, and handling traffic at wire speed without introducing unacceptable latency or packet loss.

4.5.3 Access control and security policy enforcement

Access control and security policy enforcement govern administrative access to products and regulate network traffic according to defined security policies. These functions determine which entities can modify product configuration and how network traffic is permitted or restricted based on security requirements.

Products implement authentication mechanisms that verify the identity of users attempting to access management functions. Following authentication, products enforce authorization policies that determine which commands and configuration changes each authenticated user can execute based on assigned privileges. This includes maintaining role-based access controls that separate read-only monitoring functions from configuration modification capabilities, ensuring users can only perform actions appropriate to their administrative role. Products maintain these access control decisions across sessions and preserve them through system restarts by storing authentication credentials and authorization policies in protected non-volatile memory.

Security policy enforcement extends beyond administrative access to control network traffic flows. Products implement access control lists and filtering rules that determine which packets can traverse network boundaries based on source and destination addresses, protocols, and port numbers. They enforce network segmentation policies that maintain isolation between different security zones, preventing unauthorized communication between network segments with different trust levels. For products operating at network boundaries, this function includes enforcing policies that distinguish between traffic from trusted internal networks and untrusted external sources, applying appropriate security controls based on traffic origin and destination.

These access control and policy enforcement functions operate continuously, evaluating every administrative command against authorization policies and inspecting network traffic against configured security rules. The integrity of these functions determines the product's ability to maintain secure network boundaries and prevent unauthorized configuration changes that could compromise network security.

577 4.5.4 Configuration and management

578 Configuration and management functions provide interfaces for product administration including command -line
579 interfaces, web-based management, and programmatic APIs. These functions handle network interface settings, routing
580 protocol parameters, security policies, quality of service rules, and system maintenance operations. Configuration
581 systems maintain consistency across redundant components and protect stored configurations against corruption or
582 unauthorized modification.

583 4.5.5 Monitoring and diagnostics

584 Monitoring functions collect interface statistics, error conditions, performance metrics, and security events. These
585 capabilities provide visibility into product operation, network traffic patterns, and potential security incidents.
586 Diagnostic features enable troubleshooting of connectivity issues, performance problems, and configuration errors
587 while managing exposure of sensitive operational information.

588 4.6 Product architecture

589 Products process and forward traffic using standardized communication protocols across multiple network layers,
590 handling protocol encoding and decoding, state management, and error handling while maintaining interoperability with
591 products from various manufacturers.

592 The software architecture builds upon an embedded operating system, whether Linux-based, real-time operating system
593 variants, or proprietary implementations. Network protocol stacks implement standard protocols for routing, switching,
594 and network services. Management software provides configuration interfaces, monitoring capabilities, and integration
595 with network management systems. Security services operate across all architectural layers, implementing access
596 controls at management interfaces, encryption for control plane communications, and packet filtering in the data plane.
597 The firmware update mechanism requires secure verification of update authenticity and integrity while maintaining
598 service availability during update procedures.

599 Manufacturers increasingly bundle these products with additional software features to enhance market appeal and
600 provide greater value. These features include integrated firewall capabilities, VPN services, content filtering, quality of
601 service management, and network monitoring tools. While this expanded software ecosystem aims to deliver
602 comprehensive networking solutions, it introduces significant security considerations. Each additional software
603 component represents a potential attack surface that adversaries may exploit. These supplementary features require
604 careful security assessment and ongoing maintenance to prevent them from becoming vulnerability points that could
605 compromise the entire network infrastructure.

606 4.7 Operational environment

607 4.7.1 Introduction

608 The technical requirements of the present document apply to products operating within their intended deployment
609 conditions. Products shall comply when operating within the boundaries defined by their intended use.

610 Products operate in diverse physical and logical environments that influence their security requirements and threat
611 exposure. Physical environments range from data centres with restricted access to residential settings with minimal
612 physical security and outdoor deployments exposed to tampering. Logical environments encompass the network
613 architectures, trust boundaries, and interconnected systems that define the operational context.

614 These products operate continuously with occasional planned downtime, processing traffic flows between networks
615 with varying trust levels. They may connect directly to untrusted public networks and bridge networks with different
616 security classifications. The operational environment includes adjacent network products, upstream service provider
617 products, downstream client systems, and management infrastructure that collectively form the extended attack surface.

618 Security considerations for these products include management plane security and administrative access controls,
619 protocol implementation robustness against malformed inputs and attacks, boot process and software update mechanism
620 integrity, breach containment through isolation and segmentation capabilities, and protection against physical tampering
621 or unauthorized physical access.

4.7.2 Residential deployments

Residential network infrastructure typically includes a modem intended for connection to the internet with integrated wireless access point functionality, serving households with multiple connected products: computers, smartphones, smart home appliances, and entertainment systems. These modems connect directly to internet service providers through cable, DSL, or fibre connections, operating with minimal technical oversight from users who expect plug-and-play functionality with default configurations.

The network boundary between trusted products on the private network and the public network relies entirely on the security controls these products implement, as residential users rarely deploy additional security layers. Traffic patterns include streaming media, web browsing, remote work connections, online gaming, and smart home product communications with cloud services, creating diverse security requirements within a single deployment.

4.7.3 Small and medium enterprise deployments

Small and medium enterprises deploy network infrastructure for point-of-sale systems, employee workstations, guest wireless networks, and connections to cloud-based business applications. These environments typically feature managed switches for network segmentation between employee and customer networks, business-grade routers with virtual private network capabilities for remote workers, and dedicated security appliances or router-integrated security features for threat protection.

Internal IT staff or managed service providers provide technical expertise, but resource constraints often limit comprehensive security monitoring and rapid response capabilities. Business continuity requirements demand high availability. Redundancy implementations vary significantly based on enterprise resources and risk tolerance.

4.7.4 Enterprise and data centre deployments

Large enterprise deployments utilize hierarchical network architectures with core, distribution, and access layer switches managing thousands of endpoints across multiple physical locations. High-performance routers handle inter-site connectivity, internet edge routing, and complex traffic engineering requirements. These routers implement sophisticated security policies and quality of service guarantees.

These environments feature redundant paths, automated failover mechanisms, and extensive monitoring infrastructure to maintain service availability for business-critical applications. Network segmentation enforces security boundaries between departments, applications, and user populations. Dedicated security teams manage firewall rules, intrusion detection systems, and incident response procedures.

The infrastructure supports diverse traffic types: real-time communications, database replication, backup transfers, and user application traffic. Each type has specific performance and security requirements.

4.7.5 Critical infrastructure and industrial deployments

Critical infrastructure sectors deploy products whose availability and integrity affect public safety and essential services. These deployments use specialized industrial protocols, real-time control system communications, and strict segregation between operational technology and information technology networks. Products in these environments have to maintain deterministic performance while implementing defence-in-depth security architectures against persistent adversaries. Regulatory compliance requirements mandate specific security controls, incident reporting procedures, and recovery time objectives for product selection and configuration. Industrial settings operate products for decades, creating challenges for vulnerability management and security updates without disrupting operations.

4.7.6 Service provider and carrier networks

Internet service providers and telecommunications carriers deploy carrier-grade routing and switching infrastructure that handles millions of subscriber connections. This infrastructure implements BGP for internet backbone connectivity and segment routing for network programmability. It supports residential broadband, enterprise services, mobile backhaul, and content delivery networks under strict service level agreements. Security controls protect the provider's infrastructure from attacks and provide lawful intercept capabilities, distributed denial of service mitigation, and subscriber isolation. These large-scale deployments require automated configuration management, real-time telemetry collection, and rapid incident response across extensive network territories.

4.7.7 Cloud and virtualized environments

Cloud service providers and enterprises implementing private clouds deploy virtual routers and switches as software-defined networking components in virtualized infrastructure. These virtual network functions operate on commodity hardware and provide programmable network services. Orchestration platforms dynamically instantiate, scale, and reconfigure these services. Abstracting network functions from physical hardware enables rapid service deployment and infrastructure agility but introduces hypervisor vulnerabilities, east-west traffic visibility issues, and control plane security risks. Multi-tenant environments require strict isolation between customer networks and controlled inter-tenant connectivity for partner integrations. Cloud environments change continuously as workloads migrate and scale. Security controls have to adapt to changing network topologies and maintain consistent policy enforcement.

4.8 Risk assessment framework

4.8.1 Introduction

This clause establishes a risk assessment framework for determining which security requirements from Clause 5 apply to a product. The framework consists of two components:

(a) Risk factors (clauses 4.8.2.1 through 4.8.2.5) - cybersecurity risk factors that manufacturers shall evaluate based on the product's intended purpose, reasonably foreseeable use, and conditions of use;

(b) Risk factor assessment methodology (clause 4.8.3) - the process for documenting and maintaining the assessment of which risk factors apply to the product.

The risk factors are organized into six categories:

(i) Baseline risk factors - arising from fundamental security properties required for all network infrastructure products;

(ii) Management access risk factors - arising from administrative interface accessibility;

(iii) Management operational risk factors - arising from administration and update methods;

(iv) Protocol implementation risk factors - arising from network protocols and services;

(vi) Data operations risk factors - arising from data import/export and transfer capabilities.

A single product may present multiple risk factors simultaneously. Each risk factor present in the product triggers its corresponding security requirements in Clause 5.

4.8.2 Risk factors

4.8.2.1 Baseline risk factors

The following risk factors arise from fundamental security properties required for all network infrastructure products:

[BL-RF-1] Initial configuration risk factor

This risk factor applies to all products when first deployed or after factory reset. Products shipped with insecure default configurations face immediate exploitation. Attackers scan networks for default credentials, open services, and weak settings within minutes of device connection. Default passwords enable automated attacks across product populations. Unnecessary services enabled by default expand attack surface without operational benefit. Products requiring manual security hardening remain vulnerable during initial deployment periods when administrators lack time or expertise to configure properly. Initial configuration weaknesses enable mass compromise, automated credential stuffing, and exploitation before administrators complete hardening.

[BL-RF-2] Lifecycle transition risk factor

This risk factor applies when products undergo decommissioning, service returns, ownership transfers, or equipment recycling. Products retaining configuration data during lifecycle transitions expose credentials, cryptographic keys, network topology, and operational logs to unauthorized parties. Service technicians accessing returned devices extract administrative credentials affecting other deployments. Recycled equipment leaks network architecture details to competitors or adversaries. Factory reset mechanisms failing to remove all data enable subsequent owners to access previous configurations. Incomplete data removal during ownership transfer compromises previous operators when

credentials persist. Lifecycle transition failures enable credential theft, reconnaissance using residual data, and unauthorized access by parties lacking legitimate rights.

[BL-RF-3] Availability disruption risk factor

This risk factor applies to all products providing network connectivity or critical services. Network infrastructure failures cascade through dependent systems affecting thousands of users simultaneously. Products lacking resilience mechanisms fail completely under attack or abnormal load regardless of processing capacity. Attackers flood services to exhaust resources, trigger defects causing crashes, or exploit protocol weaknesses disrupting operations. Products positioned at aggregation points create disproportionate impact when failures occur. Devices unable to recover automatically extend brief disruptions into prolonged outages requiring manual intervention. Resource exhaustion from legitimate traffic creates availability failures during peak usage. Availability failures enable attackers to disrupt critical services, prevent security updates, and mask concurrent attacks with operational chaos.

[BL-RF-4] System integrity compromise risk factor

This risk factor applies to all products executing firmware and software. Boot process compromise enables persistent implants surviving all software remediation attempts. Attackers achieving boot-level control subvert authentication, bypass access controls, extract cryptographic keys, establish covert channels, and modify audit systems hiding compromise evidence. Products booting unsigned firmware cannot distinguish legitimate updates from malicious modifications. Physical attackers install persistent malware through firmware chip replacement or boot storage modification. Boot-level implants reload with each power cycle maintaining control indefinitely. Runtime integrity failures enable attackers escalating from application exploits to system-level control. Integrity compromise provides complete control over all software security mechanisms.

[BL-RF-5] Packet processing risk factor

This risk factor applies to all products forwarding or processing network packets. Products process millions of packets daily where each represents potential exploitation when packet structures deviate from protocol specifications. Attackers craft malformed packets with invalid protocol combinations, unusual encapsulations, or deeply nested structures triggering buffer overflows, memory corruption, or undefined behaviour. Protocol fuzzing generates packet variations exposing implementation weaknesses. Products cannot validate every possible packet construction explicitly due to unbounded input space. Processing paths lacking explicit validation create exploitable conditions when encountering unexpected inputs. Uncertain packet handling decisions create security vulnerabilities where products forward or partially process packets they cannot fully validate. Packet processing failures enable remote code execution, system crashes, and security control bypass through protocol manipulation.

[BL-RF-6] Attack surface exposure risk factor

This risk factor applies to all products with network interfaces, management functions, and physical ports. Every exposed interface represents potential attack vector regardless of network location. Debug interfaces including JTAG, UART, and SWD provide complete system control through physical access. Test modes and diagnostic functions accessible without authentication enable configuration modification and credential extraction. Unused network services listening on interfaces expand attack surface without operational justification. Legacy protocols maintained for backward compatibility create permanent vulnerabilities. Management interfaces on data plane networks enable attacks from transit traffic. Physical console ports accessible in unsecured locations bypass all network security controls. Attack surface exposure enables attackers to exploit unnecessary interfaces, leverage debug functions for persistent access, and reach management capabilities from untrusted networks.

[BL-RF-7] Security event visibility risk factor

This risk factor applies to all products requiring breach detection, incident response, and compliance demonstration. Products lacking comprehensive audit logging operate as security blind spots where attacks proceed undetected. Failed authentication attempts indicating credential compromise go unrecorded. Session hijacking continues undetected without session lifecycle logging. Configuration changes weakening security lack accountability without audit trails. Authorization failures signalling privilege escalation attempts disappear without evidence. Products failing to persist logs across resets eliminate forensic evidence before analysis occurs. Incomplete logging prevents incident investigation, compliance demonstration, and security policy enforcement verification. Audit gaps enable attackers to erase compromise evidence, operate undetected during extended breach periods, and avoid detection of reconnaissance activities.

4.8.2.2 Management access risk factors

The following risk factors arise from management interface accessibility:

763 [MA-RF-1] Physical access exploitation risk factor

764 This risk factor applies when management requires physical presence at the device. Physical-only management
765 interfaces create unaudited configuration risk. Attackers with physical access can bypass all network security controls
766 through console ports, USB interfaces, or serial connections. Physical access enables configuration modification,
767 permanent security feature disabling, and credential extraction from device memory.

768 [MA-RF-2] Local network compromise risk factor

769 This risk factor applies when devices support management via protocols accessible from the local segment or broadcast
770 domain. Local network management access creates insider threat opportunities. Attackers on the same network segment
771 can reach management interfaces without crossing security boundaries. Local network access enables Layer 2 hijacking,
772 ARP spoofing attacks, and firewall rule bypassing.

773 [MA-RF-3] Internal network traversal risk factor

774 This risk factor applies when management interfaces accept routed connections within organizational perimeters.
775 Routable management interfaces enable lateral movement attacks. Compromised systems anywhere in the corporate
776 network can reach management functions across VLANs, VPNs, and WAN links. Internal network access enables
777 cross-site attacks, credential reuse, and pivot-based compromise.

778 [MA-RF-4] Global internet exposure risk factor

779 This risk factor applies when management interfaces accept connections from public IP addresses or cloud platforms.
780 Internet-accessible management creates continuous attack surface. Global adversaries can probe interfaces using
781 automated tools, zero-day exploits, and credential stuffing campaigns. Internet access enables mass compromise,
782 simultaneous global attacks, and nation-state targeting.

783 4.8.2.3 Management operational risk factors

784 The following risk factors arise from administration and update methods:

785 [MO-RF-1] Manual administration risk factor

786 This risk factor applies when devices support individual manual administration without network management system
787 integration. Manual control affects both configuration and updates. Security patches remain uninstalled for extended
788 periods, configurations drift between devices, and changes lack audit trails. Manual processes enable missed critical
789 updates, inconsistent security policies, human configuration errors, and indefinite vulnerability persistence.

790 [MO-RF-2] Centralized management compromise risk factor

791 This risk factor applies when devices support connection to network management systems or cloud platforms.
792 Centralized management systems become single points of catastrophic failure. Attackers who compromise the
793 management platform can control entire device fleets instantly. Management system access enables mass configuration
794 changes, fleet-wide backdoor installation, and supply chain attacks.

795 4.8.2.4 Protocol implementation risk factors

796 The following risk factors arise from network protocol implementations:

797 [PI-RF-1] Cleartext credential risk factor

798 This risk factor applies when devices support protocols that transmit authentication, commands, or data without
799 encryption. Unencrypted management protocols leak authentication credentials across networks. Attackers can capture
800 passwords with packet sniffers, modify configuration commands in transit, and replay captured sessions. Cleartext
801 transmission enables credential theft, command manipulation, and session hijacking.

802 [PI-RF-2] Unauthenticated request processing risk factor

803 This risk factor applies when devices implement protocols that accept requests without authentication. Open protocol
804 endpoints enable resource exhaustion attacks. Attackers can flood services with bogus requests, trigger expensive
805 operations, and amplify attacks using spoofed addresses. Unauthenticated processing enables denial of service, resource
806 depletion, and reflection attacks.

807 [PI-RF-3] Information disclosure risk factor

This risk factor applies when devices implement protocols that respond to unauthenticated information requests. Discovery protocols reveal attack blueprints to anonymous queries. Attackers can map network topology, identify software versions, and enumerate services without authentication. Information disclosure enables reconnaissance, vulnerability identification, and attack planning.

[PI-RF-4] Weak cryptography exploitation risk factor

This risk factor applies when devices support protocols using deprecated algorithms, short keys, or unevaluated cryptography. Outdated cryptographic algorithms guarantee future compromise. Attackers can break deprecated ciphers using cloud computing, force protocol downgrades, and decrypt stored traffic later. Weak cryptography enables cipher breaking, downgrade attacks, and retroactive decryption.

[PI-RF-5] Unverified trust establishment risk factor

This risk factor applies when devices implement protocols that make routing or security decisions without cryptographic verification. Protocols without cryptographic verification enable network manipulation. Attackers can inject false routing information, redirect traffic through malicious paths, and impersonate network devices. Unverified trust enables route hijacking, traffic redirection, and topology manipulation.

[PI-RF-6] Post-authentication cleartext risk factor

This risk factor applies when devices support protocols that authenticate peers but transmit subsequent data unencrypted. Authenticated but unencrypted sessions enable hijacking attacks. Attackers can steal active sessions after authentication, inject commands into authenticated channels, and extract flowing data. Post-authentication cleartext enables session theft, command injection, and data interception.

[PI-RF-7] Cryptographic session compromise risk factor

This risk factor applies when implementing encrypted, authenticated protocols with any software stack. Even encrypted protocols suffer implementation vulnerabilities. Attackers can exploit weak random number generators, extract keys through side channels, and leverage protocol-specific weaknesses. Implementation flaws enable key extraction, protocol attacks, and cryptographic bypass.

4.8.2.5 Data operations risk factors

The following risk factors arise from data import/export operations:

[DO-RF-1] Data transfer risk factor

This risk factor applies when the device supports configuration backup/restore, log export, firmware upload, or any file import/export operations. Data export functions leak sensitive configuration including credentials, network topology, and security policies. Attackers can inject malicious configurations through import functions, upload backdoored firmware, and exfiltrate operational data. Unvalidated imports enable arbitrary code execution and persistent compromise.

4.8.3 Risk factor assessment

4.8.3.1 General

The manufacturer shall assess and document which risk factors from clauses 4.8.2.1 through 4.8.2.5 apply to the product based on its intended purpose, reasonably foreseeable use, and conditions of use.

NOTE: The Risk Factor Assessment shall be included in the Declaration of conformity and in the product's technical documentation.

The Risk Factor Assessment identifies which risk factors apply to the product and therefore which security requirements from Clause 5 are applicable.

4.8.3.2 Content requirements

The Risk Factor Assessment shall include:

- a) Product identification (Manufacturer, Product name, Product version).
- b) Firmware/software version assessed.

- c) Assessment of each risk factor defined in clauses 4.8.2.1 through 4.8.2.5 according to the following categories:
- a. Applicable (Default): the risk factor applies in the factory default configuration.
 - b. Applicable (Configurable): the risk factor can apply through configuration.
 - c. Not Applicable: the risk factor cannot apply to the product.
 - d) Date of assessment.

4.8.3.3 Completeness

The manufacturer shall assess every risk factor defined in clauses 4.8.2.1 through 4.8.2.5. The assessment shall be documented in the Risk Factor Assessment using the template provided in Annex B.

A risk factor assessed as "Applicable (Configurable)" shall trigger the same requirements as a factor assessed as "Applicable (Default)".

4.8.3.4 Maintenance of the risk factor assessment

The manufacturer shall revise the Risk Factor Assessment when:

- (i) a new firmware or software version changes which risk factors apply,
- (ii) a hardware revision affects the product's risk factors, or
- (iii) when otherwise necessary.

The Risk Factor Assessment shall be maintained as part of the technical documentation.

4.8.4 Undeclared or misdeclared risk factors

Products are non-compliant with the present document when applicable risk factors differ from those documented in the Risk Factor Assessment. This applies when risk factors are present in any of the following scenarios:

- (i) default configuration creates the risk factor;
- (ii) documented configuration enables the risk factor; or
- (iii) undocumented procedures can establish the risk factor.

Two categories of violations shall result in non-compliance:

- (i) undeclared risk factors, when risk factors defined in clauses 4.8.2.1 through 4.8.2.5 apply to the product but are not identified in the Risk Factor Assessment; and
- (ii) misdeclared risk factors, when the Risk Factor Assessment incorrectly identifies which risk factors apply to the product.

When firmware or software updates introduce features that create new risk factors or change which factors apply, manufacturers shall revise the Risk Factor Assessment before releasing the update. Updates that trigger different risk factors require the updated product to meet all security requirements associated with those factors.

Failure to update the Risk Factor Assessment when applicable risk factors change, or releasing updates that modify which factors apply without ensuring compliance with newly applicable requirements, constitutes non-compliance with this document. This obligation continues throughout the product support lifecycle, ensuring security requirements remain aligned with the risk factors present in the product.

4.8.5 Mapping table: Requirements to risk factors

Risk Factor Code	Risk Factor Description	Applicable Requirements
MA-RF-1	Physical access exploitation risk factor	[AUTH-1-RQ-*], [AUTH-2-RQ-*], [LOG-RQ-*]

MA-RF-2	Local network compromise risk factor	[AUTH-1-RQ-*], [AUTH-3-RQ-*], [PACKET-RQ-*], [EXPOSURE-RQ-*]
MA-RF-3	Internal network traversal risk factor	[AUTH-1-RQ-*], [AUTH-3-RQ-*], [DATA-RQ-*]
MA-RF-4	Global internet exposure risk factor	[AUTH-1-RQ-*], [UPDATE-RQ-*], [INTEGRITY-RQ-*], [AVAIL-RQ-*]
MO-RF-1	Manual administration risk factor	[UPDATE-RQ-*], [DEFAULT-RQ-*], [LOG-RQ-*]
MO-RF-2	Centralized management compromise risk factor	[AUTH-4-RQ-*], [TRANSFER-RQ-*], [LOG-RQ-*]
PI-RF-1	Cleartext credential risk factor	[DATA-RQ-*], [AUTH-1-RQ-*]
PI-RF-2	Unauthenticated request processing risk factor	[PACKET-RQ-*], [AVAIL-RQ-*]
PI-RF-3	Information disclosure risk factor	[EXPOSURE-RQ-*], [DATA-RQ-*]
PI-RF-4	Weak cryptography exploitation risk factor	[DATA-RQ-*], [UPDATE-RQ-*]
PI-RF-5	Unverified trust establishment risk factor	[AUTH-4-RQ-*], [INTEGRITY-RQ-*]
PI-RF-6	Post-authentication cleartext risk factor	[DATA-RQ-*], [TRANSFER-RQ-*]
PI-RF-7	Cryptographic session compromise risk factor	[DATA-RQ-*], [UPDATE-RQ-*], [INTEGRITY-RQ-*]
DO-RF-1	Data transfer risk factor	[TRANSFER-RQ-*], [DATA-RQ-*], [AUTH-1-RQ-*]
BR-RF-1	Initial configuration risk factor	[DEFAULT-RQ-*]
BR-RF-2	Lifecycle transition risk factor	[RESET-RQ-*]
BR-RF-3	Availability disruption risk factor	[AVAIL-RQ-*]
BR-RF-4	System integrity compromise risk factor	[INTEGRITY-RQ-*]
BR-RF-5	Packet processing risk factor	[PACKET-RQ-*]
BR-RF-6	Attack surface exposure risk factor	[EXPOSURE-RQ-*]
BR-RF-7	Security event visibility risk factor	[LOG-RQ-*]

4.9 Users

Products interact with several user categories, each with distinct access levels and technical capabilities.

Professional network administrators configure and maintain these products. They understand how to implement security policies, analyse logs, and respond to incidents. Their privileged access requires strong authentication and accountability measures.

Service provider personnel install and maintain customer premises equipment in managed service environments. Their access covers service provisioning and troubleshooting functions; customer data and certain security settings remain restricted. This split access model reflects shared responsibility between service providers and customers.

End users in homes and small offices interact with product configuration through simplified interfaces. These users lack security expertise and may create vulnerabilities through weak passwords or misconfiguration. Consumer products balance usability with security through automated updates and secure defaults.

898 Management systems and orchestration platforms use programmatic interfaces to automate configuration and
899 monitoring. These automated systems need authentication and audit controls equal to human users, since their
900 compromise affects multiple products simultaneously.

901 4.10 Reasonably foreseeable use cases

902 4.10.1 Introduction

903 This clause identifies reasonably foreseeable use cases for routers, modems intended for connection to the internet, and
904 switches. Each describes a deployment pattern combining operational environment, management model, and
905 capabilities to determine applicable risk factors from clause **Error! Reference source not found.**

906 Economic operators shall apply these use cases to identify their products' intended purpose and reasonably foreseeable
907 use when completing the Condition Assessment (clause **Error! Reference source not found.**). A single product may
908 support multiple use cases, triggering applicable risk factors and corresponding security requirements from clause 5.

909 These use cases represent common deployment patterns across residential, commercial, industrial, and service provider
910 environments. They are neither exhaustive nor mutually exclusive. Products may support multiple use cases; economic
911 operators shall assess all applicable conditions.

912 4.10.2 Consumer premises equipment

913 4.10.2.1 Description

914 Consumer premises equipment comprises modems intended for connection to the internet and residential routers for
915 homes and small offices. These products connect private networks to internet service providers through cable, DSL,
916 fibre, or cellular connections and often incorporate wireless access point functionality.

917 End users manage products directly through simplified web interfaces or mobile applications, or service providers
918 manage them remotely through protocols such as TR-069 or TR-369. Automated provisioning systems or setup wizards
919 handle initial configuration.

920 4.10.2.2 Typical deployment characteristics

921 Products deploy in residential premises or small offices with minimal physical security. They remain powered
922 continuously and maintain connections to both private networks and public internet.

923 Management interfaces connect to the internet through either direct public IP address assignment or service provider
924 management platforms that establish connections from public networks. Local network users access management
925 interfaces through web browsers or mobile applications.

926 End users without cybersecurity expertise configure and maintain products, often retaining default credentials beyond
927 recommended periods. Service provider personnel remotely access products for provisioning, troubleshooting, and
928 firmware updates without customer involvement.

929 4.10.2.3 Security considerations

930 Products face continuous threat exposure from internet-connected attackers conducting automated vulnerability
931 scanning and exploitation. Weak default credentials, unpatched vulnerabilities, and exposed management interfaces
932 enable unauthorized access. Compromised devices attack connected home networks, join distributed denial of service
933 botnets, and intercept user communications.

934 Service provider remote management creates supply chain dependencies. Compromised provisioning systems or
935 credentials affect many customer devices simultaneously. Unencrypted management protocols expose configuration
936 data and credentials during transmission.

937 4.10.3 Small business network infrastructure

938 4.10.3.1 Description

939 Small business network infrastructure includes routers and managed switches deployed in small and medium enterprises
940 for office networking, point-of-sale systems, and business internet connectivity. These products segment networks

among employee workstations, guest access, and business systems while providing internet connectivity and basic security controls.

Local IT staff or managed service providers configure and maintain these products through direct network access or remote VPN connections. Configuration complexity ranges from basic VLAN and firewall rules to advanced routing protocols and quality of service policies.

4.10.3.2 Typical deployment characteristics

Products deploy in office buildings, retail locations, or warehouses with varying physical security from locked server closets to publicly accessible areas. They operate continuously with occasional maintenance windows for updates and configuration changes.

Local networks provide management interface access, potentially spanning multiple office locations through site-to-site VPN or MPLS connections. IT staff or managed service providers manage remotely through VPN connections rather than direct internet exposure.

IT personnel with varying expertise perform configuration and maintenance. Managed service providers may administer multiple client networks through centralized management tools. Network segmentation or administrative access controls prevent business network users from accessing management interfaces.

4.10.3.3 Security considerations

Products in business environments handle sensitive commercial data and provide connectivity for critical business operations. Compromised switches or routers enable traffic interception, network disruption, and lateral movement to compromise connected systems. Inadequate network segmentation allows attackers to reach management interfaces from user networks.

Managed service provider access creates shared credential risks affecting multiple client organizations. Insecurely stored configuration backup files expose network topology and security policies. Insufficient logging and monitoring prevents timely detection of unauthorized access or configuration tampering.

4.10.4 Enterprise managed network infrastructure

4.10.4.1 Description

Enterprise managed network infrastructure comprises switches, routers, and related devices that large organizations deploy in networks managed by dedicated IT and security teams. These products form hierarchical network architectures with core, distribution, and access layers. They implement complex routing protocols, extensive security policies, and integrate with network management platforms.

Professional network administrators configure products through standardized processes: change control, configuration management databases, and automated deployment tools. Products integrate with monitoring systems, logging infrastructure, and security information and event management platforms.

4.10.4.2 Typical deployment characteristics

Products operate in data centres, telecommunications rooms, and equipment closets with physical access controls, environmental monitoring, and backup power systems. Redundant configurations with automated failover mechanisms ensure availability.

Dedicated out-of-band management networks or in-band management VLANs with strict access controls provide management interface access. Remote administration occurs through jump hosts, privileged access workstations, or secure remote access infrastructure rather than direct internet connectivity.

Network engineers and administrators with professional training perform configuration and maintenance following documented procedures. Changes undergo approval workflows and testing before production deployment. Automated systems handle routine configuration tasks, backups, and compliance verification.

4.10.4.3 Security considerations

Enterprise networks contain valuable intellectual property, customer data, and business-critical systems that attract sophisticated adversaries. Compromised network infrastructure enables persistent access, traffic interception across organizational boundaries, and attacks on connected enterprise systems.

Complex network architectures with numerous interconnections create larger attack surfaces demanding comprehensive security controls. Legacy protocol requirements for interoperability with older equipment often force weak authentication or encryption. Administrative access from multiple IT team members demands robust role-based access controls and comprehensive audit logging.

4.10.5 Internet-facing enterprise edge devices

4.10.5.1 Description

Internet-facing enterprise edge devices are positioned at organizational network boundaries that connect private networks to internet service providers or business partners. These products implement security policies controlling traffic between trusted internal and untrusted external networks, often incorporating firewall, VPN, and intrusion detection capabilities.

Organizations deploy these products with heightened security configurations and monitoring because of direct internet exposure. Security teams monitor edge devices for compromise indicators and respond rapidly to incidents affecting boundary protection.

4.10.5.2 Typical deployment characteristics

Secure data centres or telecommunications rooms with physical access controls and 24/7 monitoring house these devices. Redundant devices provide high availability for critical internet connectivity.

Data plane interfaces connect directly to public internet or service provider networks, processing traffic from arbitrary sources. Management interfaces should remain accessible only from internal management networks, but misconfigurations or operational requirements sometimes expose them to public networks.

Network security engineers with specialized training configure and monitor devices. Security operations centres receive alerts for suspicious activity. Incident response procedures address detected compromises or attacks targeting edge infrastructure.

4.10.5.3 Security considerations

Direct internet connectivity exposes devices to continuous attacks from global threat actors. Compromised edge devices enable attackers to intercept traffic, map networks, and attack internal systems.

Exposing management interfaces to public networks, even unintentionally, creates critical vulnerabilities requiring immediate remediation. Sophisticated attackers target zero-day vulnerabilities in edge device protocol implementations for their strategic value.

4.10.6 Service provider network infrastructure

4.10.6.1 Description

Service provider network infrastructure comprises carrier-grade products deployed by internet service providers, telecommunications carriers, and managed service providers. These products aggregate customer connections, route backbone traffic, engineer network paths, and deliver services at scale.

Operations teams manage thousands of devices through centralized network management systems and orchestration platforms. Automated provisioning systems deploy standardized configurations. Monitoring systems collect real-time telemetry for capacity planning, troubleshooting, and service assurance.

4.10.6.2 Typical deployment characteristics

Carrier-grade facilities including central offices, points of presence, and data centres provide the physical environment with stringent physical security, environmental controls, and operational procedures. Equipment operates under strict availability requirements with extensive redundancy.

Dedicated service provider management networks or controlled connections from operations centres provide management plane access. Some devices require remote emergency access capabilities for rapid response to service-affecting incidents.

1030 Network operations personnel follow rigorous change management procedures. Automated systems perform most
1031 configuration changes. Multiple administrative roles with segregated responsibilities enforce least privilege and
1032 separation of duties.

1033 4.10.6.3 Security considerations

1034 Service provider infrastructure forms high-value targets enabling widespread attacks on many customers. Compromised
1035 devices enable traffic interception across multiple customer networks, service disruption across regions or entire
1036 networks, and attacks on third parties through provider infrastructure.

1037 Exploited protocol vulnerabilities affect internet routing globally. Customer isolation failures allow cross -customer
1038 attacks. Management system compromise affects thousands of device configurations. Regulatory requirements mandate
1039 additional capabilities and data retention requiring strong security controls.

1040 4.10.7 Critical infrastructure network devices

1041 4.10.7.1 Description

1042 Critical infrastructure network devices support operational technology and industrial control system networks across
1043 sectors. These products enable communication between supervisory control and data acquisition systems,
1044 programmable logic controllers, remote terminal units, and human-machine interfaces.

1045 Network configurations often implement airgaps or unidirectional gateways that separate operational technology
1046 networks from corporate IT networks. Internet connectivity, when present, flows through multiple security boundaries
1047 with monitoring and filtering at each layer. Products often remain in service for extended periods matching operational
1048 technology equipment lifecycles.

1049 4.10.7.2 Typical deployment characteristics

1050 Products operate in industrial facilities with physical access controls appropriate to critical operations. They have to
1051 withstand temperature extremes, vibration, and electromagnetic interference.

1052 Many deployments maintain air-gapped networks with no internet connectivity. Others implement controlled
1053 connections through firewalls, intrusion detection systems, and security monitoring. Remote access for vendors or
1054 operational support occurs through carefully controlled VPN connections with extensive logging.

1055 Control system engineers and operational technology specialists perform configuration and maintenance during
1056 scheduled outages to avoid disrupting critical processes. Some devices undergo minimal configuration changes after
1057 initial commissioning. Security updates follow extensive testing protocols to ensure no impact on real -time control
1058 system operations.

1059 4.10.7.3 Security considerations

1060 Critical infrastructure network compromise affects public safety, environmental protection, and essential services.
1061 Attackers targeting these environments possess significant capabilities and persistence. Disruption of industrial control
1062 system communications causes physical equipment damage, environmental releases, or loss of critical services to large
1063 populations.

1064 Long operational lifecycles challenge vulnerability management because devices require extensive testing and
1065 scheduled outages before updates. Legacy industrial protocols lack authentication and encryption, requiring defence-in-
1066 depth strategies. Insider threats from contractors or disgruntled personnel demand strong access controls and audit
1067 logging.

1068 4.10.8 Virtualized network functions

1069 4.10.8.1 Description

1070 Virtualized network functions implement routing, switching, and security capabilities as software on commodity
1071 hardware or cloud infrastructure rather than purpose-built appliances. These virtual routers and switches operate as
1072 virtual machines, containers, or cloud-native network functions in private, public, or hybrid clouds.

1073 Orchestration platforms dynamically instantiate, scale, and configure virtual network functions to meet traffic demands
1074 and service requirements. Infrastructure-as-code practices manage configurations through version-controlled templates.
1075 API-driven management integrates products with cloud management platforms and continuous integration pipelines.

1076 4.10.8.2 Typical deployment characteristics

1077 Products deploy on virtualized compute infrastructure in data centres or distributed edge computing locations. Physical
1078 security protects underlying infrastructure rather than individual virtual network function instances. Infrastructure
1079 operates under hypervisors, container orchestrators, or cloud service provider management.

1080 Virtualized management networks, cloud provider virtual private clouds, or software-defined networking control planes
1081 provide management interface access. Cloud architecture determines which network locations can access API endpoints
1082 for orchestration and configuration.

1083 Cloud architects and DevOps engineers deploy and configure virtual network functions through infrastructure-as-code,
1084 command-line tools, or web-based cloud consoles. Automated systems handle scaling, failover, and configuration
1085 updates based on policies and service demands. Highly automated environments may limit traditional network
1086 engineers' direct access.

1087 4.10.8.3 Security considerations

1088 Virtualized network functions introduce hypervisor and container runtime dependencies that create additional attack
1089 surfaces. Hypervisor compromise affects all virtual network functions on shared infrastructure. East-west traffic
1090 between virtual functions may bypass traditional security controls without proper architecture.

1091 Multi-tenant cloud environments demand strong isolation between customer virtual network functions. Orchestration
1092 API security is critical because compromised orchestration credentials allow attackers to instantiate malicious network
1093 functions or tamper with legitimate configurations. Rapid scaling and deployment through automation demand security
1094 controls that operate at cloud speed without manual review delays.

1095 4.11 Context summary

1096 Routers, modems intended for connection to the internet, and switches operate in diverse contexts that prevent uniform
1097 security requirements. These products operate in environments ranging from physically secured data centres with
1098 professional administration to residential settings with minimal oversight and no physical access controls. They serve
1099 networks processing casual home internet traffic and critical infrastructure control systems where availability affects
1100 public safety.

1101 Several critical dimensions influence security requirements. Products with internet-exposed management interfaces face
1102 different threats than those accessible only through physical console ports. Centrally managed products receive
1103 coordinated security updates within hours of vulnerability disclosure, while individually administered devices may
1104 operate for months with known vulnerabilities. Asset value correlates directly with attacker sophistication and
1105 persistence. Protected assets range from personal browsing data to financial transactions and industrial control systems.

1106 These factors establish the foundation for the conditional applicability model in clause **Error! Reference source not**
1107 **found..** Security measures necessary for carrier-grade routers processing millions of subscriber connections differ
1108 substantially from those for small office switches with local management only. Understanding operational contexts,
1109 threat exposures, and deployment constraints enables security requirements that provide appropriate protection without
1110 imposing unnecessary complexity where such measures provide no benefit.

1111 This comprehensive product context enables the risk-based approach that follows, ensuring each implementation
1112 receives security controls proportionate to actual threat exposure and operational constraints rather than theoretical risk
1113 disconnected from deployment reality.

1114 5 Cybersecurity requirements

1115 5.1 General

1116 This clause establishes cybersecurity requirements for products within the scope of the present document. The
1117 requirements implement the essential cybersecurity requirements specified in Annex I Part I of Regulation (EU)
1118 2024/2847.

1119 Each requirement in this section according to risk assessment from previous section.

1120 The requirements address the security properties necessary for routers, modems intended for connection to the internet,
1121 and switches operating in various deployment contexts and threat environments. The conditional applicability ensures
1122 proportionate security measures while maintaining essential security properties across all product implementations.

1123 5.2 Secure by design

1124 5.2.1 General

1125 Routers, modems intended for the connection to the internet, and switches shall implement secure by design principles
1126 throughout their lifecycle by applying the horizontal requirements established in PT1 (General principles for cyber
1127 resilience), with additional considerations specific to their role in network connectivity and traffic management.

1128 5.2.1.1 Requirements

1129 [SBD-1-RQ-1-1] The product shall implement all applicable requirements from PT1 General principles for cyber
1130 resilience, including but not limited to: (i) risk assessment and treatment processes; (ii) security activities across all
1131 lifecycle stages; (iii) secure development and implementation; and (iv) secure production practices.

1132 5.3 No known exploitable vulnerabilities

1133 5.3.1.1 General

1134 The manufacturer of routers, modems intended for the connection to the internet, and switches shall implement
1135 vulnerability identification and remediation processes throughout development and the whole lifetime, applying the
1136 horizontal requirements established in PT3 (Vulnerability Handling), with additional considerations specific to their
1137 role in network connectivity and traffic management.

1138 5.3.1.2 Requirements

1139 [NKV-1-RQ-1-01] The manufacturer shall implement all applicable requirements from PT3 Vulnerability Handling
1140 Requirements, ensuring that comprehensive vulnerability identification processes are applied before market release.

1141 [NKV-1-RQ-1-02] The manufacturer shall implement all applicable requirements from PT3 Vulnerability Handling
1142 Requirements, ensuring that all identified known exploitable vulnerabilities are remediated or, for low severity
1143 vulnerabilities identified after development has finished, documented including plans for addressing them.

1144 [NKV-1-RQ-1-03] The manufacturer shall implement all applicable requirements from PT3 Vulnerability Handling
1145 Requirements, ensuring that third-party components are assessed against assessment of third-party components has been
1146 performed.

1147 5.4 Secure by default configuration

1148 5.4.1 [DEFAULT] Secure by default configuration

1149 5.4.1.1 General

1150 Routers, modems intended for connection to the internet, and switches shall include security controls configured and
1151 enabled from initial deployment to protect against exploitation attempts that often occur within minutes of network
1152 connection. The default configuration establishes the security baseline that many users, particularly in residential and
1153 small business deployments, shall operate with minimal or no modification throughout the product lifecycle.

1154 For tailor-made products, the manufacturer and business user may agree to omit requirements specified in the subclause
1155 of the present document.

1156 5.4.1.2 Requirements

1157 [DEFAULT-1-RQ-1-01] Applicable requirements from the present document may only be disabled in the factory
1158 default state when (i) enabled applicable requirements from the present document would render the initial product setup
1159 process non-functional, and (ii) omitted applicable requirements from the present document are documented in
1160 instructions to the user.

- 1161 [DEFAULT-1-RQ-1-02] The product, in its factory default state, shall utilize only those network interfaces and services
1162 that are necessary for product setup.
- 1163 [DEFAULT-1-RQ-1-03] The product, during initialization, shall limit access to accounts with initialization permissions.
- 1164 [DEFAULT-1-RQ-1-04] The product shall enforce the principle of least privilege during normal operation.
- 1165 [DEFAULT-1-RQ-1-05] The product, in its factory default state, shall allow access only using accounts and methods
1166 documented in the instructions to the user.
- 1167 [DEFAULT-1-RQ-1-06] The product shall protect remote diagnostic interfaces with authentication and authorization
1168 controls.
- 1169 [DEFAULT-1-RQ-1-07] The product, in its factory default state, shall enforce change of administrative credentials.
- 1170 [DEFAULT-1-RQ-1-08] The product, in its factory default state and before initialization, shall have debugging and
1171 diagnostic interfaces disabled.
- 1172 [DEFAULT-1-RQ-1-09] The product, in its factory default state, shall enable security audit events logging for
1173 authentication attempts, configuration changes, and product errors.
- 1174 [DEFAULT-1-RQ-1-10] The product, in its factory default state, shall configure all cryptographic functions to use
1175 algorithms and key lengths that comply with current recognized standards.
- 1176 [DEFAULT-1-RQ-1-11] The product, in its factory default state, shall disable any protocols or services that have
1177 known exploitable vulnerabilities.

1178 5.4.2 [RESET] Factory reset

1179 5.4.2.1 General

- 1180 Factory reset mechanisms shall remove all data and user configurations while leaving the current running software and
1181 the firmware versions in place. The factory reset deletes also the user login credentials leading to the initial setup
1182 procedures.

1183 5.4.2.2 Requirements

- 1184 [RESET-1-RQ-1-01] The product shall provide a factory reset mechanism that restores the product to its secure-by-
1185 default configuration.
- 1186 [RESET-1-RQ-1-02] The product shall provide a factory reset mechanism that maintains the currently installed
1187 firmware version and all applied security updates.
- 1188 [RESET-1-RQ-1-03] The product shall require authentication and authorization at the highest privilege level for any
1189 factory reset initiated through software, management interface, or remote command.
- 1190 [RESET-1-RQ-1-04] Upon successful factory reset, the product shall not retain any information that could be used to
1191 reconstruct previous configuration or compromise user privacy.

1192 5.5 Security Updates

1193 5.5.1 [UPDATE] Update mechanisms

1194 5.5.1.1 General

- 1195 This clause establishes requirements for delivering and installing security remedies to address vulnerabilities throughout
1196 the product lifetime. Given that products can remain deployed for extended periods and may serve as critical
1197 infrastructure, robust update mechanisms are essential for maintaining security posture against evolving threats.

1198 5.5.1.2 Requirements

- 1199 [UPDATE-1-RQ-1-01] The product shall provide mechanisms to receive and install remedies throughout the defined
1200 support period.
- 1201 [UPDATE-1-RQ-1-02] The product shall ensure the update mechanism is automated and activated by default.

1202 [UPDATE-1-RQ-1-03] The product shall ensure the update mechanism depends on user configurations and operates
1203 automatically following the user configuration.

1204 [UPDATE-1-RQ-1-04] The product shall implement protection preventing unauthorized and unauthenticated
1205 installation of remedies.

1206 [UPDATE-1-RQ-1-05] The product shall implement cryptographic verification of remedy to ensure authenticity and
1207 integrity.

1208 NOTE: For the present context, best practice cryptography covers the standards that are publicly endorsed, accepted
1209 and recommended. These standards can be obtained from the European Union Agency for Cybersecurity [ENISA] and
1210 are accepted among all EU member states.

1211 [UPDATE-1-RQ-1-06] The manufacturer shall ensure that any update maintains or improves the product's security
1212 properties.

1213 [UPDATE-1-RQ-1-07] The product shall generate audit events for all update activities including (i) applicable remedy
1214 availability, (ii) download initiation and completion; and (iii) installation success or failure.

1215 [UPDATE-1-RQ-1-08] The product shall store audit events in persistent memory that survives the reset.

1216 5.6 Access Control

1217 5.6.1 [AUTH-1] Authentication

1218 5.6.1.1 General

1219 Authentication forms the fundamental security barrier preventing unauthorized modification of product. Given the
1220 critical role these products play in network connectivity and data routing, compromise of access controls can lead to
1221 widespread network disruption, data interception, or malicious traffic redirection. This subclause establishes
1222 requirements ensuring that only authorized users can access product management functions.

1223 5.6.1.2 Requirement

1224 [AUTH-1-RQ-1-01] The product shall implement user authentication mechanism.

1225 [AUTH-1-RQ-1-02] The product shall eliminate shared default credentials by either: (i) generating unique credentials
1226 during secure production; or (ii) enforcing mandatory credential creation during initial setup.

1227 [AUTH-1-RQ-1-03] The product shall ensure authentication credentials are transmitted exclusively through channels
1228 that provide best practice cryptographic protection. All authentication exchanges shall (i) use secure communication
1229 channels that provide confidentiality and integrity protection using best practice cryptography; and (ii) implement best
1230 practice mechanisms that prevent disclosure of secrets even over unencrypted channels.

1231 [AUTH-1-RQ-1-04] The product shall store secrets using best practice cryptographic methods.

1232 [AUTH-1-RQ-1-05] The product shall enforce credential entropy through character complexity and minimum length
1233 requirements.

1234 [AUTH-1-RQ-1-06] The product shall implement authentication failure protection, including but not limited to: (i)
1235 progressive delays between failed attempts, and (ii) temporary account lockout after certain number of failed attempts.

1236 [AUTH-1-RQ-1-07] The product shall maintain history of previously used passwords, in their processed form, to
1237 prevent reuse. The minimal number of previous passwords that shall be kept is one. Based on the assessment of the risk
1238 the product will be exposed, manufacturer may increase this default as appropriate. Password changes shall be validated
1239 against this history before acceptance.

1240 NOTE: Historical passwords are subject to the same storage security requirements as current credentials per
1241 [AUTH-1-RQ-1-04].

1242 5.6.2 [AUTH-2] Authorization

1243 5.6.2.1 General

1244 This clause establishes requirements for controlling what authenticated users can do on product. While authentication
1245 verifies user identity, access control ensures users can only perform actions appropriate to their role. This is critical for
1246 product as different users require different privileges.

1247 5.6.2.2 Requirements

1248 [AUTH-2-RQ-1-01] The product shall implement a privilege separation mechanism that requires user authentication
1249 before granting administrative access.

1250
1251 [AUTH-2-RQ-1-02] The product shall not allow any user to perform actions beyond their authorized privilege level.
1252

1253 [AUTH-2-RQ-1-03] The product shall enforce access control on all management interfaces consistently, preventing
1254 privilege escalation through alternative interfaces.

1255
1256 [AUTH-2-RQ-1-04] The product shall implement command authorization that validates each command based on the
1257 authorized privilege level before execution.

1258 5.6.3 [AUTH-3] Authenticated session lifecycle

1259 5.6.3.1 General

1260 This subclause establishes requirements for managing the lifecycle of authenticated sessions, from establishment
1261 through termination, ensuring that the security context created through authentication (subclause 5.6.1) and
1262 authorization (subclause 5.6.2) is properly maintained throughout the user's interaction with the product. Session
1263 management forms a critical security control that preserves the integrity of authenticated access and prevents
1264 unauthorized actions through session compromise.

1265 Given that products often remain accessible continuously and may be managed from various locations and interfaces
1266 simultaneously, robust session controls are essential to prevent unauthorized configuration changes that could
1267 compromise entire network segments. Session management vulnerabilities such as hijacking, fixation, or replay attacks
1268 can lead to complete product compromise even when strong authentication mechanisms are in place.

1269 5.6.3.2 Requirements

1270 These requirements are applicable when risk factor [MA-RF-2] or [MA-RF-3] or [MA-RF-4] is present:

1271 [AUTH-3-RQ-1-01] The product shall generate cryptographically secure session identifiers using best practice
1272 technology. Session identifiers shall be unique, non-predictable, and resistant to brute force attacks.

1273 [AUTH-3-RQ-1-02] The product shall implement session timeout mechanisms with configurable idle timeout periods
1274 and appropriate default values.

1275 [AUTH-3-RQ-1-03] The product shall invalidate sessions immediately upon (i) user-initiated logout; (ii) timeout
1276 expiration; (iii) authentication credential change; or (iv) administrative termination. Session invalidation shall securely
1277 remove all session data.

1278 [AUTH-3-RQ-1-04] The product shall protect session identifiers by (i) transmitting them only over secure channels that
1279 provide confidentiality and integrity protection; (ii) implementing appropriate session token protection mechanisms for
1280 the interface type; and (iii) preventing session identifiers from appearing in audit events, logs, URLs, or error messages.

1281 [AUTH-3-RQ-1-05] The product shall implement protection against session fixation by generating new session
1282 identifiers (i) upon successful authentication; (ii) before privilege elevation; (iii) when switching between security
1283 contexts; or (iv) when transitioning between untrusted and trusted network zones.

1284 [AUTH-3-RQ-1-06] The product shall limit concurrent sessions to a configurable maximum per user account.

1285 [AUTH-3-RQ-1-07] The product shall implement session security that detects privilege escalation attempts.

1286 5.6.4 [AUTH-4] Protocol access control

1287 5.6.4.1 General

1288 This subclause establishes requirements for administrative control over network protocols available on the product.
1289 Only authenticated and authorized users shall be permitted to enable, disable, or configure network protocols. Once
1290 enabled by an authorized user, protocols may operate according to their specifications, including those that inherently
1291 lack authentication mechanisms for protocol-level interactions.

1292 5.6.4.2 Requirements

1293 [AUTH-4-RQ-1-01] Applicable when any risk factor [PI-RF-1] through [PI-RF-5] is present: The product shall require
1294 authentication and authorization for any administrative action to enable, disable, or configure these protocols.
1295 Administrative interfaces that control protocol behaviour shall be protected regardless of whether the protocols
1296 themselves support authentication.

1297
1298 [AUTH-4-RQ-1-02] Applicable when risk factor [PI-RF-1] is present: The product shall provide secure alternative
1299 protocols alongside cleartext management protocols and generate warnings when cleartext protocols are used.

1300
1301 [AUTH-4-RQ-1-03] Applicable when risk factor [PI-RF-2] is present: The product shall implement rate limiting and
1302 source validation if possible, for unauthenticated protocol requests to mitigate spoofing and injection attacks.

1303
1304 [AUTH-4-RQ-1-04] Applicable when risk factor [PI-RF-3] is present: The product shall provide configuration options
1305 to disable or limit information disclosure through diagnostic protocols.

1306
1307 [AUTH-4-RQ-1-05] Applicable when risk factor [PI-RF-4] is present: The manufacturer shall document all
1308 cryptographic algorithms and provide configuration options to disable weak protocol versions.

1309
1310 [AUTH-4-RQ-1-06] Applicable when risk factor [PI-RF-5] is present: The product shall implement additional
1311 validation mechanisms for trust establishment and provide audit logging for all trust relationship changes.

1312 5.7 Data Protection

1313 5.7.1 General

1314 This subclause establishes requirements for protecting data confidentiality, integrity, and minimization throughout the
1315 product lifecycle. Data protection encompasses three fundamental principles: (i) confidentiality ensures that sensitive
1316 information remains accessible only to authorized entities; (ii) integrity guarantees that data cannot be modified without
1317 authorization; and (iii) data minimization limits collection and retention to what is necessary for intended functions. The
1318 implementation of these principles address all data types processed by the product, with protection measures
1319 appropriate to operational requirements and threat exposure. Security controls prevent both passive interception and
1320 active manipulation of data while maintaining product functionality and performance requirements.

1321 5.7.2 Requirements

1322 [DATA-1-RQ-1-1] The product shall implement data protection measures ensuring all sensitive data including
1323 passwords, application-level cryptographic keys, and user credentials are encrypted at rest using best practice
1324 cryptographic algorithms.

1325 [DATA-1-RQ-1-2] The product shall implement data protection measures ensuring all management communications
1326 employ encrypted channels providing both confidentiality and integrity protection through best practice cryptography.

1327 [DATA-1-RQ-1-3] The product shall implement data protection measures ensuring configuration files and firmware
1328 images are protected against unauthorized modification.

1329 [DATA-1-RQ-1-4] The product shall implement data protection measures ensuring the product processes and retains
1330 only the minimum data necessary for its intended routing, switching, or modem functions. Any diagnostic or telemetry
1331 data collection beyond intended purpose of the product shall require explicit opt-in configuration, with such collection
1332 disabled by default.

1333 5.8 Availability and Resilience

1334 5.8.1 General

1335 This subclause establishes requirements for maintaining essential functions and preventing service disruptions,
1336 including protection against denial-of-service attacks. Availability and resilience encompass two core objectives: (i)
1337 maintaining operational continuity of essential functions during and after security incidents; and (ii) preventing the
1338 product from being used as a vector to disrupt other networks or services. The implementation of these objectives
1339 ensure that products can detect, withstand, and recover from attacks while preserving core network operations.

1340 5.8.2 Requirements

1341 [AVAIL-1-RQ-1-1] The product shall maintain resilience against denial-of-service attacks using appropriate techniques
1342 which include but are not limited to: (i) rate limiting and (ii) connection throttling for supported network protocols.

1343 [AVAIL-1-RQ-1-2] The product shall automatically recover to normal operational state when denial-of-service
1344 conditions cease, without requiring manual intervention.

1345 [AVAIL-1-RQ-1-3] The product shall generate audit events when: (i) it detects high resource utilisation (e.g., sustained
1346 high CPU utilisation, memory exhaustion, high packet drop count and similar); and (ii) when resource utilisation returns
1347 to levels designated by the manufacturer as “normal”.

1348 [AVAIL-1-RQ-1-4] The product shall store audit events in persistent memory that survives the reset.

1349 5.9 Attack Surface and Mitigation

1350 5.9.1 [INTEGRITY] System integrity and boot process

1351 5.9.1.1 General

1352 This section establishes requirements for ensuring the integrity of product throughout their operational lifecycle, from
1353 initial power-on through runtime operation. System integrity forms the foundational trust anchor upon which all other
1354 security controls depend. A compromised boot process or runtime environment can subvert authentication, bypass
1355 access controls, and provide persistent unauthorized access that survives reboots and firmware updates.

1356 The boot process represents a critical attack surface where malicious actors attempt to install persistent implants, bypass
1357 security controls, or extract cryptographic materials. Given that product often operate autonomously for extended
1358 periods and control critical network functions, ensuring boot integrity and maintaining runtime security are essential for
1359 preventing sophisticated attacks that could compromise entire network segments.

1361 5.9.1.2 Requirements

1362 [INTEGRITY-1-RQ-1-01] The product shall implement cryptographic verification of boot components using best
1363 practice cryptographic methods.

1364 [INTEGRITY-1-RQ-1-02] The product shall establish a secure boot chain where (i) each stage verifies the next stage
1365 before transferring control; (ii) the initial bootloader is immutable or hardware-protected; (iii) verification failures halt
1366 the boot process; and (iv) only verified code can execute during normal boot.

1367 [INTEGRITY-1-RQ-1-03] The product shall generate audit events of all boot events including (i) boot stage
1368 progression with timestamps; (ii) verification, either success or failure, for each component; (iii) recovery mode
1369 activation; and (iv) detected bypass attempts.

1370 [INTEGRITY-1-RQ-1-04] The product shall store audit events in persistent memory that survives the reset.

1371 [INTEGRITY-1-RQ-1-05] The product shall protect recovery and maintenance modes, if present, by implementing
1372 authentication and authorization before granting access.

1373 5.9.2 [PACKET] Default packet disposition

1374 5.9.2.1 General

1375 Routers, modems intended for connection to the internet, and switches implement packet processing through various
1376 architectural approaches optimized for their intended deployment scenarios. While validation covers standardized
1377 protocols and expected traffic patterns, the theoretical space of all possible packet constructions remains unbounded.
1378 Packets with unexpected protocol combinations, unusual encapsulations with non-standard extension headers, or deeply
1379 nested tunnelling may fall outside validated processing paths. When packet processing components encounter formats
1380 for which no validated processing path exists, the product requires deterministic behaviour to maintain security and
1381 availability. The absence of explicit handling procedures for such packets could otherwise result in undefined states,
1382 memory corruption, or unpredictable behaviour.

1383 Products shall implement deterministic behaviour when encountering packets outside their processing domain rather
1384 than attempting best-effort processing that may trigger undefined behaviour in hardware acceleration engines or
1385 software protocol stacks.

1386 This requirement applies to all products within scope regardless of deployment context, as the inability to safely handle
1387 unexpected packets represents a fundamental security vulnerability that can be exploited from any network position.
1388 The requirement establishes that products shall default to dropping packets rather than forwarding or processing them
1389 when the correct action cannot be determined with certainty.

1390 5.9.2.2 Requirements

1391 [PACKET-1-RQ-1-01] The product shall drop any packet for which it cannot determine the appropriate processing
1392 action based on implemented protocol handlers, forwarding rules, or state machines. This includes (i) packets with
1393 unrecognized protocol identifiers or type fields; (ii) packets with invalid or unexpected encapsulation combinations; (iii)
1394 packets that would require processing beyond the product's implemented protocol stack depth; (iv) packets with header
1395 field values outside the ranges specified in relevant protocol standards; (v) packets that cannot be matched to existing
1396 connection state for stateful protocols; and (vi) any packet that would trigger undefined behaviour in product.

1397 [PACKET-1-RQ-1-02] The product shall not attempt partial processing, best-effort forwarding, or fallback handling for
1398 packets that cannot be fully validated against implemented protocol specifications. When packet processing uncertainty
1399 exists at any protocol layer, the entire packet shall be dropped rather than processed at other layers.

1400 5.9.3 [EXPOSURE] Interface and service exposure minimization

1401 5.9.3.1 General

1402 This subclause establishes requirements for minimizing the attack surface by limiting exposed interfaces and services.
1403 Products shall implement the principle of least functionality, exposing only those interfaces and services necessary for
1404 their intended operation. Given that each exposed interface represents a potential attack vector, systematic reduction of
1405 unnecessary exposure directly reduces the probability of successful exploitation.

1406 5.9.3.2 Requirements

1407 [EXPOSURE-1-RQ-1-01] The product shall disable all interfaces and services that are not essential for the product's
1408 intended function in its default configuration, including but not limited to: (i) debug interfaces such as JTAG, UART,
1409 and SWD unless physically secured; (ii) unused network protocols and services; (iii) test modes and diagnostic
1410 functions not required for normal operation; (iv) legacy protocols maintained only for backward compatibility when not
1411 actively required; and (v) any management interfaces beyond those explicitly documented for user access.

1412 [EXPOSURE-1-RQ-1-02] The product shall provide capability to selectively enable or disable individual services and
1413 interfaces through configuration.

1414 5.10 Monitoring and Logging

1415 5.10.1.1 General

1416 This subclause establishes requirements for recording and monitoring security-relevant activities to enable incident
1417 detection, forensic analysis, and compliance verification. Monitoring and logging captures authentication attempts,
1418 configuration changes, system events, and administrative actions that affect product security posture. Event data is

1419 protected against unauthorized modification or deletion, with configurable retention periods and logging scope based on
1420 operational requirements and resource constraints.

1421 5.10.1.2 Requirements

1422 [LOG-1-RQ-1-01] The product shall generate audit events for authentication activities including but not limited to: (i)
1423 successful or failed authentication; (ii) account lockout triggers and releases; and (iii) authentication credential change
1424 attempts.

1425 [LOG-1-RQ-1-02] The product shall generate audit events for all session lifecycle activities including (i) session
1426 establishment with source details; (ii) session termination with reason; (iii) failed session validation attempts; and (iv)
1427 concurrent session limit violations.

1428 [LOG-1-RQ-2-03] The product shall implement command authorization that creates audit events of unauthorized
1429 commands.

1430 [LOG-1-RQ-2-04] The product shall store audit events in persistent memory that survives the reset.

1431 5.11 Data Management

1432 5.11.1 [TRANSFER] Secure data export and transfer

1433 5.11.1.1 General

1434 This subclause addresses the requirement for secure data portability between products, enabling users to migrate
1435 configurations, operational data, and system state without compromising security. Configuration files for routers,
1436 modems intended for connection to the internet, and switches contain sensitive information including credentials,
1437 cryptographic keys, network topology details, and security policies that require protection during export and transfer.

1438 The transfer mechanism ensures data exports are encrypted to maintain confidentiality even if transfer media is
1439 compromised or intercepted, while preventing unauthorized modification that could compromise the target system upon
1440 import.

1441 5.11.1.2 Requirements

1442 [TRANSFER-1-RQ-1-01] The product shall support secure data export, allowing users to transfer the exported data
1443 over encrypted channel.

1444 [TRANSFER-1-RQ-1-02] The product shall support secure data import, allowing users to import data in the product
1445 over encrypted channel.

1446 [TRANSFER-1-RQ-1-03] The product shall provide capability to encrypt exported data using best practice encryption
1447 algorithms, with encryption applied based on user preference during export.

1448 [TRANSFER-1-RQ-1-04] The product shall require administrative access for export operations.

1449 [TRANSFER-1-RQ-1-05] The product shall require administrative access for import operations.

1450 [TRANSFER-1-RQ-1-06] The product shall generate audit events for all export and import operations.

1451 [TRANSFER-1-RQ-1-07] The product shall store audit events in persistent memory that survives the reset.

1452

1453 6 Vulnerability Handling Requirements

1454 6.1 General

1455 This clause establishes cybersecurity requirements for products within the scope of the present document. The
1456 requirements implement the essential cybersecurity requirements specified in Annex I Part II of Regulation (EU)
1457 2024/2847.

1458 The requirements address the vulnerability handling processes necessary for routers, modems intended for the
1459 connection to the internet, and switches operating in various deployment contexts and threat environments. These
1460 requirements apply to all products within scope, ensuring consistent security maintenance capabilities throughout the
1461 product support period while accounting for the operational constraints typical of network infrastructure.

1462 The product manufacturer shall implement vulnerability handling processes according to CEN CENELEC EN 40 000-
1463 1-3 [1] “Cybersecurity requirements for products with digital elements – Vulnerability Handling” [1].

1464 [The present clause 6 is empty. Requirements will be based on PT1 and PT3. This section shall focus on network
1465 equipment-specific considerations while referencing the horizontal standards for baseline requirements.]

1466 6.2 Vulnerability identification and documentation

1467 6.2.1 General

1468 6.2.1.1 Input

1469 6.2.1.2 Requirements

1470 6.2.1.3 Output

1471 6.2.1.4 Assessment criteria

1472

1473 6.3 Vulnerability Remediation

1474 6.3.1 General

1475 6.3.1.1 Input

1476 6.3.1.2 Requirements

1477 6.3.1.3 Output

1478 6.3.1.4 Assessment criteria

1479

1480 6.4 Security testing and review

1481 6.4.1 General

1482 6.4.1.1 Input

1483 6.4.1.2 Requirements

1484 6.4.1.3 Output

1485 6.4.1.4 Assessment criteria

1486

1487	6.5	Vulnerability disclosure
1488	6.5.1	General
1489	6.5.1.1	Input
1490	6.5.1.2	Requirements
1491	6.5.1.3	Output
1492	6.5.1.4	Assessment criteria
1493		
1494	6.6	Coordinated vulnerability disclosure policy
1495	6.6.1	General
1496	6.6.1.1	Input
1497	6.6.1.2	Requirements
1498	6.6.1.3	Output
1499	6.6.1.4	Assessment criteria
1500		
1501	6.7	Vulnerability reporting mechanisms
1502	6.7.1	General
1503	6.7.1.1	Input
1504	6.7.1.2	Requirements
1505	6.7.1.3	Output
1506	6.7.1.4	Assessment criteria
1507		
1508		
1509	6.8	Update distribution
1510	6.8.1	General
1511	6.8.1.1	Input
1512	6.8.1.2	Requirements
1513	6.8.1.3	Output
1514	6.8.1.4	Assessment criteria
1515		
1516		
1517		

1518 6.9 Security advisory and user guidance

1519 6.9.1 General

1520 6.9.1.1 Input

1521 6.9.1.2 Requirements

1522 6.9.1.3 Output

1523 6.9.1.4 Assessment criteria

1524

1525 7 Assessing cybersecurity requirement compliance

1526 7.1 General

1527 This clause details the assessment process for compliance with the cybersecurity requirements specified in Clause 5 and
1528 6 of the present document..

1529 7.2 Secure by Design

1530 Compliance with secure by design requirements shall be assessed as specified in PT1.

1531 7.3 No known exploitable vulnerabilities

1532 Compliance with secure by design requirements shall be assessed as specified in PT1.

1533 7.4 Secure by Default Configuration

1534 7.4.1 [DEFAULT] Secure by default configuration

1535 7.4.1.1 Requirement assessments

1536 [DEFAULT-1-RQ-1-01] Verify that applicable requirements from the present document may only be disabled in the
1537 factory default state when enabled applicable requirements would render the initial product setup process non -
1538 functional, and that omitted applicable requirements are documented in instructions to the user.

1539 Activities

1540 Verify:

- 1541 • Applicable requirements from the present document are identified for the product.
- 1542 • Factory default state configuration shows which requirements are enabled and which are disabled.
- 1543 • Each disabled requirement would render initial setup non-functional if enabled.
- 1544 • User documentation explicitly lists all disabled requirements.
- 1545 • Documentation explains the reason for disabling each requirement.
- 1546 • Documentation provides instructions for enabling disabled requirements after setup completion.
- 1547 • Disabled requirements can be enabled after initial setup is complete.
- 1548 • Product functions correctly with all requirements enabled post-setup.
- 1549 • All applicable requirements are active after setup and enabling process.

1550 Verdict

1551 Pass if:

- 1552 • Only requirements that would prevent setup are disabled in factory default state;

- 1553 • All disabled requirements are documented in user instructions;
- 1554 • Documentation explains reason for disabling each requirement;
- 1555 • Documentation provides instructions for enabling requirements after setup;
- 1556 • Disabled requirements can be enabled after initial setup completion;
- 1557 • And product functions correctly with all requirements enabled post-setup.

1558 Supporting evidence

- 1559 • Product configuration in factory default state;
- 1560 • List of all applicable requirements from present document;
- 1561 • List of requirements disabled in factory default state with justifications;
- 1562 • Test results showing impact of enabling each requirement during setup;
- 1563 • User documentation pages showing disabled requirement information;
- 1564 • Configuration showing requirements enabled after setup completion;
- 1565 • Product functional verification with all requirements enabled;
- 1566 • And documentation review confirming completeness of disabled requirement coverage.

1567 [DEFAULT-1-RQ-1-02] Verify the product, in its factory default state, utilises only those network interfaces and
1568 services that are necessary for product setup.

1569 Activities

1570 Verify:

- 1571 • Factory default state shows which network interfaces are active.
- 1572 • Active network interfaces match those necessary for product setup.
- 1573 • Network services running in factory default state are identified.
- 1574 • Active network services match those necessary for product setup.
- 1575 • Product documentation describes setup process network requirements.
- 1576 • Active interfaces and services align with documented setup requirements.
- 1577 • No unnecessary network interfaces are active in factory default state.
- 1578 • No unnecessary network services respond to requests.
- 1579 • Setup process completes successfully with factory default configuration.
- 1580 • Post-setup configuration shows setup-only interfaces or services are disabled if not needed.

1581 Verdict

1582 Pass if:

- 1583 • Only network interfaces necessary for setup are active in factory default state;
- 1584 • Only network services necessary for setup are running in factory default state;
- 1585 • No unnecessary network interfaces are active;
- 1586 • No unnecessary network services are running;
- 1587 • Active interfaces and services match documented setup requirements;
- 1588 • and Setup process functions correctly with minimal interface and service configuration.

1589 Supporting evidence

- 1590 • Network interface scan results in factory default state;
- 1591 • Network service scan results in factory default state;
- 1592 • Documentation of setup process network requirements;
- 1593 • Comparison of active interfaces versus required interfaces;
- 1594 • Comparison of active services versus required services;
- 1595 • Service banner information or response data;
- 1596 • Network traffic captures showing service activity;
- 1597 • Post-setup interface and service configuration for comparison.

1598 [DEFAULT-1-RQ-1-03] Verify the product, during initialization, limits access to accounts with initialization
1599 permissions.

1600 Activities

1601 Verify:

- 1602 • Product documentation describes which accounts have initialization permissions.
- 1603 • During initialization phase, accounts with initialization permissions are accessible.
- 1604 • During initialization phase, accounts without initialization permissions are blocked.
- 1605 • Administrative accounts not designated for initialization cannot access the product during initialization.
- 1606 • Regular user accounts cannot access the product during initialization.
- 1607 • Initialization-permitted accounts can perform only initialization-related functions.
- 1608 • Initialization completes successfully using only initialization-permitted accounts.
- 1609 • After initialization completes, non-initialization accounts become accessible as configured.
- 1610 • Access control transitions correctly from initialization mode to normal operation mode.

1611 Verdict

1612 Pass if:

- 1613 • Only accounts with initialization permissions are accessible during initialization;
- 1614 • Accounts without initialization permissions are blocked during initialization phase;
- 1615 • Initialization-permitted accounts are limited to initialization-related functions;
- 1616 • Initialization completes successfully with designated accounts;
- 1617 • Non-initialization accounts become accessible after initialization completes;
- 1618 • Documentation describes which accounts have initialization permissions.

1619 Supporting evidence

- 1620 • Product documentation describing initialization account permissions;
- 1621 • Test results showing successful access with initialization-permitted accounts during initialization;
- 1622 • Test results showing blocked access for non-initialization accounts during initialization;
- 1623 • List of functions accessible to initialization accounts;
- 1624 • Configuration showing access control during initialization phase;
- 1625 • Post-initialization access verification for regular accounts.

1626 [DEFAULT-1-RQ-1-04] Verify the product enforces the principle of least privilege during normal operation.

1627 Activities

1628 Verify:

- 1629 • Product role and permission model documentation describes all available user roles and their associated
1630 privileges.
- 1631 • User accounts exist for each defined role with appropriate privilege levels.
- 1632 • Low-privilege accounts cannot perform administrative tasks.
- 1633 • Low-privilege accounts can only perform authorised tasks for their assigned role.
- 1634 • Intermediate privilege accounts cannot exceed their assigned privilege levels.
- 1635 • Intermediate privilege accounts can perform all tasks within their privilege level.
- 1636 • Administrative accounts have elevated privileges for sensitive operations.
- 1637 • Administrative privileges are required for sensitive operations.
- 1638 • Internal product processes and services run with minimum required privileges.
- 1639 • Product components do not run with unnecessary elevated privileges.
- 1640 • Privilege escalation attempts from low-privilege accounts are prevented.
- 1641 • Product logs all privilege enforcement actions and violations.

1642 Verdict

1643 Pass if:

- 1644 • Product defines distinct privilege levels for different roles;
- 1645 • User accounts can only perform operations within assigned privilege levels;
- 1646 • Administrative privileges are required for sensitive operations;
- 1647 • Low-privilege accounts cannot perform administrative functions;
- 1648 • Privilege escalation attempts are prevented;
- 1649 • Internal processes run with minimum required privileges;
- 1650 • Product logs all privilege enforcement actions and violations.

1651 Supporting evidence

- 1652 • Product role and permission documentation;
- 1653 • User accounts created with different privilege levels;
- 1654 • Test results showing privilege enforcement for each role;
- 1655 • Attempts to perform unauthorised operations with results;
- 1656 • Process listing showing privilege levels of system components;
- 1657 • Privilege escalation attempt results;
- 1658 • Log entries showing privilege enforcement and violation detection;
- 1659 • Configuration showing role-based access control implementation.

1660 [DEFAULT-1-RQ-1-05] Verify the product, in its factory default state, allows access only using accounts and methods
1661 documented in the instructions to the user.

1662 Activities

1663 Verify:

- 1664 • Product user documentation describes factory default access information.
- 1665 • All accounts listed in user instructions are documented.
- 1666 • All access methods listed in user instructions are documented.
- 1667 • Documented accounts are functional in factory default state.
- 1668 • Undocumented common default accounts are not accessible.
- 1669 • Documented access methods are functional.
- 1670 • Undocumented access methods are not available.
- 1671 • Account enumeration shows only documented accounts are present.
- 1672 • All available network services accept only documented authentication methods.
- 1673 • Only documented credentials provide access.
- 1674 • Product logs all authentication attempts and methods used.

1675 Verdict

1676 Pass if:

- 1677 • Only accounts documented in user instructions are accessible;
- 1678 • Only access methods documented in user instructions are available;
- 1679 • All documented accounts function correctly;
- 1680 • All documented access methods function correctly;
- 1681 • Undocumented accounts are not present or accessible;
- 1682 • Undocumented access methods are not available;
- 1683 • Product logs all authentication attempts.

1684 Supporting evidence

- 1685 • Product user documentation pages showing default accounts and access methods;
- 1686 • Authentication attempts using documented accounts with results;
- 1687 • Authentication attempts using undocumented accounts with results;
- 1688 • Access method testing using documented methods with results;

- 1689 • Access method testing using undocumented methods with results;
- 1690 • Account enumeration results;
- 1691 • Service discovery results showing available authentication mechanisms;
- 1692 • Log entries showing all authentication attempts and methods.

1693 [DEFAULT-1-RQ-1-06] Verify the product protects remote diagnostic interfaces with authentication and authorisation
1694 controls.

1695 Activities

1696 Verify:

- 1697 • All remote diagnostic interfaces on product are identified.
- 1698 • Purpose and functionality of each diagnostic interface are documented.
- 1699 • Unauthenticated access is denied to all diagnostic interfaces.
- 1700 • Low-privilege accounts cannot access diagnostic interfaces.
- 1701 • Unauthorised accounts cannot access diagnostic interfaces.
- 1702 • Authorised accounts can access diagnostic interfaces.
- 1703 • Authentication is required for each diagnostic session.
- 1704 • Expired sessions require re-authentication.
- 1705 • Authentication bypass attempts fail.
- 1706 • All paths to diagnostic functions require authentication and authorisation.
- 1707 • Product logs all diagnostic interface access attempts with authentication results.

1708 Verdict

1709 Pass if:

- 1710 • All remote diagnostic interfaces require authentication;
- 1711 • All remote diagnostic interfaces require proper authorisation;
- 1712 • Unauthenticated access to diagnostic interfaces is denied;
- 1713 • Unauthorised accounts cannot access diagnostic interfaces;
- 1714 • Authentication is enforced for each diagnostic session;
- 1715 • Authentication bypass attempts are prevented;
- 1716 • Product logs all diagnostic interface access attempts.

1717 Supporting evidence

- 1718 • Documentation of all remote diagnostic interfaces;
- 1719 • Unauthenticated access attempts to diagnostic interfaces with results;
- 1720 • Low-privilege account access attempts with results;
- 1721 • Unauthorised account access attempts with results;
- 1722 • Authorised account successful access evidence;
- 1723 • Authentication bypass attempt results;
- 1724 • Session timeout and re-authentication test results;
- 1725 • Log entries showing all diagnostic interface access attempts and authentication results.

1726 [DEFAULT-1-RQ-1-07] Verify the product enforces change of administrative credentials in factory default state.

1727 Activities

1728 Verify:

- 1729 • Documentation describes default credential handling.
- 1730 • Product forces credential change before granting administrative functions.
- 1731 • Administrative access with default credentials triggers credential change requirement.
- 1732 • Credential change requirement cannot be bypassed.
- 1733 • Administrative operations are blocked until credentials change.

1734 Verdict

1735 Pass if:

- 1736 • Credential change is required on first administrative access;
- 1737 • Administrative functions are blocked until credentials change;
- 1738 • Credential change requirement cannot be bypassed.

1739 Supporting evidence

- 1740 • Test results demonstrating credential change enforcement;
- 1741 • Test results demonstrating blocked administrative functions;
- 1742 • Test results showing bypass attempts failed;
- 1743 • Documentation describing credential change process.

1744 [DEFAULT-1-RQ-1-08] Verify the product disables debugging and diagnostic interfaces in factory default state.

1745 Activities

1746 Verify:

- 1747 • Documentation describes debugging and diagnostic interfaces.
- 1748 • Network services are scanned and physical interfaces are inspected.
- 1749 • Debugging interfaces not listed in documentation are probed.
- 1750 • All debugging and diagnostic interfaces are inaccessible.
- 1751 • No debugging interfaces are accessible in factory default state.
- 1752 • No diagnostic interfaces are accessible in factory default state.

1753 Verdict

1754 Pass if:

- 1755 • No debugging interfaces are accessible in factory default state;
- 1756 • No diagnostic interfaces are accessible in factory default state.

1757 Supporting evidence

- 1758 • Documentation listing debugging and diagnostic interfaces;
- 1759 • Network scan results;
- 1760 • Physical interface inspection results;
- 1761 • Test results for each interface showing disabled status.

1762 [DEFAULT-1-RQ-1-09] Verify the product enables security audit logging in factory default state
1763 for authentication attempts, configuration changes, and product errors.

1764 Activities

1765 Verify:

- 1766 • Documentation describes default audit logging configuration and log locations.
- 1767 • Audit logs are accessible without changing configuration.
- 1768 • Successful authentication events are logged.
- 1769 • Failed authentication events are logged.
- 1770 • Configuration changes are logged.
- 1771 • Product errors are logged.
- 1772 • All log entries include timestamps and event details.
- 1773 • All log entries are formatted in a structured manner suitable for monitoring and forensic analysis.

1774 Verdict

1775 Pass if:

- 1776 • Authentication attempts are logged by default;
- 1777 • Configuration changes are logged by default;
- 1778 • Product errors are logged by default;
- 1779 • All log entries are timestamped records formatted in a structured manner suitable for monitoring and forensic analysis.
- 1780

1781 Supporting evidence

- 1782 • Log entries demonstrating successful authentication logging;
- 1783 • Log entries demonstrating failed authentication logging;
- 1784 • Log entries demonstrating configuration change logging;
- 1785 • Log entries demonstrating product error logging.

1786 [DEFAULT-1-RQ-1-10] Verify the product configures all cryptographic functions to use algorithms and key lengths
1787 that comply with current recognised standards in factory default state.

1788 Activities

1789 Verify:

- 1790 • Product documentation describes cryptographic algorithms and key lengths used in factory default
1791 configuration.
- 1792 • All cryptographic functions in factory default state use algorithms recognised by current industry standards.
- 1793 • Key lengths meet or exceed minimum requirements specified in current recognised standards.
- 1794 • Cryptographic configuration in factory default state aligns with manufacturer documentation.
- 1795 • No deprecated or weak cryptographic algorithms are enabled in factory default configuration.

1796 Verdict

1797 Pass if:

- 1798 • All cryptographic algorithms in factory default state comply with current recognised industry standards;
- 1799 • All key lengths meet minimum requirements of recognised standards;
- 1800 • Factory default cryptographic configuration matches manufacturer documentation;
- 1801 • No deprecated or weak algorithms are enabled by default.

1802 Supporting evidence

- 1803 • Manufacturer documentation describing cryptographic algorithms and key lengths in factory default state;
- 1804 • Product configuration showing cryptographic settings in factory default state;
- 1805 • Analysis confirming cryptographic algorithms align with recognised standards;
- 1806 • Verification showing key lengths meet minimum requirements;
- 1807 • Configuration review confirming no deprecated algorithms are enabled.

1808 [DEFAULT-1-RQ-1-11] Verify the product disables any protocols or services that have known exploitable
1809 vulnerabilities in factory default state.

1810 Activities

1811 Verify:

- 1812 • Manufacturer documentation describes all protocols and services enabled in factory default state.
- 1813 • All enabled protocols and services in factory default state are free from known exploitable vulnerabilities.
- 1814 • Protocols and services with known exploitable vulnerabilities are disabled in factory default state.

- 1815 • Product configuration in factory default state aligns with manufacturer documentation regarding enabled
- 1816 protocols and services.
- 1817 • No vulnerable or deprecated protocols are accessible in factory default configuration.

1818 Verdict

1819 Pass if:

- 1820 • All protocols and services enabled in factory default state are free from known exploitable vulnerabilities;
- 1821 • Vulnerable protocols and services are disabled in factory default state;
- 1822 • Factory default configuration matches manufacturer documentation;
- 1823 • No deprecated or exploitable protocols are accessible by default.

1824 Supporting evidence

- 1825 • Manufacturer documentation describing protocols and services in factory default state;
- 1826 • Product configuration showing enabled and disabled protocols and services in factory default state;
- 1827 • Network scan results showing accessible protocols and services;
- 1828 • Analysis confirming absence of known vulnerable protocols such;
- 1829 • Vulnerability assessment results for factory default configuration.

1830 7.4.2 [RESET] Factory reset

1831 7.4.2.1 Requirement assessments

1832 [RESET-1-RQ-1-01] Verify the product provides a factory reset mechanism that restores the product to its secure-by-
1833 default configuration.

1834 Activities

1835 Verify:

- 1836 • Manufacturer documentation describes the factory reset mechanism and its location.
- 1837 • Factory reset mechanism is accessible through documented methods.
- 1838 • Factory reset operation restores all security settings to factory default state.
- 1839 • All user-configured settings are removed during factory reset.
- 1840 • All user data is cleared during factory reset.
- 1841 • Default credentials are restored after factory reset.
- 1842 • Product returns to secure-by-default configuration after factory reset.
- 1843 • Product functions correctly after factory reset completion.

1844 Verdict

1845 Pass if:

- 1846 • Factory reset mechanism is available and documented;
- 1847 • Factory reset restores product to secure-by-default configuration;
- 1848 • All user configurations and data are removed;
- 1849 • Default credentials are restored;
- 1850 • Product operates correctly after reset.

1851 Supporting evidence

- 1852 • Manufacturer documentation describing factory reset mechanism and procedures;
- 1853 • Product configuration before factory reset showing user modifications;
- 1854 • Product configuration after factory reset showing default state;
- 1855 • Test results demonstrating restoration of default credentials;
- 1856 • Verification confirming removal of user data and configurations;

- 1857
- Functional testing results after factory reset completion.

1858 [RESET-1-RQ-1-02] Verify the product maintains the currently installed firmware version and all applied security
1859 updates after factory reset.

1860 Activities

1861 Verify:

- 1862
- Manufacturer documentation describes factory reset behaviour regarding firmware and security updates.
 - 1863 • Firmware version before factory reset is recorded.
 - 1864 • Security updates applied before factory reset are documented.
 - 1865 • Factory reset operation is performed.
 - 1866 • Firmware version after factory reset matches version before reset.
 - 1867 • All security updates applied before factory reset remain applied after reset.
 - 1868 • Product does not revert to original factory firmware version.
 - 1869 • Security patches are not removed during factory reset process.

1870 Verdict

1871 Pass if:

- 1872
- Firmware version is maintained after factory reset;
 - 1873 • All security updates remain applied after factory reset;
 - 1874 • Product does not downgrade to original factory firmware;
 - 1875 • Factory reset affects only configuration and user data, not firmware or security updates.

1876 Supporting evidence

- 1877
- Manufacturer documentation describing factory reset behaviour for firmware and updates;
 - 1878 • Firmware version information before factory reset;
 - 1879 • List of security updates applied before factory reset;
 - 1880 • Firmware version information after factory reset;
 - 1881 • Verification confirming security updates remain applied after reset;
 - 1882 • Comparison showing firmware and security patch retention.

1883 [RESET-1-RQ-1-03] Verify the product requires authentication and authorization at the highest privilege level for
1884 factory reset initiated through software, management interface, or remote command.

1885 Activities

1886 Verify:

- 1887
- Manufacturer documentation describes authentication and authorization requirements for factory reset
1888 operations.
 - 1889 • Factory reset through software interface requires authentication.
 - 1890 • Factory reset through management interface requires authentication.
 - 1891 • Factory reset through remote command requires authentication.
 - 1892 • Authentication requires credentials at the highest privilege level.
 - 1893 • Authorisation verifies user has appropriate privileges before allowing factory reset.
 - 1894 • Attempts to initiate factory reset without authentication are denied.
 - 1895 • Attempts to initiate factory reset with insufficient privileges are denied.
 - 1896 • Factory reset operations are logged with user identity and timestamp.

1897 Verdict

1898 Pass if:

- 1899
- Factory reset through software, management interface, or remote command requires authentication;

- 1900 • Authentication requires highest privilege level credentials;
- 1901 • Authorisation confirms appropriate privileges before allowing reset;
- 1902 • Factory reset attempts without proper authentication are denied;
- 1903 • Factory reset attempts with insufficient privileges are denied;
- 1904 • All factory reset operations are logged.

1905 Supporting evidence

- 1906 • Manufacturer documentation describing authentication and authorization requirements for factory reset;
- 1907 • Test results showing factory reset requires authentication for software interface;
- 1908 • Test results showing factory reset requires authentication for management interface;
- 1909 • Test results showing factory reset requires authentication for remote commands;
- 1910 • Verification confirming highest privilege level is required;
- 1911 • Attempted factory reset with insufficient privileges showing denial;
- 1912 • Attempted factory reset without authentication showing denial;
- 1913 • Logs showing factory reset operations with user identity and timestamps.

1914 [RESET-1-RQ-1-04] Verify the product does not retain any information that could be used to reconstruct previous
 1915 configuration or compromise user privacy after factory reset.

1916 Activities

1917 Verify:

- 1918 • Manufacturer documentation describes data removal during factory reset process.
- 1919 • All user configuration data is removed during factory reset.
- 1920 • All user credentials are removed during factory reset.
- 1921 • All personal data is removed during factory reset.
- 1922 • All log files containing sensitive information are removed during factory reset.
- 1923 • All cached data is cleared during factory reset.
- 1924 • Storage areas are properly cleared to prevent data recovery.
- 1925 • Data recovery attempts after factory reset do not yield previous configuration information.
- 1926 • Data recovery attempts after factory reset do not yield user personal information.
- 1927 • No residual data remains that could compromise user privacy.

1928 Verdict

1929 Pass if:

- 1930 • All user configuration data is removed after factory reset;
- 1931 • All user credentials are removed after factory reset;
- 1932 • All personal data is removed after factory reset;
- 1933 • All sensitive logs and cached data are cleared;
- 1934 • Data recovery attempts do not reconstruct previous configuration;
- 1935 • Data recovery attempts do not reveal user personal information;
- 1936 • User privacy is protected after factory reset.

1937 Supporting evidence

- 1938 • Manufacturer documentation describing data removal during factory reset;
- 1939 • Product storage analysis before factory reset showing user data presence;
- 1940 • Product storage analysis after factory reset showing data removal;
- 1941 • Data recovery attempts after factory reset with results;
- 1942 • Verification confirming configuration data cannot be reconstructed;
- 1943 • Verification confirming personal information cannot be recovered;
- 1944 • Analysis confirming storage areas are properly cleared.

1945 7.4.3 [UPDATE] Update mechanisms

1946 7.4.3.1 Requirement assessments

1947 [UPDATE-1-RQ-1-01] Verify the product provides mechanisms to receive and install remedies throughout the defined
1948 support period.

1949 Activities

1950 Verify:

- 1951 • Manufacturer documentation describes mechanisms for receiving remedies.
- 1952 • Manufacturer documentation describes mechanisms for installing remedies.
- 1953 • Manufacturer documentation defines the support period for the product.
- 1954 • Mechanisms to receive remedies are functional and accessible.
- 1955 • Mechanisms to install remedies are functional and accessible.
- 1956 • Product can successfully receive remedies using documented mechanisms.
- 1957 • Product can successfully install remedies using documented mechanisms.
- 1958 • Remedy mechanisms remain available throughout the defined support period.
- 1959 • Product notifies users when remedies are available.
- 1960 • Installed remedies are verified for authenticity and integrity.

1961 Verdict

1962 Pass if:

- 1963 • Mechanisms for receiving remedies are provided and documented;
- 1964 • Mechanisms for installing remedies are provided and documented;
- 1965 • Support period is clearly defined in documentation;
- 1966 • Remedy mechanisms are functional and accessible;
- 1967 • Product successfully receives and installs remedies;
- 1968 • Mechanisms remain available throughout the defined support period;
- 1969 • Users are notified of available remedies.

1970 Supporting evidence

- 1971 • Manufacturer documentation describing remedy receiving mechanisms;
- 1972 • Manufacturer documentation describing remedy installation mechanisms;
- 1973 • Manufacturer documentation defining support period;
- 1974 • Test results demonstrating successful remedy receipt;
- 1975 • Test results demonstrating successful remedy installation;
- 1976 • Verification showing remedy mechanisms are accessible;
- 1977 • Notification evidence showing user alerts for available remedies;
- 1978 • Analysis confirming remedy authenticity and integrity verification.

1979 [UPDATE-1-RQ-1-02] Verify the update mechanism is automated and activated by default.

1980 Activities

1981 Verify:

- 1982 • Manufacturer documentation describes the update mechanism and its default configuration.
- 1983 • Update mechanism is automated without requiring manual user intervention.
- 1984 • Update mechanism is activated by default in factory default state.
- 1985 • Product checks for updates automatically according to documented schedule.
- 1986 • Product downloads updates automatically when available.
- 1987 • Product notifies users of available or installed updates.
- 1988 • No manual configuration is required to enable automated updates.
- 1989 • User can verify automated update mechanism is active.

1990 Verdict

1991 Pass if:

- 1992 • Update mechanism is automated;
- 1993 • Update mechanism is activated by default;
- 1994 • Product checks for updates automatically;
- 1995 • Product downloads updates automatically;
- 1996 • No manual intervention is required for update mechanism operation;
- 1997 • Users are notified of update activity.

1998 Supporting evidence

- 1999 • Manufacturer documentation describing automated update mechanism;
- 2000 • Product configuration in factory default state showing update mechanism status;
- 2001 • Test results demonstrating automatic update checks;
- 2002 • Test results demonstrating automatic update downloads;
- 2003 • Verification confirming no manual configuration required;
- 2004 • User notification evidence showing update activity alerts;
- 2005 • Analysis confirming update mechanism operates without user intervention.

2006 [UPDATE-1-RQ-1-03] Verify the update mechanism depends on user configurations and operates automatically
2007 following the user configuration.

2008 Activities

2009 Verify:

- 2010 • Manufacturer documentation describes user-configurable update mechanism options.
- 2011 • Update mechanism provides user configuration settings.
- 2012 • User can configure update mechanism parameters.
- 2013 • Update mechanism operates automatically after user configuration is applied.
- 2014 • Update mechanism follows user-configured settings without requiring further manual intervention.
- 2015 • Product checks for updates automatically according to user-configured schedule.
- 2016 • Product downloads updates automatically according to user-configured preferences.
- 2017 • Product installs updates automatically according to user-configured policies.
- 2018 • Changes to user configuration are applied to automatic update behaviour.

2019 Verdict

2020 Pass if:

- 2021 • Update mechanism provides user configuration options;
- 2022 • Update mechanism operates automatically after configuration;
- 2023 • Update mechanism follows user-configured settings;
- 2024 • No manual intervention is required after initial configuration;
- 2025 • User configuration changes are reflected in automatic update behaviour.

2026 Supporting evidence

- 2027 • Manufacturer documentation describing user-configurable update options;
- 2028 • User interface showing available configuration settings;
- 2029 • Test results demonstrating automatic operation after user configuration;
- 2030 • Verification confirming update mechanism follows configured settings;
- 2031 • Test results showing configuration changes affect automatic behaviour;
- 2032 • Analysis confirming no manual intervention required after configuration.

2033 [UPDATE-1-RQ-1-04] Verify the product implements protection preventing unauthorised and unauthenticated
2034 installation of remedies.

2035 Activities

2036 Verify:

- 2037 • Manufacturer documentation describes protection mechanisms for remedy installation.
- 2038 • Remedy installation requires authentication.
- 2039 • Remedy installation requires authorisation.
- 2040 • Remedies are verified for authenticity before installation.
- 2041 • Remedies are verified for integrity before installation.
- 2042 • Unauthorised attempts to install remedies are prevented.
- 2043 • Unauthenticated attempts to install remedies are prevented.
- 2044 • Cryptographic signatures or equivalent mechanisms verify remedy authenticity.
- 2045 • Installation process rejects remedies that fail authentication or integrity verification.
- 2046 • Only remedies from trusted sources are accepted for installation.
- 2047 • Attempted installation of unauthorised remedies is logged.

2048 Verdict

2049 Pass if:

- 2050 • Protection mechanisms prevent unauthorised remedy installation;
- 2051 • Protection mechanisms prevent unauthenticated remedy installation;
- 2052 • Remedies are verified for authenticity and integrity before installation;
- 2053 • Unauthorised installation attempts are blocked;
- 2054 • Unauthenticated installation attempts are blocked;
- 2055 • Installation process rejects unverified remedies;
- 2056 • Attempted unauthorised installations are logged.

2057 Supporting evidence

- 2058 • Manufacturer documentation describing remedy installation protection mechanisms;
- 2059 • Test results demonstrating authentication requirement for remedy installation;
- 2060 • Test results demonstrating authorisation requirement for remedy installation;
- 2061 • Attempted remedy installation without authentication showing prevention;
- 2062 • Attempted remedy installation without authorisation showing prevention;
- 2063 • Verification confirming cryptographic signature checking;
- 2064 • Test results showing rejection of unverified remedies;
- 2065 • Logs showing unauthorised installation attempts.

2066 [UPDATE-1-RQ-1-05] Verify the product implements cryptographic verification of remedy to ensure authenticity and
2067 integrity.

2068 Activities

2069 Verify:

- 2070 • Manufacturer documentation describes cryptographic verification mechanisms for remedies.
- 2071 • Remedies are cryptographically signed by the manufacturer.
- 2072 • Product verifies cryptographic signatures before remedy installation.
- 2073 • Signature verification confirms remedy authenticity.
- 2074 • Integrity checking mechanisms detect any modification to remedies.
- 2075 • Product rejects remedies with invalid or missing cryptographic signatures.
- 2076 • Product rejects remedies that fail integrity verification.
- 2077 • Cryptographic algorithms used for verification comply with current recognised standards.
- 2078 • Verification process executes before any remedy installation begins.
- 2079 • Failed verification attempts prevent remedy installation and are logged.

2080 Verdict

2081 Pass if:

- 2082 • Product implements cryptographic verification for all remedies;
- 2083 • Cryptographic signatures verify remedy authenticity;
- 2084 • Integrity checking detects remedy modifications;
- 2085 • Remedies with invalid signatures are rejected;
- 2086 • Remedies that fail integrity verification are rejected;
- 2087 • Cryptographic verification occurs before installation;
- 2088 • Failed verification attempts are logged.

2089 Supporting evidence

- 2090 • Manufacturer documentation describing cryptographic verification mechanisms;
- 2091 • Analysis confirming cryptographic signature verification implementation;
- 2092 • Test results demonstrating signature verification before installation;
- 2093 • Attempted installation of unsigned remedy showing rejection;
- 2094 • Attempted installation of modified remedy showing rejection;
- 2095 • Verification confirming cryptographic algorithms comply with recognised standards;
- 2096 • Logs showing failed verification attempts;
- 2097 • Analysis confirming integrity checking mechanisms.

2098 [UPDATE-1-RQ-1-06] Verify the product ensures that any update maintains or improves the security properties of the
2099 product.

2100 Activities

2101 Verify:

- 2102 • Manufacturer documentation describes how updates maintain or improve security properties.
- 2103 • Security configuration before update is documented.
- 2104 • Update process is executed.
- 2105 • Security configuration after update is documented.
- 2106 • All security properties present before update remain active after update.
- 2107 • Security features are not downgraded or weakened by updates.
- 2108 • Security configurations are not reduced in strength by updates.
- 2109 • Updates maintain compliance with security requirements.
- 2110 • Updates maintain or improve cryptographic algorithm standards.
- 2111 • Security property changes introduced by updates are documented and justified as improvements.
- 2112 • Post-update verification confirms security properties are maintained or improved.

2113 Verdict

2114 Pass if:

- 2115 • All security properties are maintained after updates;
- 2116 • Security features are not downgraded by updates;
- 2117 • Security configurations are not weakened by updates;
- 2118 • Updates maintain compliance with security requirements;
- 2119 • Any security property changes represent documented improvements;
- 2120 • Post-update verification confirms security properties maintained or improved.

2121 Supporting evidence

- 2122 • Manufacturer documentation describing update impact on security properties;
- 2123 • Security configuration before update;
- 2124 • Security configuration after update;

- 2125 • Comparison analysis showing security properties maintained or improved;
- 2126 • Verification confirming no security feature downgrades;
- 2127 • Verification confirming no security configuration weakening;
- 2128 • Documentation of any security property changes with justification;
- 2129 • Post-update security verification results.

2130 [UPDATE-1-RQ-1-07] Verify the product generates audit events for all update activities including remedy availability,
 2131 download initiation and completion, and installation success or failure.

2132 Activities

2133 Verify:

- 2134 • Manufacturer documentation describes audit events generated for update activities.
- 2135 • Product generates audit events when remedies become available.
- 2136 • Product generates audit events when remedy download is initiated.
- 2137 • Product generates audit events when remedy download completes.
- 2138 • Product generates audit events when remedy installation succeeds.
- 2139 • Product generates audit events when remedy installation fails.
- 2140 • Audit events include timestamps for all update activities.
- 2141 • Audit events include relevant identifiers for remedies.
- 2142 • Audit events include status information for each update activity.
- 2143 • All update-related audit events are recorded and accessible for review.
- 2144 • Audit events are retained according to documented retention policies.

2145 Verdict

2146 Pass if:

- 2147 • Audit events are generated for remedy availability notifications;
- 2148 • Audit events are generated for remedy download initiation;
- 2149 • Audit events are generated for remedy download completion;
- 2150 • Audit events are generated for successful remedy installation;
- 2151 • Audit events are generated for failed remedy installation;
- 2152 • All audit events include timestamps and relevant identifiers;
- 2153 • Audit events are accessible for review.

2154 Supporting evidence

- 2155 • Manufacturer documentation describing audit events for update activities;
- 2156 • Audit logs showing remedy availability notifications;
- 2157 • Audit logs showing remedy download initiation events;
- 2158 • Audit logs showing remedy download completion events;
- 2159 • Audit logs showing successful installation events;
- 2160 • Audit logs showing failed installation events;
- 2161 • Verification confirming all audit events include timestamps and identifiers;
- 2162 • Analysis confirming audit event retention and accessibility.

2163 [UPDATE-1-RQ-1-08] Verify the product stores audit events in persistent memory that survives the reset.

2164 Activities

2165 Verify:

- 2166 • Manufacturer documentation describes audit event storage mechanisms.
- 2167 • Audit events are stored in persistent memory.
- 2168 • Audit events recorded before reset operation are documented.
- 2169 • Reset operation is performed.
- 2170 • Audit events recorded before reset remain accessible after reset.

- 2171 • Audit event storage survives power cycles.
- 2172 • Audit event storage survives factory reset operations.
- 2173 • Audit event storage is not volatile memory.
- 2174 • All previously recorded audit events are retrievable after reset.
- 2175 • Storage mechanism preserves event integrity through reset operations.

2176 Verdict

2177 Pass if:

- 2178 • Audit events are stored in persistent memory;
- 2179 • Audit events survive reset operations;
- 2180 • Previously recorded events remain accessible after reset;
- 2181 • Audit event storage survives power cycles;
- 2182 • Audit event integrity is maintained through reset operations.

2183 Supporting evidence

- 2184 • Manufacturer documentation describing audit event storage mechanisms;
- 2185 • Audit events recorded before reset operation;
- 2186 • Reset operation confirmation;
- 2187 • Audit events retrieved after reset operation;
- 2188 • Comparison showing audit events preserved through reset;
- 2189 • Verification confirming persistent memory storage;
- 2190 • Analysis confirming storage survives power cycles and factory reset.

2191 7.5 Access Control

2192 7.5.1 [AUTH-1] Authentication

2193 7.5.1.1 Requirement assessments

2194 [AUTH-1-RQ-1-01] Verify the product implements user authentication mechanism.

2195 Activities

2196 Verify:

- 2197 • Manufacturer documentation describes user authentication mechanisms.
- 2198 • Product implements user authentication for access control.
- 2199 • Users are required to authenticate before accessing product functionality.
- 2200 • Authentication mechanism is functional and operational.
- 2201 • Unauthenticated access attempts are denied.
- 2202 • Authentication process validates user credentials before granting access.
- 2203 • Product maintains authentication state during user sessions.
- 2204 • Authentication mechanism operates according to manufacturer documentation.

2205 Verdict

2206 Pass if:

- 2207 • Product implements user authentication mechanism;
- 2208 • Users have to authenticate before accessing product functionality;
- 2209 • Authentication mechanism is functional;
- 2210 • Unauthenticated access attempts are denied;
- 2211 • Authentication operates as documented.

2212 Supporting evidence

- 2213 • Manufacturer documentation describing user authentication mechanisms;
- 2214 • Product configuration showing authentication implementation;
- 2215 • Test results demonstrating authentication requirement for access;
- 2216 • Attempted access without authentication showing denial;
- 2217 • Verification confirming authentication mechanism functionality;
- 2218 • Analysis confirming authentication state management during sessions.

2219 [AUTH-1-RQ-1-02] Verify the product eliminates shared default credentials by either generating unique credentials
 2220 during secure production or enforcing mandatory credential creation during initial setup.

2221 Activities

2222 Verify:

- 2223 • Manufacturer documentation describes credential provisioning approach.
- 2224 • Product does not use shared default credentials across multiple units.
- 2225 • If credentials are generated during production, then each product unit has unique credentials.
- 2226 • If credentials are created during initial setup, then initial setup enforces mandatory credential creation.
- 2227 • Product does not allow operation without unique credentials.
- 2228 • Default credentials are not shared between different product instances.
- 2229 • Users cannot proceed with initial setup without creating credentials if mandatory creation approach is used.
- 2230 • Unique credentials generated during production are properly documented per unit.
- 2231 • Mandatory credential creation during setup prevents use of weak or default values.
- 2232 • Product configuration confirms elimination of shared default credentials.

2233 Verdict

2234 Pass if:

- 2235 • Product eliminates shared default credentials;
- 2236 • Either unique credentials are generated during production or mandatory credential creation is enforced during
 2237 setup;
- 2238 • Product does not use identical default credentials across multiple units;
- 2239 • Credentials are unique to each product instance;
- 2240 • Product operation requires unique credentials.

2241 Supporting evidence

- 2242 • Manufacturer documentation describing credential provisioning approach;
- 2243 • Product configuration showing credential implementation;
- 2244 • Verification confirming credentials are unique per product unit;
- 2245 • Initial setup process demonstration showing mandatory credential creation if applicable;
- 2246 • Test results from multiple product units confirming no shared credentials;
- 2247 • Documentation of unique credentials per unit if production-generated;
- 2248 • Analysis confirming elimination of shared default credentials.

2249 [AUTH-1-RQ-1-03] Verify the product ensures authentication credentials are transmitted exclusively through channels
 2250 that provide best practice cryptographic protection, using secure communication channels with confidentiality and
 2251 integrity protection and implementing mechanisms that prevent disclosure of secrets even over unencrypted channels.

2252 Activities

2253 Verify:

- 2254 • Manufacturer documentation describes credential transmission mechanisms and cryptographic protection.
- 2255 • Authentication credentials are transmitted only through cryptographically protected channels.
- 2256 • Communication channels provide confidentiality protection for credentials in transit.
- 2257 • Communication channels provide integrity protection for credentials in transit.
- 2258 • Cryptographic protection meets best practice standards.

- 2259 • Mechanisms prevent credential disclosure over unencrypted channels.
- 2260 • Credentials are not transmitted in plaintext over any channel.
- 2261 • Attempted credential transmission over unencrypted channels is prevented or credentials are protected by
- 2262 alternative mechanisms.
- 2263 • Channel security is verified before credential transmission occurs.
- 2264 • All credential exchanges use appropriate cryptographic protocols.

2265 Verdict

2266 Pass if:

- 2267 • Authentication credentials are transmitted exclusively through cryptographically protected channels;
- 2268 • Communication channels provide confidentiality and integrity protection;
- 2269 • Cryptographic protection meets best practice standards;
- 2270 • Mechanisms prevent credential disclosure over unencrypted channels;
- 2271 • Credentials are never transmitted in plaintext;
- 2272 • Channel security is verified before transmission.

2273 Supporting evidence

- 2274 • Manufacturer documentation describing credential transmission mechanisms;
- 2275 • Network traffic analysis showing encrypted credential transmission;
- 2276 • Verification confirming cryptographic protection meets best practice standards;
- 2277 • Attempted credential transmission analysis showing protection mechanisms;
- 2278 • Protocol analysis confirming confidentiality and integrity protection;
- 2279 • Test results demonstrating prevention of plaintext credential transmission;
- 2280 • Analysis confirming channel security verification before transmission.

2281 [AUTH-1-RQ-1-04] Verify the product stores secrets using best practice cryptographic methods.

2282 Activities

2283 Verify:

- 2284 • Manufacturer documentation describes secret storage mechanisms and cryptographic methods used.
- 2285 • Secrets are stored using cryptographic protection.
- 2286 • Cryptographic methods used for secret storage meet best practice standards.
- 2287 • Secrets are not stored in plaintext.
- 2288 • Secret storage mechanisms protect confidentiality.
- 2289 • Secret storage mechanisms protect integrity.
- 2290 • Cryptographic algorithms used for secret storage comply with current recognised standards.
- 2291 • Key derivation functions meet best practice requirements where applicable.
- 2292 • Storage locations for secrets are properly protected.
- 2293 • Secrets cannot be retrieved in plaintext without proper authorisation.

2294 Verdict

2295 Pass if:

- 2296 • Secrets are stored using cryptographic protection;
- 2297 • Cryptographic methods meet best practice standards;
- 2298 • Secrets are not stored in plaintext;
- 2299 • Storage mechanisms protect confidentiality and integrity;
- 2300 • Cryptographic algorithms comply with current recognised standards;
- 2301 • Secrets cannot be retrieved in plaintext without authorisation.

2302 Supporting evidence

- 2303 • Manufacturer documentation describing secret storage mechanisms;
- 2304 • Analysis of secret storage implementation showing cryptographic methods;
- 2305 • Verification confirming cryptographic methods meet best practice standards;
- 2306 • Storage analysis confirming secrets are not in plaintext;
- 2307 • Verification confirming cryptographic algorithms comply with recognised standards;
- 2308 • Analysis confirming storage location protection;
- 2309 • Test results demonstrating secrets cannot be retrieved without authorisation.

2310 [AUTH-1-RQ-1-05] Verify the product enforces minimum credential entropy through character complexity and
 2311 minimum length requirements.

2312 Activities

2313 Verify:

- 2314 • Manufacturer documentation describes minimum credential entropy requirements.
- 2315 • Product enforces minimum length requirements for credentials.
- 2316 • Product enforces character complexity requirements for credentials.
- 2317 • Minimum length requirements are sufficient to ensure adequate entropy.
- 2318 • Character complexity requirements contribute to credential strength.
- 2319 • Product rejects credentials that do not meet minimum length requirements.
- 2320 • Product rejects credentials that do not meet character complexity requirements.
- 2321 • Users are informed of credential requirements during credential creation.
- 2322 • Credential creation process validates entropy requirements before acceptance.
- 2323 • Enforcement mechanisms operate during initial credential creation and credential changes.

2324 Verdict

2325 Pass if:

- 2326 • Product enforces minimum credential length requirements;
- 2327 • Product enforces character complexity requirements;
- 2328 • Requirements ensure adequate credential entropy;
- 2329 • Credentials not meeting requirements are rejected;
- 2330 • Users are informed of requirements;
- 2331 • Enforcement operates during creation and changes.

2332 Supporting evidence

- 2333 • Manufacturer documentation describing credential entropy requirements;
- 2334 • Product configuration showing minimum length requirements;
- 2335 • Product configuration showing character complexity requirements;
- 2336 • Attempted credential creation with insufficient length showing rejection;
- 2337 • Attempted credential creation with insufficient complexity showing rejection;
- 2338 • User interface showing credential requirement information;
- 2339 • Verification confirming entropy requirements are adequate;
- 2340 • Test results demonstrating enforcement during credential creation and changes.

2341 [AUTH-1-RQ-1-06] Verify the product implements authentication failure protection including progressive delays
 2342 between failed attempts and temporary account lockout after certain number of failed attempts.

2343 Activities

2344 Verify:

- 2345 • Manufacturer documentation describes authentication failure protection mechanisms.
- 2346 • Product implements progressive delays between failed authentication attempts.
- 2347 • Delay duration increases with consecutive failed attempts.
- 2348 • Product implements temporary account lockout after specified number of failed attempts.

- 2349 • Lockout threshold is documented and configurable if applicable.
- 2350 • Lockout duration is documented and appropriate for security.
- 2351 • Failed authentication attempts are counted per account.
- 2352 • Progressive delays prevent rapid authentication attempts.
- 2353 • Account lockout is temporary and does not require administrative intervention for release if applicable.
- 2354 • Authentication failure protection mechanisms reset after successful authentication.
- 2355 • All authentication failures and lockouts are logged.

2356 Verdict

2357 Pass if:

- 2358 • Product implements progressive delays between failed authentication attempts;
- 2359 • Product implements temporary account lockout after specified number of failures;
- 2360 • Delay duration increases with consecutive failures;
- 2361 • Lockout threshold and duration are appropriate;
- 2362 • Failed attempts are tracked per account;
- 2363 • Protection mechanisms prevent brute force attacks;
- 2364 • Authentication failures and lockouts are logged.

2365 Supporting evidence

- 2366 • Manufacturer documentation describing authentication failure protection mechanisms;
- 2367 • Test results demonstrating progressive delays between failed attempts;
- 2368 • Test results demonstrating account lockout after threshold reached;
- 2369 • Verification confirming delay duration increases with failures;
- 2370 • Lockout threshold and duration documentation;
- 2371 • Logs showing failed authentication attempts and lockouts;
- 2372 • Analysis confirming protection mechanisms prevent rapid authentication attempts;
- 2373 • Test results showing protection mechanism reset after successful authentication.

2374 [AUTH-1-RQ-1-07] Verify the product maintains history of previously used passwords, in their processed form, to
2375 prevent reuse, with a minimum of one previous password kept, and that password changes are validated against this
2376 history before acceptance.

2377 Activities

2378 Verify:

- 2379 • Manufacturer documentation describes password history mechanisms and reuse prevention.
- 2380 • Product maintains history of previously used passwords.
- 2381 • Password history stores passwords in processed form rather than plaintext.
- 2382 • Minimum of one previous password is retained in history.
- 2383 • Password changes are validated against password history.
- 2384 • Product prevents reuse of passwords stored in history.
- 2385 • Attempted password changes to previously used passwords are rejected.
- 2386 • Users are informed when password change attempts fail due to history conflict.
- 2387 • Password history is maintained per user account.
- 2388 • Password history mechanisms operate during all password change operations.

2389 Verdict

2390 Pass if:

- 2391 • Product maintains password history in processed form;
- 2392 • Minimum of one previous password is retained;
- 2393 • Password changes are validated against history before acceptance;
- 2394 • Previously used passwords cannot be reused;

- 2395 • Attempted reuse of historical passwords is rejected;
- 2396 • Password history is maintained per user account.

2397 Supporting evidence

- 2398 • Manufacturer documentation describing password history mechanisms;
- 2399 • Analysis confirming password history storage in processed form;
- 2400 • Verification confirming minimum of one previous password retained;
- 2401 • Attempted password change to previous password showing rejection;
- 2402 • Test results demonstrating validation against password history;
- 2403 • User notification evidence when password reuse is attempted;
- 2404 • Analysis confirming password history maintained per account;
- 2405 • Verification confirming history mechanisms operate during password changes.

2406 7.5.2 [AUTH-2] Authorization

2407 7.5.2.1 Requirement assessments

2408 [AUTH-2-RQ-1-01] Verify the product implements a privilege separation mechanism that requires user authentication
2409 before granting administrative access.

2410 Activities

2411 Verify:

- 2412 • Manufacturer documentation describes privilege separation mechanism and authentication requirements.
- 2413 • Product implements privilege separation between administrative and non-administrative access.
- 2414 • Administrative access requires user authentication.
- 2415 • Authentication occurs before administrative privileges are granted.
- 2416 • Non-administrative users cannot access administrative functions without authentication.
- 2417 • Privilege levels are clearly defined and enforced.
- 2418 • Administrative operations require appropriate privilege level.
- 2419 • Attempted administrative access without authentication is denied.
- 2420 • Attempted administrative access with non-administrative credentials is denied.
- 2421 • Privilege separation mechanism prevents unauthorised elevation to administrative access.

2422 Verdict

2423 Pass if:

- 2424 • Product implements privilege separation mechanism;
- 2425 • Administrative access requires user authentication;
- 2426 • Authentication occurs before granting administrative privileges;
- 2427 • Non-administrative users cannot access administrative functions;
- 2428 • Privilege levels are defined and enforced;
- 2429 • Unauthorised administrative access attempts are denied.

2430 Supporting evidence

- 2431 • Manufacturer documentation describing privilege separation mechanism;
- 2432 • Product configuration showing privilege levels;
- 2433 • Test results demonstrating authentication requirement for administrative access;
- 2434 • Attempted administrative access without authentication showing denial;
- 2435 • Attempted administrative access with non-administrative credentials showing denial;
- 2436 • Verification confirming privilege separation enforcement;
- 2437 • Analysis confirming privilege levels are properly defined and enforced.

2438 [AUTH-2-RQ-1-02] Verify the product does not allow any user to perform actions beyond their authorized privilege
2439 level.

2440 Activities

2441 Verify:

- 2442 • Manufacturer documentation describes privilege levels and associated permissions.
- 2443 • Product enforces privilege level restrictions for all operations.
- 2444 • Users are limited to actions within their authorized privilege level.
- 2445 • Attempted actions beyond authorized privilege level are denied.
- 2446 • Privilege verification occurs before executing operations.
- 2447 • Privilege escalation attempts are prevented.
- 2448 • Each operation validates user authorization against required privilege level.
- 2449 • Users cannot bypass privilege level restrictions.
- 2450 • Privilege enforcement mechanisms operate consistently across all product interfaces.
- 2451 • All attempts to exceed privilege levels are logged.

2452 Verdict

2453 Pass if:

- 2454 • Product enforces privilege level restrictions for all operations;
- 2455 • Users cannot perform actions beyond their authorized privilege level;
- 2456 • Attempted actions beyond privilege level are denied;
- 2457 • Privilege verification occurs before operation execution;
- 2458 • Privilege escalation is prevented;
- 2459 • Attempts to exceed privilege levels are logged.

2460 Supporting evidence

- 2461 • Manufacturer documentation describing privilege levels and permissions;
- 2462 • Product configuration showing privilege level definitions;
- 2463 • Test results demonstrating privilege enforcement;
- 2464 • Attempted operations beyond privilege level showing denial;
- 2465 • Attempted privilege escalation showing prevention;
- 2466 • Verification confirming privilege verification before operation execution;
- 2467 • Logs showing attempts to exceed privilege levels;
- 2468 • Analysis confirming consistent privilege enforcement across all interfaces.

2469 [AUTH-2-RQ-1-03] Verify the product enforces access control on all management interfaces consistently, preventing
2470 privilege escalation through alternative interfaces.

2471 Activities

2472 Verify:

- 2473 • Manufacturer documentation describes all management interfaces and access control mechanisms.
- 2474 • Product implements access control on all management interfaces.
- 2475 • Access control enforcement is consistent across all management interfaces.
- 2476 • Each management interface requires authentication before granting access.
- 2477 • Each management interface enforces privilege levels consistently.
- 2478 • Alternative management interfaces do not provide paths to bypass access controls.
- 2479 • Privilege escalation through alternative interfaces is prevented.
- 2480 • Operations requiring specific privilege levels are enforced identically across all interfaces.
- 2481 • Attempted access through alternative interfaces without proper authorization is denied.
- 2482 • No management interface provides elevated privileges not available through other interfaces.
- 2483 • Access control policies are applied uniformly regardless of interface used.

2484 Verdict

2485 Pass if:

- 2486 • Access control is enforced on all management interfaces;
- 2487 • Enforcement is consistent across all interfaces;
- 2488 • All interfaces require authentication and enforce privilege levels;
- 2489 • Alternative interfaces do not bypass access controls;
- 2490 • Privilege escalation through alternative interfaces is prevented;
- 2491 • Access control policies are applied uniformly across interfaces.

2492 Supporting evidence

- 2493 • Manufacturer documentation describing all management interfaces;
- 2494 • Product configuration showing access control implementation on each interface;
- 2495 • Test results demonstrating access control enforcement on each management interface;
- 2496 • Attempted access through alternative interfaces without authorization showing denial;
- 2497 • Attempted privilege escalation through alternative interfaces showing prevention;
- 2498 • Verification confirming consistent enforcement across all interfaces;
- 2499 • Analysis confirming uniform access control policy application;
- 2500 • Comparison showing equivalent privilege enforcement across interfaces.

2501 [AUTH-2-RQ-1-04] Verify the product implements command authorisation that validates each command based on the
2502 authorised privilege level before execution.

2503 Activities

2504 Verify:

- 2505 • Manufacturer documentation describes command authorisation mechanisms.
- 2506 • Product implements command authorisation for all operations.
- 2507 • Each command is validated against user's authorised privilege level.
- 2508 • Authorisation validation occurs before command execution.
- 2509 • Commands requiring specific privilege levels are properly restricted.
- 2510 • Users with insufficient privilege level cannot execute restricted commands.
- 2511 • Attempted command execution without proper authorisation is denied.
- 2512 • Command authorisation enforcement operates consistently across all interfaces.
- 2513 • Authorisation validation prevents execution of unauthorised commands.
- 2514 • All unauthorised command attempts are logged.

2515 Verdict

2516 Pass if:

- 2517 • Product implements command authorisation for all operations;
- 2518 • Each command is validated against authorised privilege level before execution;
- 2519 • Commands are restricted based on privilege requirements;
- 2520 • Unauthorised command execution attempts are denied;
- 2521 • Authorisation enforcement operates consistently;
- 2522 • Unauthorised command attempts are logged.

2523 Supporting evidence

- 2524 • Manufacturer documentation describing command authorisation mechanisms;
- 2525 • Product configuration showing command privilege level requirements;
- 2526 • Test results demonstrating authorisation validation before execution;
- 2527 • Attempted command execution with insufficient privileges showing denial;
- 2528 • Verification confirming authorisation enforcement across all interfaces;

- 2529 • Logs showing unauthorised command attempts;
- 2530 • Analysis confirming command validation against privilege levels.

2531 7.5.3 [AUTH-3] Authenticated session lifecycle

2532 7.5.3.1 Requirement assessments

2533 [AUTH-3-RQ-1-01] Verify the product generates cryptographically secure session identifiers using best practice
 2534 technology, and that session identifiers are unique, non-predictable, and resistant to brute force attacks.

2535 Activities

2536 Verify:

- 2537 • Manufacturer documentation describes session identifier generation mechanisms.
- 2538 • Product generates session identifiers using cryptographically secure methods.
- 2539 • Session identifier generation uses best practice technology.
- 2540 • Session identifiers are unique for each session.
- 2541 • Session identifiers are non-predictable and cannot be guessed.
- 2542 • Session identifier generation prevents collisions between concurrent sessions.
- 2543 • Session identifiers have sufficient entropy to resist brute force attacks.
- 2544 • Session identifier generation algorithm meets current recognised cryptographic standards.
- 2545 • Session identifiers cannot be derived from previous or subsequent identifiers.
- 2546 • Multiple session creations produce distinct non-sequential identifiers.

2547 Verdict

2548 Pass if:

- 2549 • Session identifiers are generated using cryptographically secure methods;
- 2550 • Generation uses best practice technology;
- 2551 • Session identifiers are unique for each session;
- 2552 • Session identifiers are non-predictable;
- 2553 • Session identifiers resist brute force attacks;
- 2554 • Generation algorithm meets recognised cryptographic standards.

2555 Supporting evidence

- 2556 • Manufacturer documentation describing session identifier generation mechanisms;
- 2557 • Analysis of session identifier generation algorithm;
- 2558 • Verification confirming cryptographically secure generation;
- 2559 • Test results showing session identifier uniqueness;
- 2560 • Analysis demonstrating non-predictability of identifiers;
- 2561 • Entropy analysis confirming resistance to brute force attacks;
- 2562 • Verification confirming compliance with recognised cryptographic standards;
- 2563 • Test results from multiple session creations showing distinct identifiers.

2564 [AUTH-3-RQ-1-02] Verify the product implements session timeout mechanisms with configurable idle timeout periods
 2565 and appropriate default values.

2566 Activities

2567 Verify:

- 2568 • Manufacturer documentation describes session timeout mechanisms and configuration options.
- 2569 • Product implements session timeout for idle sessions.
- 2570 • Idle timeout periods are configurable.
- 2571 • Default timeout values are appropriate for security.
- 2572 • Sessions are terminated after configured idle timeout period expires.

- 2573 • User activity resets the idle timeout counter.
- 2574 • Inactive sessions cannot be reused after timeout expiration.
- 2575 • Users are notified of impending session timeout where applicable.
- 2576 • Timeout configuration allows administrators to set appropriate values for operational requirements.
- 2577 • Minimum and maximum timeout values are documented where applicable.
- 2578 • Session termination due to timeout is logged.

2579 Verdict

2580 Pass if:

- 2581 • Product implements session timeout mechanisms;
- 2582 • Idle timeout periods are configurable;
- 2583 • Default timeout values are appropriate;
- 2584 • Sessions terminate after idle timeout expires;
- 2585 • Inactive sessions cannot be reused after timeout;
- 2586 • User activity resets timeout counter;
- 2587 • Session timeout events are logged.

2588 Supporting evidence

- 2589 • Manufacturer documentation describing session timeout mechanisms;
- 2590 • Product configuration showing timeout settings and default values;
- 2591 • Test results demonstrating session termination after idle timeout;
- 2592 • Test results showing user activity resets timeout counter;
- 2593 • Attempted session reuse after timeout showing denial;
- 2594 • Configuration interface showing timeout period options;
- 2595 • Logs showing session timeout events;
- 2596 • Verification confirming default values are appropriate for security.

2597 [AUTH-3-RQ-1-03] Verify the product invalidates sessions immediately upon user-initiated logout, timeout expiration,
2598 authentication credential change, or administrative termination, and that session invalidation securely removes all
2599 session data.

2600 Activities

2601 Verify:

- 2602 • Manufacturer documentation describes session invalidation mechanisms and triggers.
- 2603 • Product invalidates sessions immediately upon user-initiated logout.
- 2604 • Product invalidates sessions immediately upon timeout expiration.
- 2605 • Product invalidates sessions immediately upon authentication credential change.
- 2606 • Product invalidates sessions immediately upon administrative termination.
- 2607 • Session invalidation occurs without delay when triggered.
- 2608 • Invalidated sessions cannot be reused or resumed.
- 2609 • Session data is securely removed during invalidation.
- 2610 • All session state information is cleared upon invalidation.
- 2611 • Session identifiers are rendered invalid and cannot authenticate subsequent requests.
- 2612 • Attempted use of invalidated session identifiers is denied.
- 2613 • Session invalidation is logged with trigger reason.

2614 Verdict

2615 Pass if:

- 2616 • Sessions are invalidated immediately upon user logout;
- 2617 • Sessions are invalidated immediately upon timeout expiration;
- 2618 • Sessions are invalidated immediately upon credential change;

- 2619 • Sessions are invalidated immediately upon administrative termination;
- 2620 • Invalidated sessions cannot be reused;
- 2621 • Session data is securely removed during invalidation;
- 2622 • Attempted use of invalidated sessions is denied;
- 2623 • Session invalidation events are logged.

2624 Supporting evidence

- 2625 • Manufacturer documentation describing session invalidation mechanisms;
- 2626 • Test results demonstrating immediate invalidation upon user logout;
- 2627 • Test results demonstrating immediate invalidation upon timeout;
- 2628 • Test results demonstrating immediate invalidation upon credential change;
- 2629 • Test results demonstrating immediate invalidation upon administrative termination;
- 2630 • Attempted session reuse after invalidation showing denial;
- 2631 • Analysis confirming secure removal of session data;
- 2632 • Verification confirming session state is cleared;
- 2633 • Logs showing session invalidation events with trigger reasons.

2634 [AUTH-3-RQ-1-04] Verify the product protects session identifiers by transmitting them only over secure channels that
2635 provide confidentiality and integrity protection, implementing appropriate session token protection mechanisms for the
2636 interface type, and preventing session identifiers from appearing in audit events, logs, URLs, or error messages.

2637 Activities

2638 Verify:

- 2639 • Manufacturer documentation describes session identifier protection mechanisms.
- 2640 • Session identifiers are transmitted only over secure channels.
- 2641 • Secure channels provide confidentiality protection for session identifiers.
- 2642 • Secure channels provide integrity protection for session identifiers.
- 2643 • Session token protection mechanisms are appropriate for the interface type.
- 2644 • Session identifiers do not appear in audit events.
- 2645 • Session identifiers do not appear in logs.
- 2646 • Session identifiers do not appear in URLs.
- 2647 • Session identifiers do not appear in error messages.
- 2648 • Session identifier transmission uses encrypted protocols.
- 2649 • Session identifiers are not exposed through insecure channels.
- 2650 • Network traffic analysis confirms session identifiers are protected during transmission.

2651 Verdict

2652 Pass if:

- 2653 • Session identifiers are transmitted only over secure channels;
- 2654 • Secure channels provide confidentiality and integrity protection;
- 2655 • Session token protection mechanisms are appropriate for interface type;
- 2656 • Session identifiers do not appear in audit events;
- 2657 • Session identifiers do not appear in logs;
- 2658 • Session identifiers do not appear in URLs;
- 2659 • Session identifiers do not appear in error messages.

2660 Supporting evidence

- 2661 • Manufacturer documentation describing session identifier protection mechanisms;
- 2662 • Network traffic analysis showing encrypted session identifier transmission;
- 2663 • Verification confirming secure channel usage;
- 2664 • Audit event review confirming session identifiers are not present;
- 2665 • Log file review confirming session identifiers are not present;

- 2666 • URL analysis confirming session identifiers are not exposed;
- 2667 • Error message review confirming session identifiers are not disclosed;
- 2668 • Analysis confirming session token protection mechanisms appropriate for interface type.

2669 [AUTH-3-RQ-1-05] Verify the product implements protection against session fixation by generating new session
 2670 identifiers upon successful authentication, before privilege elevation, when switching between security contexts, or
 2671 when transitioning between untrusted and trusted network zones.

2672 Activities

2673 Verify:

- 2674 • Manufacturer documentation describes session fixation protection mechanisms.
- 2675 • Product generates new session identifiers upon successful authentication.
- 2676 • Product generates new session identifiers before privilege elevation.
- 2677 • Product generates new session identifiers when switching between security contexts.
- 2678 • Product generates new session identifiers when transitioning between untrusted and trusted network zones.
- 2679 • Previous session identifier becomes invalid when new identifier is generated.
- 2680 • Old session identifiers cannot be used after new identifier generation.
- 2681 • Session fixation attacks are prevented through identifier regeneration.
- 2682 • Session identifier regeneration occurs automatically at appropriate trigger points.
- 2683 • Attempted use of old session identifiers after regeneration is denied.
- 2684 • Session identifier regeneration events are logged.

2685 Verdict

2686 Pass if:

- 2687 • New session identifiers are generated upon successful authentication;
- 2688 • New session identifiers are generated before privilege elevation;
- 2689 • New session identifiers are generated when switching security contexts;
- 2690 • New session identifiers are generated when transitioning between network zones;
- 2691 • Previous session identifiers become invalid after regeneration;
- 2692 • Session fixation attacks are prevented;
- 2693 • Identifier regeneration events are logged.

2694 Supporting evidence

- 2695 • Manufacturer documentation describing session fixation protection mechanisms;
- 2696 • Test results demonstrating new identifier generation upon authentication;
- 2697 • Test results demonstrating new identifier generation before privilege elevation;
- 2698 • Test results demonstrating new identifier generation when switching security contexts;
- 2699 • Test results demonstrating new identifier generation when transitioning network zones;
- 2700 • Attempted use of old session identifiers showing denial;
- 2701 • Analysis confirming session fixation attack prevention;
- 2702 • Logs showing session identifier regeneration events.

2703 [AUTH-3-RQ-1-06] Verify the product limits concurrent sessions to a configurable maximum per user account.

2704 Activities

2705 Verify:

- 2706 • Manufacturer documentation describes concurrent session limit mechanisms and configuration options.
- 2707 • Product limits concurrent sessions per user account.
- 2708 • Maximum number of concurrent sessions is configurable.
- 2709 • Session limit can be set by administrators.
- 2710 • When session limit is reached, product handles new session requests according to documented policy.
- 2711 • Session limit enforcement operates on a per-user account basis.

- 2712 • Attempted sessions beyond configured limit are handled appropriately.
- 2713 • Users with multiple concurrent sessions within limit can access product normally.
- 2714 • Configuration allows setting appropriate limits for operational requirements.
- 2715 • Session limit violations are logged.

2716 Verdict

2717 Pass if:

- 2718 • Product limits concurrent sessions per user account;
- 2719 • Maximum concurrent sessions is configurable;
- 2720 • Session limit can be set by administrators;
- 2721 • Limit enforcement operates per user account;
- 2722 • Sessions beyond limit are handled according to policy;
- 2723 • Session limit violations are logged.

2724 Supporting evidence

- 2725 • Manufacturer documentation describing concurrent session limit mechanisms;
- 2726 • Product configuration showing session limit settings;
- 2727 • Configuration interface showing options to set session limits;
- 2728 • Test results demonstrating session limit enforcement;
- 2729 • Test results showing behaviour when limit is reached;
- 2730 • Verification confirming per-user account enforcement;
- 2731 • Logs showing session limit violations;
- 2732 • Analysis confirming configurable limit options.

2733 [AUTH-3-RQ-1-07] Verify the product implements session security that detects privilege escalation attempts.

2734 Activities

2735 Verify:

- 2736 • Manufacturer documentation describes session security mechanisms for privilege escalation detection.
- 2737 • Product implements session security monitoring during active sessions.
- 2738 • Session security mechanisms detect attempts to escalate privileges.
- 2739 • Privilege escalation attempts within sessions are identified.
- 2740 • Unauthorised privilege changes during sessions are detected.
- 2741 • Detection mechanisms monitor session activities for privilege violations.
- 2742 • Detected privilege escalation attempts trigger appropriate responses.
- 2743 • Sessions exhibiting privilege escalation attempts are handled according to security policy.
- 2744 • All privilege escalation attempts are logged with session context.
- 2745 • Session security operates continuously throughout session lifecycle.

2746 Verdict

2747 Pass if:

- 2748 • Product implements session security mechanisms;
- 2749 • Session security detects privilege escalation attempts;
- 2750 • Privilege escalation attempts are identified during sessions;
- 2751 • Unauthorised privilege changes are detected;
- 2752 • Detected attempts trigger appropriate responses;
- 2753 • All privilege escalation attempts are logged.

2754 Supporting evidence

- 2755 • Manufacturer documentation describing session security mechanisms;

- 2756 • Product configuration showing privilege escalation detection implementation;
- 2757 • Test results demonstrating detection of privilege escalation attempts;
- 2758 • Simulated privilege escalation attempts showing detection;
- 2759 • Logs showing detected privilege escalation attempts with session context;
- 2760 • Analysis confirming session security operates throughout session lifecycle;
- 2761 • Verification confirming appropriate responses to detected attempts.

2762 7.5.4 [AUTH-4] Protocol access control

2763 7.5.4.1 Requirement assessments

2764 [AUTH-4-RQ-1-01] Verify that when any risk factor PI-RF-1 through PI-RF-5 is present, the product requires
 2765 authentication and authorisation for any administrative action to enable, disable, or configure these protocols, and that
 2766 administrative interfaces controlling protocol behaviour are protected regardless of whether the protocols themselves
 2767 support authentication.

2768 NOTE: This requirement is only applicable when at least one risk factor PI-RF-1 through PI-RF-5 is present.

2769 Activities

2770 Verify:

- 2771 • Manufacturer documentation identifies which risk factors PI-RF-1 through PI-RF-5 are present in the product.
- 2772 • If at least one risk factor PI-RF-1 through PI-RF-5 is present, then administrative actions to enable protocols
 2773 require authentication and authorisation.
- 2774 • If at least one risk factor PI-RF-1 through PI-RF-5 is present, then administrative actions to disable protocols
 2775 require authentication and authorisation.
- 2776 • If at least one risk factor PI-RF-1 through PI-RF-5 is present, then administrative actions to configure protocols
 2777 require authentication and authorisation.
- 2778 • Administrative interfaces controlling protocol behaviour are protected by authentication and authorisation.
- 2779 • Protection of administrative interfaces is independent of whether the protocols themselves support
 2780 authentication.
- 2781 • Attempted administrative actions without authentication are denied.
- 2782 • Attempted administrative actions without authorisation are denied.
- 2783 • All administrative actions on protocol configuration are logged.

2784 Verdict

2785 Pass if:

- 2786 • Risk factors PI-RF-1 through PI-RF-5 are documented;
- 2787 • If applicable risk factors are present, then authentication is required for all administrative actions on protocols;
- 2788 • If applicable risk factors are present, then authorisation is required for all administrative actions on protocols;
- 2789 • Administrative interfaces controlling protocol behaviour are protected;
- 2790 • Protection operates regardless of protocol authentication capabilities;
- 2791 • Unauthorised administrative actions are denied;
- 2792 • Administrative actions are logged.

2793 Supporting evidence

- 2794 • Manufacturer documentation identifying risk factors PI-RF-1 through PI-RF-5 present in product;
- 2795 • Product configuration showing authentication and authorisation requirements for protocol administrative
 2796 actions;
- 2797 • Test results demonstrating authentication requirement for enabling protocols;
- 2798 • Test results demonstrating authentication requirement for disabling protocols;
- 2799 • Test results demonstrating authentication requirement for configuring protocols;
- 2800 • Attempted administrative actions without authentication showing denial;
- 2801 • Attempted administrative actions without authorisation showing denial;
- 2802 • Verification confirming protection independent of protocol authentication capabilities;

- 2803
- Logs showing administrative actions on protocol configuration.

2804 [AUTH-4-RQ-1-02] Verify that when risk factor PI-RF-1 is present, the product provides secure alternative protocols
2805 alongside cleartext management protocols and generates warnings when cleartext protocols are used.

2806 NOTE: This requirement is only applicable when risk factor PI-RF-1 is present.

2807 Activities

2808 Verify:

- 2809
- Manufacturer documentation identifies whether risk factor PI-RF-1 is present in the product.
 - 2810 • If risk factor PI-RF-1 is present, then product provides secure alternative protocols for each cleartext
 - 2811 management protocol.
 - 2812 • If risk factor PI-RF-1 is present, then secure alternative protocols offer equivalent management functionality.
 - 2813 • If risk factor PI-RF-1 is present, then secure alternative protocols use encryption for data transmission.
 - 2814 • If risk factor PI-RF-1 is present, then product generates warnings when cleartext protocols are used.
 - 2815 • If risk factor PI-RF-1 is present, then warnings inform users of security risks associated with cleartext protocol
 - 2816 usage.
 - 2817 • Secure alternatives are accessible and functional alongside cleartext protocols.
 - 2818 • Users can choose between cleartext and secure protocol options.
 - 2819 • Warnings are displayed at appropriate points during cleartext protocol usage.

2820 Verdict

2821 Pass if:

- 2822
- Risk factor PI-RF-1 presence is documented;
 - 2823 • If risk factor PI-RF-1 is present, then secure alternative protocols are provided for each cleartext protocol;
 - 2824 • If risk factor PI-RF-1 is present, then secure alternatives offer equivalent functionality;
 - 2825 • If risk factor PI-RF-1 is present, then warnings are generated when cleartext protocols are used;
 - 2826 • Secure alternatives use encryption;
 - 2827 • Users can select between protocol options.

2828 Supporting evidence

- 2829
- Manufacturer documentation identifying risk factor PI-RF-1 presence;
 - 2830 • Product configuration showing available management protocols;
 - 2831 • Documentation describing secure alternative protocols;
 - 2832 • Test results demonstrating secure protocol functionality;
 - 2833 • Verification confirming equivalent functionality between cleartext and secure protocols;
 - 2834 • Warning messages displayed during cleartext protocol usage;
 - 2835 • Analysis confirming secure alternatives use encryption;
 - 2836 • User interface showing protocol selection options.

2837 [AUTH-4-RQ-1-03] Verify that when risk factor PI-RF-2 is present, the product implements rate limiting and source
2838 validation if possible for unauthenticated protocol requests to mitigate spoofing and injection attacks.

2839 NOTE: This requirement is only applicable when risk factor PI-RF-2 is present.

2840 Activities

2841 Verify:

- 2842
- Manufacturer documentation identifies whether risk factor PI-RF-2 is present in the product.
 - 2843 • If risk factor PI-RF-2 is present, then product implements rate limiting for unauthenticated protocol requests.
 - 2844 • If risk factor PI-RF-2 is present, then product implements source validation for unauthenticated protocol
 - 2845 requests where technically possible.
 - 2846 • Rate limiting mechanisms restrict the number of unauthenticated requests accepted within a defined time
 - 2847 period.

- 2848 • Rate limiting thresholds are appropriate for mitigating attack scenarios.
- 2849 • Source validation mechanisms verify request origin where protocol design permits.
- 2850 • Documentation explains where source validation is not technically possible due to protocol limitations.
- 2851 • Rate limiting prevents request flooding attacks.
- 2852 • Protection mechanisms mitigate spoofing attacks where validation is possible.
- 2853 • Protection mechanisms mitigate injection attacks.
- 2854 • Unauthenticated protocol requests exceeding rate limits are rejected or delayed.

2855 Verdict

2856 Pass if:

- 2857 • Risk factor PI-RF-2 presence is documented;
- 2858 • If risk factor PI-RF-2 is present, then rate limiting is implemented for unauthenticated protocols;
- 2859 • If risk factor PI-RF-2 is present, then source validation is implemented where technically possible;
- 2860 • Rate limiting mechanisms effectively prevent request flooding;
- 2861 • Protection mechanisms mitigate spoofing and injection attacks;
- 2862 • Technical limitations preventing source validation are documented where applicable.

2863 Supporting evidence

- 2864 • Manufacturer documentation identifying risk factor PI-RF-2 presence;
- 2865 • Documentation describing rate limiting mechanisms implemented;
- 2866 • Documentation describing source validation mechanisms;
- 2867 • Test results demonstrating rate limiting in action;
- 2868 • Documentation describing rate limit thresholds and behaviour;
- 2869 • Explanation where source validation is not possible due to protocol limitations;
- 2870 • Test results demonstrating protection against request flooding;
- 2871 • Test results demonstrating attack mitigation effectiveness.

2872 [AUTH-4-RQ-1-04] Verify that when risk factor PI-RF-3 is present, the product provides configuration options to
2873 disable or limit information disclosure through diagnostic protocols.

2874 NOTE: This requirement is only applicable when risk factor PI-RF-3 is present.

2875 Activities

2876 Verify:

- 2877 • Manufacturer documentation identifies whether risk factor PI-RF-3 is present in the product.
- 2878 • If risk factor PI-RF-3 is present, then product provides configuration options for protocols that disclose
2879 information to unauthenticated queries.
- 2880 • If risk factor PI-RF-3 is present, then configuration options allow disabling information-disclosing protocols.
- 2881 • If risk factor PI-RF-3 is present, then configuration options allow limiting information disclosure through
2882 diagnostic protocols.
- 2883 • Configuration options effectively control information disclosure.
- 2884 • Configuration changes to information disclosure settings persist after product restart.
- 2885 • Disabled protocols do not respond to unauthenticated queries.
- 2886 • Limited disclosure configurations restrict information provided in responses.
- 2887 • Users can configure appropriate levels of information disclosure based on operational requirements.
- 2888 • Documentation describes available configuration options for controlling disclosure.

2889 Verdict

2890 Pass if:

- 2891 • Risk factor PI-RF-3 presence is documented;
- 2892 • If risk factor PI-RF-3 is present, then configuration options exist for information-disclosing protocols;
- 2893 • If risk factor PI-RF-3 is present, then information disclosure can be disabled or limited through configuration;

- 2894 • Configuration changes effectively control information disclosure;
- 2895 • Configuration changes persist after restart.

2896 Supporting evidence

- 2897 • Manufacturer documentation identifying risk factor PI-RF-3 presence;
- 2898 • Documentation describing configuration options available for controlling disclosure;
- 2899 • Product configuration showing available options;
- 2900 • Test results demonstrating protocols can be disabled where disable option is provided;
- 2901 • Test results demonstrating information disclosure can be limited where limit option is provided;
- 2902 • Test results demonstrating configuration persistence after restart;
- 2903 • Examples of information disclosed by default for each protocol;
- 2904 • Verification confirming configuration changes effectively control disclosure.

2905 [AUTH-4-RQ-1-05] Verify that when risk factor PI-RF-4 is present, the product documents deprecated cryptographic
 2906 mechanisms and provides configuration options to disable weak protocol versions when operationally feasible.

2907 NOTE: This requirement is only applicable when risk factor PI-RF-4 is present.

2908 Activities

2909 Verify:

- 2910 • Manufacturer documentation identifies whether risk factor PI-RF-4 is present in the product.
- 2911 • If risk factor PI-RF-4 is present, then manufacturer documentation lists all deprecated cryptographic
 2912 mechanisms.
- 2913 • If risk factor PI-RF-4 is present, then documentation describes risks associated with deprecated mechanisms.
- 2914 • If risk factor PI-RF-4 is present, then product provides configuration options to disable weak protocol versions
 2915 where operationally feasible.
- 2916 • If risk factor PI-RF-4 is present, then documentation explains cases where disabling weak protocol versions is
 2917 not operationally feasible.
- 2918 • Deprecated cryptographic mechanisms are clearly identified in documentation.
- 2919 • Configuration options allow disabling weak protocol versions where feasible.
- 2920 • Strong protocol versions remain functional when weak versions are disabled.
- 2921 • Documentation provides justification where disabling is not operationally feasible.
- 2922 • Disabled weak protocol versions no longer accept connections.

2923 Verdict

2924 Pass if:

- 2925 • Risk factor PI-RF-4 presence is documented;
- 2926 • If risk factor PI-RF-4 is present, then deprecated cryptographic mechanisms are documented;
- 2927 • If risk factor PI-RF-4 is present, then configuration options to disable weak versions are provided where
 2928 operationally feasible;
- 2929 • If risk factor PI-RF-4 is present, then operational infeasibility is documented where weak protocols cannot be
 2930 disabled;
- 2931 • Documentation identifies weak cryptographic mechanisms;
- 2932 • Strong protocol versions continue to function when weak versions are disabled.

2933 Supporting evidence

- 2934 • Manufacturer documentation identifying risk factor PI-RF-4 presence;
- 2935 • Documentation listing all deprecated cryptographic mechanisms;
- 2936 • Documentation describing risks associated with deprecated mechanisms;
- 2937 • Documentation describing configuration options available for disabling weak protocol versions;
- 2938 • Documentation explaining cases where disabling is not operationally feasible;
- 2939 • Test results demonstrating weak versions can be disabled where operationally feasible;
- 2940 • Test results demonstrating disabled protocols no longer function;

- 2941
- Test results demonstrating strong protocol versions continue to work.

2942 [AUTH-4-RQ-1-06] Verify that when risk factor PI-RF-5 is present, the product implements additional validation
2943 mechanisms for trust establishment and provides audit logging for all trust relationship changes.

2944 NOTE: This requirement is only applicable when risk factor PI-RF-5 is present.

2945 Activities

2946 Verify:

- 2947
- Manufacturer documentation identifies whether risk factor PI-RF-5 is present in the product.
 - 2948 • If risk factor PI-RF-5 is present, then product implements additional validation mechanisms for trust
 - 2949 establishment.
 - 2950 • If risk factor PI-RF-5 is present, then product provides audit logging for all trust relationship changes.
 - 2951 • Additional validation mechanisms supplement protocols that establish trust without cryptographic verification.
 - 2952 • Trust establishment operations are validated through additional security controls.
 - 2953 • All trust relationship changes are logged with relevant details.
 - 2954 • Audit logs include timestamps for trust relationship changes.
 - 2955 • Audit logs include identifiers for entities involved in trust relationships.
 - 2956 • Audit logs include the nature of trust relationship changes.
 - 2957 • Validation mechanisms operate for all trust establishment protocols.
 - 2958 • Trust relationship modifications are captured in audit logs.

2959 Verdict

2960 Pass if:

- 2961
- Risk factor PI-RF-5 presence is documented;
 - 2962 • If risk factor PI-RF-5 is present, then additional validation mechanisms are implemented for trust
 - 2963 establishment;
 - 2964 • If risk factor PI-RF-5 is present, then audit logging is provided for all trust relationship changes;
 - 2965 • Validation mechanisms supplement trust establishment without cryptographic verification;
 - 2966 • All trust relationship changes are logged with timestamps and identifiers.

2967 Supporting evidence

- 2968
- Manufacturer documentation identifying risk factor PI-RF-5 presence;
 - 2969 • Documentation describing additional validation mechanisms for trust establishment;
 - 2970 • Documentation describing audit logging for trust relationship changes;
 - 2971 • Test results demonstrating validation mechanisms operate during trust establishment;
 - 2972 • Audit logs showing trust relationship establishment events;
 - 2973 • Audit logs showing trust relationship modification events;
 - 2974 • Verification confirming logs include timestamps and entity identifiers;
 - 2975 • Analysis confirming validation mechanisms supplement protocols without cryptographic verification.

2976 7.6 Data Protection

2977 7.6.1.1 Requirement assessments

2978 [DATA-1-RQ-1-1] Verify the product implements data protection measures ensuring all sensitive data including
2979 passwords, application-level cryptographic keys, and user credentials are encrypted at rest using best practice
2980 cryptographic algorithms.

2981 Activities

2982 Verify:

- 2983
- Manufacturer documentation describes data protection measures for sensitive data at rest.

- 2984 • Product encrypts passwords at rest using cryptographic protection.
- 2985 • Product encrypts application-level cryptographic keys at rest using cryptographic protection.
- 2986 • Product encrypts user credentials at rest using cryptographic protection.
- 2987 • Cryptographic algorithms used for data at rest encryption meet best practice standards.
- 2988 • All sensitive data storage locations implement encryption at rest.
- 2989 • Encrypted data cannot be retrieved in plaintext without proper authorisation.
- 2990 • Cryptographic algorithms comply with current recognised standards.
- 2991 • Data protection measures cover all types of sensitive data stored by the product.
- 2992 • Storage mechanisms prevent unauthorised access to sensitive data.

2993 Verdict

2994 Pass if:

- 2995 • Product implements data protection measures for sensitive data at rest;
- 2996 • Passwords are encrypted at rest using best practice cryptographic algorithms;
- 2997 • Application-level cryptographic keys are encrypted at rest using best practice cryptographic algorithms;
- 2998 • User credentials are encrypted at rest using best practice cryptographic algorithms;
- 2999 • Cryptographic algorithms meet best practice standards;
- 3000 • Encrypted data cannot be retrieved in plaintext without authorisation.

3001 Supporting evidence

- 3002 • Manufacturer documentation describing data protection measures;
- 3003 • Analysis of password storage showing encryption at rest;
- 3004 • Analysis of cryptographic key storage showing encryption at rest;
- 3005 • Analysis of user credential storage showing encryption at rest;
- 3006 • Verification confirming cryptographic algorithms meet best practice standards;
- 3007 • Storage location analysis confirming encryption implementation;
- 3008 • Test results demonstrating encrypted data cannot be retrieved without authorisation;
- 3009 • Analysis confirming cryptographic algorithms comply with recognised standards.

3010 [DATA-1-RQ-1-2] Verify the product implements data protection measures ensuring all management communications
3011 and control plane traffic employ encrypted channels providing both confidentiality and integrity protection through best
3012 practice cryptography.

3013 Activities

3014 Verify:

- 3015 • Manufacturer documentation describes data protection measures for management communications and control
3016 plane traffic.
- 3017 • All management communications employ encrypted channels.
- 3018 • All control plane traffic employs encrypted channels.
- 3019 • Encrypted channels provide confidentiality protection for transmitted data.
- 3020 • Encrypted channels provide integrity protection for transmitted data.
- 3021 • Cryptographic algorithms used for channel encryption meet best practice standards.
- 3022 • Management communications are not transmitted in plaintext.
- 3023 • Control plane traffic is not transmitted in plaintext.
- 3024 • Encryption is mandatory for all management and control plane communications.
- 3025 • Cryptographic protection cannot be disabled for management communications.
- 3026 • Cryptographic protection cannot be disabled for control plane traffic.

3027 Verdict

3028 Pass if:

- 3029 • Product implements data protection measures for management communications and control plane traffic;
- 3030 • All management communications employ encrypted channels;

- 3031 • All control plane traffic employs encrypted channels;
- 3032 • Encrypted channels provide confidentiality and integrity protection;
- 3033 • Cryptographic algorithms meet best practice standards;
- 3034 • Management and control plane communications are not transmitted in plaintext.

3035 Supporting evidence

- 3036 • Manufacturer documentation describing data protection measures;
- 3037 • Network traffic analysis showing encrypted management communications;
- 3038 • Network traffic analysis showing encrypted control plane traffic;
- 3039 • Verification confirming confidentiality protection for transmitted data;
- 3040 • Verification confirming integrity protection for transmitted data;
- 3041 • Analysis confirming cryptographic algorithms meet best practice standards;
- 3042 • Test results demonstrating no plaintext transmission of management communications;
- 3043 • Test results demonstrating no plaintext transmission of control plane traffic;
- 3044 • Protocol analysis confirming mandatory encryption for management and control plane communications.

3045 [DATA-1-RQ-1-3] Verify the product implements data protection measures ensuring configuration files and firmware
3046 images are protected against unauthorised modification.

3047 Activities

3048 Verify:

- 3049 • Manufacturer documentation describes data protection measures for configuration files and firmware images.
- 3050 • Product implements protection mechanisms for configuration files against unauthorised modification.
- 3051 • Product implements protection mechanisms for firmware images against unauthorised modification.
- 3052 • Integrity protection mechanisms detect unauthorised modifications to configuration files.
- 3053 • Integrity protection mechanisms detect unauthorised modifications to firmware images.
- 3054 • Unauthorised attempts to modify configuration files are prevented or detected.
- 3055 • Unauthorised attempts to modify firmware images are prevented or detected.
- 3056 • Protection mechanisms operate continuously during product operation.
- 3057 • Modifications to configuration files require appropriate authorisation.
- 3058 • Modifications to firmware images require appropriate authorisation.
- 3059 • Integrity verification mechanisms confirm configuration and firmware integrity.

3060 Verdict

3061 Pass if:

- 3062 • Product implements data protection measures for configuration files and firmware images;
- 3063 • Configuration files are protected against unauthorised modification;
- 3064 • Firmware images are protected against unauthorised modification;
- 3065 • Integrity protection mechanisms detect unauthorised modifications;
- 3066 • Unauthorised modification attempts are prevented or detected;
- 3067 • Modifications require appropriate authorisation.

3068 Supporting evidence

- 3069 • Manufacturer documentation describing data protection measures;
- 3070 • Product configuration showing protection mechanisms for configuration files;
- 3071 • Product configuration showing protection mechanisms for firmware images;
- 3072 • Test results demonstrating integrity protection for configuration files;
- 3073 • Test results demonstrating integrity protection for firmware images;
- 3074 • Attempted unauthorised modification of configuration files showing prevention or detection;
- 3075 • Attempted unauthorised modification of firmware images showing prevention or detection;
- 3076 • Verification confirming integrity verification mechanisms;
- 3077 • Analysis confirming protection mechanisms operate continuously.

3078 [DATA-1-RQ-1-4] Verify the product implements data protection measures ensuring the product processes and retains
 3079 only the minimum data necessary for its intended routing, switching, or modem functions, and that any diagnostic or
 3080 telemetry data collection beyond intended purpose of the product requires explicit opt-in configuration, with such
 3081 collection disabled by default.

3082 Activities

3083 Verify:

- 3084 • Manufacturer documentation describes data processing and retention practices.
- 3085 • Manufacturer documentation defines the intended routing, switching, or modem functions of the product.
- 3086 • Product processes only the minimum data necessary for its intended functions.
- 3087 • Product retains only the minimum data necessary for its intended functions.
- 3088 • Manufacturer documentation identifies diagnostic or telemetry data collection capabilities beyond intended
 3089 purpose.
- 3090 • Diagnostic or telemetry data collection beyond intended purpose is disabled by default in factory default state.
- 3091 • Enabling diagnostic or telemetry data collection beyond intended purpose requires explicit opt-in
 3092 configuration.
- 3093 • Users have to actively configure the product to enable additional data collection.
- 3094 • Product does not collect diagnostic or telemetry data beyond intended purpose without user consent.
- 3095 • Configuration interface clearly identifies optional diagnostic or telemetry data collection.
- 3096 • Documentation explains what data is collected when optional features are enabled.
- 3097 • Data retention periods are limited to operational necessity.

3098 Verdict

3099 Pass if:

- 3100 • Product processes only minimum data necessary for intended functions;
- 3101 • Product retains only minimum data necessary for intended functions;
- 3102 • Diagnostic or telemetry data collection beyond intended purpose is disabled by default;
- 3103 • Additional data collection requires explicit opt-in configuration;
- 3104 • Product does not collect additional data without user consent;
- 3105 • Documentation describes data processing and retention practices.

3106 Supporting evidence

- 3107 • Manufacturer documentation describing data processing and retention practices;
- 3108 • Manufacturer documentation defining intended product functions;
- 3109 • Product configuration in factory default state showing diagnostic and telemetry data collection status;
- 3110 • Data flow analysis confirming only necessary data is processed;
- 3111 • Data retention analysis confirming only necessary data is retained;
- 3112 • Configuration interface showing opt-in options for additional data collection;
- 3113 • Documentation describing diagnostic and telemetry data collection capabilities;
- 3114 • Test results demonstrating additional data collection is disabled by default;
- 3115 • Test results demonstrating opt-in requirement for enabling additional collection;
- 3116 • Verification confirming product does not collect additional data without explicit consent.

3117 7.7 Availability and Resilience

3118 7.7.1.1 Requirement assessments

3119 [AVAIL-1-RQ-1-1] Verify the product maintains resilience against denial-of-service attacks using appropriate
 3120 techniques which include but are not limited to rate limiting and connection throttling for supported network protocols.

3121 Activities

3122 Verify:

- 3123 • Manufacturer documentation describes denial-of-service protection mechanisms implemented.
- 3124 • Product implements rate limiting for network protocols.
- 3125 • Product implements connection throttling for network protocols.
- 3126 • Rate limiting mechanisms restrict the number of requests accepted within defined time periods.
- 3127 • Connection throttling mechanisms control the rate of new connection establishment.
- 3128 • Protection mechanisms operate for all supported network protocols.
- 3129 • Rate limiting thresholds are appropriate for preventing resource exhaustion.
- 3130 • Connection throttling prevents excessive connection attempts from overwhelming the product.
- 3131 • Product maintains essential functions during denial-of-service attack conditions.
- 3132 • Legitimate traffic is preserved during attack mitigation.
- 3133 • Protection mechanisms activate automatically when attack patterns are detected.
- 3134 • Product continues to process legitimate requests during attack scenarios.

3135 Verdict

3136 Pass if:

- 3137 • Product implements denial-of-service protection mechanisms;
- 3138 • Rate limiting is implemented for network protocols;
- 3139 • Connection throttling is implemented for network protocols;
- 3140 • Protection mechanisms prevent resource exhaustion;
- 3141 • Product maintains essential functions during attack conditions;
- 3142 • Legitimate traffic is preserved during attack mitigation.

3143 Supporting evidence

- 3144 • Manufacturer documentation describing denial-of-service protection mechanisms;
- 3145 • Product configuration showing rate limiting implementation;
- 3146 • Product configuration showing connection throttling implementation;
- 3147 • Documentation describing rate limiting thresholds and behaviour;
- 3148 • Documentation describing connection throttling parameters;
- 3149 • Test results demonstrating rate limiting in action;
- 3150 • Test results demonstrating connection throttling in action;
- 3151 • Test results demonstrating product maintains essential functions during simulated attacks;
- 3152 • Verification confirming legitimate traffic processing during attack scenarios;
- 3153 • Analysis confirming protection mechanisms cover all supported network protocols.

3154 [AVAIL-1-RQ-1-2] Verify the product automatically recovers to normal operational state when denial-of-service
3155 conditions cease, without requiring manual intervention.

3156 Activities

3157 Verify:

- 3158 • Manufacturer documentation describes automatic recovery mechanisms from denial-of-service conditions.
- 3159 • Product detects when denial-of-service conditions cease.
- 3160 • Product automatically returns to normal operational state after attack conditions end.
- 3161 • Recovery occurs without requiring manual intervention.
- 3162 • Recovery occurs without requiring administrative action.
- 3163 • All essential functions resume normal operation after recovery.
- 3164 • Protection mechanisms that were activated during attack are deactivated appropriately after recovery.
- 3165 • Rate limiting returns to normal thresholds after attack conditions cease.
- 3166 • Connection throttling returns to normal behaviour after attack conditions cease.
- 3167 • Recovery time is appropriate for maintaining service availability.
- 3168 • Product does not remain in degraded state after attack ends.
- 3169 • No manual reset or restart is required for recovery.

3170 Verdict

3171 Pass if:

- 3172 • Product automatically detects when denial-of-service conditions cease;
- 3173 • Product automatically recovers to normal operational state;
- 3174 • Recovery occurs without manual intervention;
- 3175 • All essential functions resume normal operation after recovery;
- 3176 • Protection mechanisms return to normal state appropriately;
- 3177 • Product does not remain in degraded state after attack ends.

3178 Supporting evidence

- 3179 • Manufacturer documentation describing automatic recovery mechanisms;
- 3180 • Test results demonstrating automatic detection of attack cessation;
- 3181 • Test results demonstrating automatic recovery to normal operational state;
- 3182 • Verification confirming recovery occurs without manual intervention;
- 3183 • Test results showing all essential functions resume normal operation;
- 3184 • Verification confirming rate limiting returns to normal thresholds;
- 3185 • Verification confirming connection throttling returns to normal behaviour;
- 3186 • Analysis confirming appropriate recovery time;
- 3187 • Test results demonstrating no manual reset or restart required.

3188 [AVAIL-1-RQ-1-3] Verify the product generates audit events when it detects high resource utilisation and when
3189 resource utilisation returns to levels designated by the manufacturer as normal.

3190 Activities

3191 Verify:

- 3192 • Manufacturer documentation describes audit events generated for resource utilisation monitoring.
- 3193 • Manufacturer documentation defines what constitutes high resource utilisation.
- 3194 • Manufacturer documentation defines normal resource utilisation levels.
- 3195 • Product generates audit events when high resource utilisation is detected.
- 3196 • Product generates audit events when resource utilisation returns to normal levels.
- 3197 • High resource utilisation detection includes sustained high CPU utilisation where applicable.
- 3198 • High resource utilisation detection includes memory exhaustion where applicable.
- 3199 • High resource utilisation detection includes high packet drop count where applicable.
- 3200 • All resource utilisation audit events include timestamps.
- 3201 • Audit events include details of resource utilisation levels detected.
- 3202 • Audit events identify which resources triggered the high utilisation alert.
- 3203 • Audit events indicate when resource utilisation returns to manufacturer-designated normal levels.
- 3204 • All resource utilisation audit events are recorded and accessible for review.
- 3205 • Audit events are retained according to documented retention policies.

3206 Verdict

3207 Pass if:

- 3208 • Product generates audit events when high resource utilisation is detected;
- 3209 • Product generates audit events when resource utilisation returns to normal levels;
- 3210 • Manufacturer documentation defines high and normal resource utilisation levels;
- 3211 • All audit events include timestamps and resource utilisation details;
- 3212 • Audit events identify which resources are affected;
- 3213 • Audit events are accessible for review.

3214 Supporting evidence

- 3215 • Manufacturer documentation describing audit events for resource utilisation;
- 3216 • Manufacturer documentation defining high resource utilisation thresholds;

- 3217 • Manufacturer documentation defining normal resource utilisation levels;
- 3218 • Audit logs showing high resource utilisation detection events;
- 3219 • Audit logs showing return to normal resource utilisation events;
- 3220 • Verification confirming all audit events include timestamps;
- 3221 • Verification confirming audit events include resource utilisation details;
- 3222 • Test results demonstrating audit event generation during high resource utilisation;
- 3223 • Test results demonstrating audit event generation when returning to normal;
- 3224 • Analysis confirming audit event retention and accessibility.

3225 [AVAIL-1-RQ-1-4] Verify the product stores audit events in persistent memory that survives the reset.

3226 Activities

3227 Verify:

- 3228 • Manufacturer documentation describes audit event storage mechanisms.
- 3229 • Audit events are stored in persistent memory.
- 3230 • Audit events recorded before reset operation are documented.
- 3231 • Reset operation is performed.
- 3232 • Audit events recorded before reset remain accessible after reset.
- 3233 • Audit event storage survives power cycles.
- 3234 • Audit event storage survives factory reset operations.
- 3235 • Audit event storage is not volatile memory.
- 3236 • All previously recorded audit events are retrievable after reset.
- 3237 • Storage mechanism preserves event integrity through reset operations.

3238 Verdict

3239 Pass if:

- 3240 • Audit events are stored in persistent memory;
- 3241 • Audit events survive reset operations;
- 3242 • Previously recorded events remain accessible after reset;
- 3243 • Audit event storage survives power cycles;
- 3244 • Audit event integrity is maintained through reset operations.

3245 Supporting evidence

- 3246 • Manufacturer documentation describing audit event storage mechanisms;
- 3247 • Audit events recorded before reset operation;
- 3248 • Reset operation confirmation;
- 3249 • Audit events retrieved after reset operation;
- 3250 • Comparison showing audit events preserved through reset;
- 3251 • Verification confirming persistent memory storage;
- 3252 • Analysis confirming storage survives power cycles and factory reset.

3253 7.8 Attack Surface and Mitigation

3254 7.8.1 [INTEGRITY] System integrity and boot process

3255 7.8.1.1 Requirement assessments

3256 [INTEGRITY-1-RQ-1-01] Verify the product implements cryptographic verification of boot components using best
3257 practice cryptographic methods.

3258 Activities

3259 Verify:

- 3260 • Manufacturer documentation describes cryptographic verification mechanisms for boot components.
- 3261 • Product implements cryptographic verification during boot process.
- 3262 • All boot components are cryptographically verified before execution.
- 3263 • Cryptographic verification uses best practice methods.
- 3264 • Cryptographic algorithms used for boot verification comply with current recognised standards.
- 3265 • Boot components include cryptographic signatures or equivalent verification data.
- 3266 • Verification process validates authenticity of boot components.
- 3267 • Verification process validates integrity of boot components.
- 3268 • Boot process halts or takes appropriate action if verification fails.
- 3269 • Unverified boot components are not executed.
- 3270 • Cryptographic keys used for boot verification are properly protected.
- 3271 • Boot verification mechanisms operate automatically without user intervention.

3272 Verdict

3273 Pass if:

- 3274 • Product implements cryptographic verification of boot components;
- 3275 • Cryptographic verification uses best practice methods;
- 3276 • All boot components are verified before execution;
- 3277 • Cryptographic algorithms comply with current recognised standards;
- 3278 • Boot process halts or takes appropriate action if verification fails;
- 3279 • Unverified components are not executed.

3280 Supporting evidence

- 3281 • Manufacturer documentation describing cryptographic verification mechanisms for boot components;
- 3282 • Analysis of boot process showing cryptographic verification implementation;
- 3283 • Verification confirming cryptographic methods meet best practice standards;
- 3284 • Test results demonstrating boot component verification before execution;
- 3285 • Verification confirming cryptographic algorithms comply with recognised standards;
- 3286 • Test results showing boot process response to verification failures;
- 3287 • Analysis confirming unverified components are not executed;
- 3288 • Verification confirming cryptographic key protection for boot verification.

3289 [INTEGRITY-1-RQ-1-02] Verify the product establishes a secure boot chain where each stage verifies the next stage
 3290 before transferring control, the initial bootloader is immutable or hardware-protected, verification failures halt the boot
 3291 process, and only verified code can execute during normal boot.

3292 Activities

3293 Verify:

- 3294 • Manufacturer documentation describes secure boot chain implementation.
- 3295 • Product implements a secure boot chain where each boot stage verifies the next stage.
- 3296 • Each boot stage completes verification before transferring control to the next stage.
- 3297 • Initial bootloader is immutable or protected by hardware mechanisms.
- 3298 • Initial bootloader cannot be modified through software means.
- 3299 • Hardware protection mechanisms prevent unauthorised modification of initial bootloader where applicable.
- 3300 • Verification occurs at each stage transition in the boot process.
- 3301 • Boot process halts when verification failure is detected at any stage.
- 3302 • Failed verification prevents transfer of control to unverified stages.
- 3303 • Only cryptographically verified code executes during normal boot process.
- 3304 • Unverified code cannot execute during boot sequence.
- 3305 • Boot chain maintains integrity from initial bootloader through final operating system load.
- 3306 • Verification failures generate appropriate diagnostic information.

3307 Verdict

3308 Pass if:

- 3309 • Product establishes a secure boot chain where each stage verifies the next stage;
- 3310 • Verification occurs before control transfer at each stage;
- 3311 • Initial bootloader is immutable or hardware-protected;
- 3312 • Verification failures halt the boot process;
- 3313 • Only verified code executes during normal boot;
- 3314 • Unverified code cannot execute during boot sequence.

3315 Supporting evidence

- 3316 • Manufacturer documentation describing secure boot chain implementation;
- 3317 • Analysis of boot process showing stage-by-stage verification;
- 3318 • Verification confirming each stage verifies next stage before control transfer;
- 3319 • Analysis confirming initial bootloader is immutable or hardware-protected;
- 3320 • Test results demonstrating boot process halts on verification failure;
- 3321 • Attempted boot with modified component showing verification failure and halt;
- 3322 • Verification confirming only verified code executes during normal boot;
- 3323 • Analysis confirming boot chain integrity from initial bootloader through operating system;
- 3324 • Documentation describing hardware protection mechanisms for initial bootloader where applicable.

3325 [INTEGRITY-1-RQ-1-03] Verify the product generates audit events of all boot events including boot stage progression
3326 with timestamps, verification success or failure for each component, recovery mode activation, and detected bypass
3327 attempts.

3328 Activities

3329 Verify:

- 3330 • Manufacturer documentation describes audit events generated for boot processes.
- 3331 • Product generates audit events for boot stage progression.
- 3332 • Product generates audit events for verification success of each boot component.
- 3333 • Product generates audit events for verification failure of each boot component.
- 3334 • Product generates audit events for recovery mode activation.
- 3335 • Product generates audit events for detected bypass attempts.
- 3336 • All boot-related audit events include timestamps.
- 3337 • Audit events include identification of boot stages reached.
- 3338 • Audit events include verification results for each boot component.
- 3339 • Audit events include details of recovery mode activation circumstances.
- 3340 • Audit events include details of detected bypass attempts.
- 3341 • Boot audit events are recorded in persistent storage.
- 3342 • Boot audit events are accessible for review after boot completion.
- 3343 • All boot events are captured regardless of boot outcome.

3344 Verdict

3345 Pass if:

- 3346 • Product generates audit events for boot stage progression;
- 3347 • Product generates audit events for verification success and failure of each component;
- 3348 • Product generates audit events for recovery mode activation;
- 3349 • Product generates audit events for detected bypass attempts;
- 3350 • All boot audit events include timestamps;
- 3351 • Boot audit events are recorded in persistent storage;
- 3352 • Boot audit events are accessible for review.

3353 Supporting evidence

- 3354 • Manufacturer documentation describing audit events for boot processes;
- 3355 • Audit logs showing boot stage progression events;
- 3356 • Audit logs showing verification success events for boot components;
- 3357 • Audit logs showing verification failure events for boot components;
- 3358 • Audit logs showing recovery mode activation events;
- 3359 • Audit logs showing detected bypass attempt events;
- 3360 • Verification confirming all boot events include timestamps;
- 3361 • Verification confirming boot audit events are stored in persistent storage;
- 3362 • Analysis confirming boot audit events are accessible after boot completion;
- 3363 • Test results demonstrating audit event generation for various boot scenarios.

3364 [INTEGRITY-1-RQ-1-04] Verify the product stores audit events in persistent memory that survives the reset.

3365 Activities

3366 Verify:

- 3367 • Manufacturer documentation describes audit event storage mechanisms.
- 3368 • Audit events are stored in persistent memory.
- 3369 • Audit events recorded before reset operation are documented.
- 3370 • Reset operation is performed.
- 3371 • Audit events recorded before reset remain accessible after reset.
- 3372 • Audit event storage survives power cycles.
- 3373 • Audit event storage survives factory reset operations.
- 3374 • Audit event storage is not volatile memory.
- 3375 • All previously recorded audit events are retrievable after reset.
- 3376 • Storage mechanism preserves event integrity through reset operations.

3377 Verdict

3378 Pass if:

- 3379 • Audit events are stored in persistent memory;
- 3380 • Audit events survive reset operations;
- 3381 • Previously recorded events remain accessible after reset;
- 3382 • Audit event storage survives power cycles;
- 3383 • Audit event integrity is maintained through reset operations.

3384 Supporting evidence

- 3385 • Manufacturer documentation describing audit event storage mechanisms;
- 3386 • Audit events recorded before reset operation;
- 3387 • Reset operation confirmation;
- 3388 • Audit events retrieved after reset operation;
- 3389 • Comparison showing audit events preserved through reset;
- 3390 • Verification confirming persistent memory storage;
- 3391 • Analysis confirming storage survives power cycles and factory reset.

3392 [INTEGRITY-1-RQ-1-05] Verify the product protects recovery and maintenance modes, if present, by implementing
3393 authentication and authorisation before granting access.

3394 Activities

3395 Verify:

- 3396 • Manufacturer documentation identifies whether recovery mode is present in the product.
- 3397 • Manufacturer documentation identifies whether maintenance mode is present in the product.
- 3398 • If recovery mode is present, then access to recovery mode requires authentication.
- 3399 • If recovery mode is present, then access to recovery mode requires authorisation.

- 3400 • If maintenance mode is present, then access to maintenance mode requires authentication.
- 3401 • If maintenance mode is present, then access to maintenance mode requires authorisation.
- 3402 • Authentication occurs before granting access to recovery mode.
- 3403 • Authentication occurs before granting access to maintenance mode.
- 3404 • Authorisation verifies appropriate privileges before allowing recovery mode access.
- 3405 • Authorisation verifies appropriate privileges before allowing maintenance mode access.
- 3406 • Attempted access to recovery mode without authentication is denied.
- 3407 • Attempted access to maintenance mode without authentication is denied.
- 3408 • Attempted access without proper authorisation is denied for both modes.
- 3409 • Recovery and maintenance mode access attempts are logged.

3410 Verdict

3411 Pass if:

- 3412 • Recovery and maintenance mode presence is documented;
- 3413 • If recovery mode is present, then authentication and authorisation are required for access;
- 3414 • If maintenance mode is present, then authentication and authorisation are required for access;
- 3415 • Access without authentication is denied;
- 3416 • Access without authorisation is denied;
- 3417 • Access attempts are logged.

3418 Supporting evidence

- 3419 • Manufacturer documentation identifying recovery mode presence;
- 3420 • Manufacturer documentation identifying maintenance mode presence;
- 3421 • Product configuration showing authentication requirements for recovery mode if present;
- 3422 • Product configuration showing authentication requirements for maintenance mode if present;
- 3423 • Test results demonstrating authentication requirement for recovery mode access if present;
- 3424 • Test results demonstrating authentication requirement for maintenance mode access if present;
- 3425 • Attempted access to recovery mode without authentication showing denial if present;
- 3426 • Attempted access to maintenance mode without authentication showing denial if present;
- 3427 • Logs showing recovery and maintenance mode access attempts;
- 3428 • Verification confirming authorisation requirements for both modes if present.

3429 7.8.2 [PACKET] Default packet disposition

3430 7.8.2.1 Requirement assessments

3431 [PACKET-1-RQ-1-01] Verify the product drops any packet for which it cannot determine the appropriate processing
3432 action based on implemented protocol handlers, forwarding rules, or state machines, including packets with
3433 unrecognised protocol identifiers or type fields, packets with invalid or unexpected encapsulation combinations, packets
3434 that would require processing beyond the product's implemented protocol stack depth, packets with header field values
3435 outside the ranges specified in relevant protocol standards, packets that cannot be matched to existing connection state
3436 for stateful protocols, and any packet that would trigger undefined behaviour in product.

3437 Activities

3438 Verify:

- 3439 • Manufacturer documentation describes packet processing and dropping behaviour.
- 3440 • Product drops packets when appropriate processing action cannot be determined.
- 3441 • Product drops packets with unrecognised protocol identifiers.
- 3442 • Product drops packets with unrecognised type fields.
- 3443 • Product drops packets with invalid encapsulation combinations.
- 3444 • Product drops packets with unexpected encapsulation combinations.
- 3445 • Product drops packets that would require processing beyond implemented protocol stack depth.
- 3446 • Product drops packets with header field values outside ranges specified in relevant protocol standards.
- 3447 • Product drops packets that cannot be matched to existing connection state for stateful protocols.

- 3448 • Product drops packets that would trigger undefined behaviour.
- 3449 • Dropped packets do not cause processing errors or system instability.
- 3450 • Packet dropping behaviour is consistent across all protocol types.
- 3451 • Product does not attempt to process packets it cannot handle safely.
- 3452 • Packet drops are logged with appropriate detail where feasible.

3453 Verdict

3454 Pass if:

- 3455 • Product drops packets when appropriate processing action cannot be determined;
- 3456 • Packets with unrecognised protocol identifiers or type fields are dropped;
- 3457 • Packets with invalid or unexpected encapsulation combinations are dropped;
- 3458 • Packets requiring processing beyond implemented stack depth are dropped;
- 3459 • Packets with header field values outside protocol standard ranges are dropped;
- 3460 • Packets that cannot be matched to connection state are dropped for stateful protocols;
- 3461 • Packets that would trigger undefined behaviour are dropped;
- 3462 • Dropped packets do not cause processing errors or instability.

3463 Supporting evidence

- 3464 • Manufacturer documentation describing packet processing and dropping behaviour;
- 3465 • Test results demonstrating dropping of packets with unrecognised protocol identifiers;
- 3466 • Test results demonstrating dropping of packets with unrecognised type fields;
- 3467 • Test results demonstrating dropping of packets with invalid encapsulation combinations;
- 3468 • Test results demonstrating dropping of packets beyond protocol stack depth;
- 3469 • Test results demonstrating dropping of packets with invalid header field values;
- 3470 • Test results demonstrating dropping of packets without matching connection state;
- 3471 • Verification confirming dropped packets do not cause system instability;
- 3472 • Logs showing packet drop events where applicable;
- 3473 • Analysis confirming consistent dropping behaviour across protocol types.

3474 [PACKET-1-RQ-1-02] Verify the product does not attempt partial processing, best-effort forwarding, or fallback
3475 handling for packets that cannot be fully validated against implemented protocol specifications, and that when packet
3476 processing uncertainty exists at any protocol layer, the entire packet is dropped rather than processed at other layers.

3477 Activities

3478 Verify:

- 3479 • Manufacturer documentation describes packet validation and processing behaviour.
- 3480 • Product does not attempt partial processing of packets that cannot be fully validated.
- 3481 • Product does not attempt best-effort forwarding of packets that cannot be fully validated.
- 3482 • Product does not implement fallback handling for packets that cannot be fully validated.
- 3483 • When packet processing uncertainty exists at any protocol layer, the entire packet is dropped.
- 3484 • Packets with validation failures at one layer are not processed at other layers.
- 3485 • Product does not forward packets that fail validation at any protocol layer.
- 3486 • Invalid packets are dropped completely rather than processed partially.
- 3487 • No fallback mechanisms process packets that fail validation.
- 3488 • Packet dropping occurs at the point where validation fails.
- 3489 • Failed validation at any layer prevents further processing of the packet.
- 3490 • Product behaviour is consistent for all validation failures across protocol layers.

3491 Verdict

3492 Pass if:

- 3493 • Product does not attempt partial processing of invalidated packets;

- 3494 • Product does not attempt best-effort forwarding of invalidated packets;
- 3495 • Product does not implement fallback handling for invalidated packets;
- 3496 • When uncertainty exists at any protocol layer, entire packet is dropped;
- 3497 • Packets with validation failures at one layer are not processed at other layers;
- 3498 • Packet dropping is consistent across all protocol layers.

3499 Supporting evidence

- 3500 • Manufacturer documentation describing packet validation and processing behaviour;
- 3501 • Test results demonstrating no partial processing of invalid packets;
- 3502 • Test results demonstrating no best-effort forwarding of invalid packets;
- 3503 • Test results demonstrating no fallback handling for invalid packets;
- 3504 • Test results showing entire packet drop when validation fails at any layer;
- 3505 • Verification confirming packets failing validation at one layer are not processed at other layers;
- 3506 • Analysis confirming consistent dropping behaviour across protocol layers;
- 3507 • Test results with packets having validation failures at different layers showing complete packet drop.

3508 7.8.3 [EXPOSURE] Interface and service exposure minimization

3509 7.8.3.1 Requirement assessments

3510 [EXPOSURE-1-RQ-1-01] Verify the product disables all interfaces and services that are not essential for the product's
 3511 intended function in its default configuration, including debug interfaces such as JTAG, UART, and SWD unless
 3512 physically secured, unused network protocols and services, test modes and diagnostic functions not required for normal
 3513 operation, legacy protocols maintained only for backward compatibility when not actively required, and any
 3514 management interfaces beyond those explicitly documented for user access.

3515 Activities

3516 Verify:

- 3517 • Manufacturer documentation describes the product's intended function and essential interfaces and services.
- 3518 • Product default configuration is examined for enabled interfaces and services.
- 3519 • All enabled interfaces and services in default configuration are essential for the product's intended function.
- 3520 • Debug interfaces are disabled in default configuration unless physically secured.
- 3521 • Unused network protocols are disabled in default configuration.
- 3522 • Unused network services are disabled in default configuration.
- 3523 • Test modes not required for normal operation are disabled in default configuration.
- 3524 • Diagnostic functions not required for normal operation are disabled in default configuration.
- 3525 • Legacy protocols maintained only for backward compatibility are disabled when not actively required.
- 3526 • Only management interfaces explicitly documented for user access are enabled in default configuration.
- 3527 • All non-essential interfaces and services can be identified and verified as disabled.
- 3528 • Physical security mechanisms for debug interfaces are documented where debug interfaces remain accessible.
- 3529 • Product does not expose unnecessary attack surface in default configuration.

3530 Verdict

3531 Pass if:

- 3532 • All interfaces and services enabled in default configuration are essential for intended function;
- 3533 • Debug interfaces are disabled in default configuration unless physically secured;
- 3534 • Unused network protocols and services are disabled in default configuration;
- 3535 • Test modes and diagnostic functions not required for normal operation are disabled;
- 3536 • Legacy protocols not actively required are disabled in default configuration;
- 3537 • Only documented management interfaces are enabled in default configuration.

3538 Supporting evidence

- 3539 • Manufacturer documentation describing intended function and essential interfaces and services;
- 3540 • Product configuration in factory default state showing enabled interfaces and services;
- 3541 • Analysis identifying all enabled interfaces and services;
- 3542 • Verification confirming each enabled interface or service is essential for intended function;
- 3543 • Verification confirming debug interfaces are disabled or physically secured;
- 3544 • Network scan results showing disabled unused protocols and services;
- 3545 • Product configuration showing test modes and diagnostic functions are disabled;
- 3546 • Verification confirming legacy protocols are disabled when not required;
- 3547 • Documentation listing management interfaces explicitly provided for user access;
- 3548 • Analysis confirming only documented management interfaces are enabled.

3549 [EXPOSURE-1-RQ-1-02] Verify the product provides capability to selectively enable or disable individual services and
3550 interfaces through configuration.

3551 Activities

3552 Verify:

- 3553 • Manufacturer documentation describes configuration capabilities for services and interfaces.
- 3554 • Product provides configuration options to enable individual services.
- 3555 • Product provides configuration options to disable individual services.
- 3556 • Product provides configuration options to enable individual interfaces.
- 3557 • Product provides configuration options to disable individual interfaces.
- 3558 • Configuration changes to services take effect according to documented behaviour.
- 3559 • Configuration changes to interfaces take effect according to documented behaviour.
- 3560 • Each service can be controlled independently through configuration.
- 3561 • Each interface can be controlled independently through configuration.
- 3562 • Disabled services are not accessible or operational.
- 3563 • Disabled interfaces are not accessible or operational.
- 3564 • Enabled services function correctly after configuration activation.
- 3565 • Enabled interfaces function correctly after configuration activation.
- 3566 • Configuration changes persist after product restart.
- 3567 • Documentation describes procedures for enabling and disabling services and interfaces.

3568 Verdict

3569 Pass if:

- 3570 • Product provides configuration capability to enable individual services;
- 3571 • Product provides configuration capability to disable individual services;
- 3572 • Product provides configuration capability to enable individual interfaces;
- 3573 • Product provides configuration capability to disable individual interfaces;
- 3574 • Configuration changes take effect as documented;
- 3575 • Disabled services and interfaces are not accessible;
- 3576 • Configuration changes persist after restart.

3577 Supporting evidence

- 3578 • Manufacturer documentation describing configuration capabilities;
- 3579 • Configuration interface showing options to enable and disable services;
- 3580 • Configuration interface showing options to enable and disable interfaces;
- 3581 • Test results demonstrating service can be disabled through configuration;
- 3582 • Test results demonstrating service can be enabled through configuration;
- 3583 • Test results demonstrating interface can be disabled through configuration;
- 3584 • Test results demonstrating interface can be enabled through configuration;
- 3585 • Verification confirming disabled services are not accessible;
- 3586 • Verification confirming disabled interfaces are not accessible;
- 3587 • Verification confirming configuration changes persist after restart;

- Documentation describing procedures for service and interface configuration.

7.9 Monitoring and Logging

7.9.1.1 Requirement assessments

[LOG-1-RQ-1-01] Verify the product generates audit events for authentication activities including successful or failed authentication, account lockout triggers and releases, and authentication credential change attempts.

Activities

Verify:

- Manufacturer documentation describes audit events generated for authentication activities.
- Product generates audit events for successful authentication.
- Product generates audit events for failed authentication.
- Product generates audit events for account lockout triggers.
- Product generates audit events for account lockout releases.
- Product generates audit events for authentication credential change attempts.
- All authentication-related audit events include timestamps.
- Audit events include user identifiers or account names where applicable.
- Audit events include sufficient detail to understand authentication activity.
- Failed authentication events include information about the failure reason where appropriate.
- Credential change attempt events indicate success or failure of the attempt.
- All authentication audit events are recorded and accessible for review.
- Audit events are retained according to documented retention policies.

Verdict

Pass if:

- Product generates audit events for successful authentication;
- Product generates audit events for failed authentication;
- Product generates audit events for account lockout triggers and releases;
- Product generates audit events for authentication credential change attempts;
- All audit events include timestamps and relevant identifiers;
- Audit events are accessible for review.

Supporting evidence

- Manufacturer documentation describing audit events for authentication activities;
- Audit logs showing successful authentication events;
- Audit logs showing failed authentication events;
- Audit logs showing account lockout trigger events;
- Audit logs showing account lockout release events;
- Audit logs showing authentication credential change attempt events;
- Verification confirming all audit events include timestamps;
- Verification confirming audit events include user identifiers or account names;
- Analysis confirming audit event retention and accessibility.

[LOG-1-RQ-1-02] Verify the product generates audit events for all session lifecycle activities including session establishment with source details, session termination with reason, failed session validation attempts, and concurrent session limit violations.

Activities

Verify:

- Manufacturer documentation describes audit events generated for session lifecycle activities.

- 3632 • Product generates audit events for session establishment.
- 3633 • Session establishment audit events include source details.
- 3634 • Product generates audit events for session termination.
- 3635 • Session termination audit events include reason for termination.
- 3636 • Product generates audit events for failed session validation attempts.
- 3637 • Product generates audit events for concurrent session limit violations.
- 3638 • All session lifecycle audit events include timestamps.
- 3639 • Session establishment events include source address or connection details.
- 3640 • Session termination events indicate whether termination was user-initiated, timeout-based, or administrative.
- 3641 • Failed session validation events include information about the validation failure.
- 3642 • Concurrent session limit violation events identify the user account affected.
- 3643 • All session lifecycle audit events are recorded and accessible for review.
- 3644 • Audit events are retained according to documented retention policies.

3645 Verdict

3646 Pass if:

- 3647 • Product generates audit events for session establishment with source details;
- 3648 • Product generates audit events for session termination with reason;
- 3649 • Product generates audit events for failed session validation attempts;
- 3650 • Product generates audit events for concurrent session limit violations;
- 3651 • All audit events include timestamps and relevant details;
- 3652 • Audit events are accessible for review.

3653 Supporting evidence

- 3654 • Manufacturer documentation describing audit events for session lifecycle activities;
- 3655 • Audit logs showing session establishment events with source details;
- 3656 • Audit logs showing session termination events with reasons;
- 3657 • Audit logs showing failed session validation attempt events;
- 3658 • Audit logs showing concurrent session limit violation events;
- 3659 • Verification confirming all audit events include timestamps;
- 3660 • Verification confirming session establishment events include source details;
- 3661 • Verification confirming session termination events include termination reasons;
- 3662 • Analysis confirming audit event retention and accessibility.

3663 [LOG-1-RQ-2-03] Verify the product implements command authorisation that creates audit events of unauthorised
3664 commands.

3665 Activities

3666 Verify:

- 3667 • Manufacturer documentation describes audit events generated for command authorisation activities.
- 3668 • Product generates audit events when unauthorised commands are attempted.
- 3669 • Command authorisation validation occurs before command execution.
- 3670 • Unauthorised command attempts are logged before denial.
- 3671 • Audit events include identification of the command that was attempted.
- 3672 • Audit events include identification of the user or account attempting the command.
- 3673 • Audit events include timestamps for unauthorised command attempts.
- 3674 • Audit events include information about why the command was unauthorised.
- 3675 • All unauthorised command attempts generate audit events regardless of interface used.
- 3676 • Audit events provide sufficient detail to understand the unauthorised access attempt.
- 3677 • All command authorisation audit events are recorded and accessible for review.
- 3678 • Audit events are retained according to documented retention policies.

3679 Verdict

3680 Pass if:

- 3681 • Product implements command authorisation that generates audit events;
- 3682 • Unauthorised command attempts generate audit events;
- 3683 • Audit events include command identification;
- 3684 • Audit events include user or account identification;
- 3685 • Audit events include timestamps and reason for denial;
- 3686 • Audit events are accessible for review.

3687 Supporting evidence

- 3688 • Manufacturer documentation describing audit events for command authorisation;
- 3689 • Audit logs showing unauthorised command attempt events;
- 3690 • Test results demonstrating audit event generation for unauthorised commands;
- 3691 • Verification confirming audit events include command identification;
- 3692 • Verification confirming audit events include user or account identification;
- 3693 • Verification confirming audit events include timestamps;
- 3694 • Verification confirming audit events include denial reasons;
- 3695 • Analysis confirming audit events generated regardless of interface used;
- 3696 • Analysis confirming audit event retention and accessibility.

3697 [LOG-1-RQ-2-04] Verify the product stores audit events in persistent memory that survives the reset.

3698 Activities

3699 Verify:

- 3700 • Manufacturer documentation describes audit event storage mechanisms.
- 3701 • Audit events are stored in persistent memory.
- 3702 • Audit events recorded before reset operation are documented.
- 3703 • Reset operation is performed.
- 3704 • Audit events recorded before reset remain accessible after reset.
- 3705 • Audit event storage survives power cycles.
- 3706 • Audit event storage survives factory reset operations.
- 3707 • Audit event storage is not volatile memory.
- 3708 • All previously recorded audit events are retrievable after reset.
- 3709 • Storage mechanism preserves event integrity through reset operations.

3710 Verdict

3711 Pass if:

- 3712 • Audit events are stored in persistent memory;
- 3713 • Audit events survive reset operations;
- 3714 • Previously recorded events remain accessible after reset;
- 3715 • Audit event storage survives power cycles;
- 3716 • Audit event integrity is maintained through reset operations.

3717 Supporting evidence

- 3718 • Manufacturer documentation describing audit event storage mechanisms;
- 3719 • Audit events recorded before reset operation;
- 3720 • Reset operation confirmation;
- 3721 • Audit events retrieved after reset operation;
- 3722 • Comparison showing audit events preserved through reset;
- 3723 • Verification confirming persistent memory storage;
- 3724 • Analysis confirming storage survives power cycles and factory reset.

3725 7.10 Data Management

3726 7.10.1 [TRANSFER] Secure data export and transfer

3727 7.10.1.1 Requirement assessments

3728 [TRANSFER-1-RQ-1-01] Verify the product supports secure data export, allowing users to transfer the exported data
3729 over encrypted channel.

3730 Activities

3731 Verify:

- 3732 • Manufacturer documentation describes secure data export capabilities.
- 3733 • Product supports data export functionality.
- 3734 • Product allows users to transfer exported data over encrypted channel.
- 3735 • Encrypted channel provides confidentiality protection for exported data during transfer.
- 3736 • Encrypted channel provides integrity protection for exported data during transfer.
- 3737 • Encryption is available for all data export operations.
- 3738 • Users can initiate export with encrypted transfer.
- 3739 • Cryptographic algorithms used for encrypted transfer meet best practice standards.
- 3740 • Exported data is protected during transmission from product to destination.
- 3741 • Transfer mechanisms prevent unauthorised access to exported data in transit.
- 3742 • Documentation describes procedures for secure data export.

3743 Verdict

3744 Pass if:

- 3745 • Product supports secure data export;
- 3746 • Users can transfer exported data over encrypted channel;
- 3747 • Encrypted channel provides confidentiality and integrity protection;
- 3748 • Encryption is available for all data export operations;
- 3749 • Cryptographic algorithms meet best practice standards.

3750 Supporting evidence

- 3751 • Manufacturer documentation describing secure data export capabilities;
- 3752 • Product configuration showing data export functionality;
- 3753 • Test results demonstrating encrypted channel availability for export;
- 3754 • Network traffic analysis confirming encrypted data transfer;
- 3755 • Verification confirming confidentiality protection during transfer;
- 3756 • Verification confirming integrity protection during transfer;
- 3757 • Analysis confirming cryptographic algorithms meet best practice standards;
- 3758 • Documentation describing procedures for secure data export;
- 3759 • Test results demonstrating successful secure export operations.

3760 [TRANSFER-1-RQ-1-02] Verify the product supports secure data import, allowing users to import data in the product
3761 over encrypted channel.

3762 Activities

3763 Verify:

- 3764 • Manufacturer documentation describes secure data import capabilities.
- 3765 • Product supports data import functionality.
- 3766 • Product allows users to import data over encrypted channel.
- 3767 • Encrypted channel provides confidentiality protection for imported data during transfer.
- 3768 • Encrypted channel provides integrity protection for imported data during transfer.

- 3769 • Encryption is available for all data import operations.
- 3770 • Users can initiate import with encrypted transfer.
- 3771 • Cryptographic algorithms used for encrypted transfer meet best practice standards.
- 3772 • Imported data is protected during transmission from source to product.
- 3773 • Transfer mechanisms prevent unauthorised access to imported data in transit.
- 3774 • Documentation describes procedures for secure data import.

3775 Verdict

3776 Pass if:

- 3777 • Product supports secure data import;
- 3778 • Users can import data over encrypted channel;
- 3779 • Encrypted channel provides confidentiality and integrity protection;
- 3780 • Encryption is available for all data import operations;
- 3781 • Cryptographic algorithms meet best practice standards.

3782 Supporting evidence

- 3783 • Manufacturer documentation describing secure data import capabilities;
- 3784 • Product configuration showing data import functionality;
- 3785 • Test results demonstrating encrypted channel availability for import;
- 3786 • Network traffic analysis confirming encrypted data transfer;
- 3787 • Verification confirming confidentiality protection during transfer;
- 3788 • Verification confirming integrity protection during transfer;
- 3789 • Analysis confirming cryptographic algorithms meet best practice standards;
- 3790 • Documentation describing procedures for secure data import;
- 3791 • Test results demonstrating successful secure import operations.

3792 [TRANSFER-1-RQ-1-03] Verify the product provides capability to encrypt exported data using best practice encryption
3793 algorithms, with encryption applied based on user preference during export.

3794 Activities

3795 Verify:

- 3796 • Manufacturer documentation describes data export encryption capabilities.
- 3797 • Product provides capability to encrypt exported data.
- 3798 • Encryption of exported data uses best practice algorithms.
- 3799 • Encryption is applied based on user preference during export.
- 3800 • Users can choose to encrypt or not encrypt exported data.
- 3801 • Encryption algorithms used for exported data meet best practice standards.
- 3802 • User interface provides options for encryption during export process.
- 3803 • Encryption settings are configurable by the user.
- 3804 • When user selects encryption, exported data is encrypted using best practice algorithms.
- 3805 • When user does not select encryption, exported data is not encrypted.
- 3806 • Cryptographic algorithms comply with current recognised standards.
- 3807 • Documentation describes encryption options available during export.
- 3808 • Users are informed of encryption choices during export process.

3809 Verdict

3810 Pass if:

- 3811 • Product provides capability to encrypt exported data;
- 3812 • Encryption uses best practice algorithms;
- 3813 • Encryption is applied based on user preference;
- 3814 • Users can choose to encrypt or not encrypt exported data;

- 3815 • Cryptographic algorithms meet best practice standards;
- 3816 • User interface provides encryption options during export.

3817 Supporting evidence

- 3818 • Manufacturer documentation describing data export encryption capabilities;
- 3819 • Documentation describing encryption algorithms used for exported data;
- 3820 • User interface showing encryption options during export process;
- 3821 • Test results demonstrating export with encryption enabled;
- 3822 • Test results demonstrating export with encryption disabled;
- 3823 • Analysis confirming encryption algorithms meet best practice standards;
- 3824 • Verification confirming cryptographic algorithms comply with recognised standards;
- 3825 • Analysis confirming encryption is applied based on user preference;
- 3826 • Test results showing user control over encryption during export.

3827 [TRANSFER-1-RQ-1-04] Verify the product requires administrative access for export operations.

3828 Activities

3829 Verify:

- 3830 • Manufacturer documentation describes access control requirements for export operations.
- 3831 • Product requires administrative access for initiating export operations.
- 3832 • Export functionality is not accessible to non-administrative users.
- 3833 • Authentication is required before export operations can be performed.
- 3834 • Authorisation verifies administrative privileges before allowing export.
- 3835 • Attempted export operations without administrative access are denied.
- 3836 • Attempted export operations with non-administrative credentials are denied.
- 3837 • All export operations require appropriate privilege level.
- 3838 • Export access control operates consistently across all product interfaces.
- 3839 • Export operation attempts are logged with user identity.

3840 Verdict

3841 Pass if:

- 3842 • Product requires administrative access for export operations;
- 3843 • Export functionality is not accessible to non-administrative users;
- 3844 • Authentication and authorisation are required before export operations;
- 3845 • Attempted exports without administrative access are denied;
- 3846 • Export access control operates consistently across all interfaces;
- 3847 • Export operation attempts are logged.

3848 Supporting evidence

- 3849 • Manufacturer documentation describing access control requirements for export operations;
- 3850 • Product configuration showing administrative access requirement for export;
- 3851 • Test results demonstrating export requires administrative credentials;
- 3852 • Attempted export with non-administrative credentials showing denial;
- 3853 • Attempted export without authentication showing denial;
- 3854 • Verification confirming export access control operates across all interfaces;
- 3855 • Logs showing export operation attempts with user identity;
- 3856 • Analysis confirming administrative privilege requirement for export operations.

3857 [TRANSFER-1-RQ-1-05] Verify the product requires administrative access for import operations.

3858 Activities

3859 Verify:

- 3860 • Manufacturer documentation describes access control requirements for import operations.
- 3861 • Product requires administrative access for initiating import operations.
- 3862 • Import functionality is not accessible to non-administrative users.
- 3863 • Authentication is required before import operations can be performed.
- 3864 • Authorisation verifies administrative privileges before allowing import.
- 3865 • Attempted import operations without administrative access are denied.
- 3866 • Attempted import operations with non-administrative credentials are denied.
- 3867 • All import operations require appropriate privilege level.
- 3868 • Import access control operates consistently across all product interfaces.
- 3869 • Import operation attempts are logged with user identity.

3870 Verdict

3871 Pass if:

- 3872 • Product requires administrative access for import operations;
- 3873 • Import functionality is not accessible to non-administrative users;
- 3874 • Authentication and authorisation are required before import operations;
- 3875 • Attempted imports without administrative access are denied;
- 3876 • Import access control operates consistently across all interfaces;
- 3877 • Import operation attempts are logged.

3878 Supporting evidence

- 3879 • Manufacturer documentation describing access control requirements for import operations;
- 3880 • Product configuration showing administrative access requirement for import;
- 3881 • Test results demonstrating import requires administrative credentials;
- 3882 • Attempted import with non-administrative credentials showing denial;
- 3883 • Attempted import without authentication showing denial;
- 3884 • Verification confirming import access control operates across all interfaces;
- 3885 • Logs showing import operation attempts with user identity;
- 3886 • Analysis confirming administrative privilege requirement for import operations.

3887 [TRANSFER-1-RQ-1-06] Verify the product generates audit events for all export and import operations.

3888 Activities

3889 Verify:

- 3890 • Manufacturer documentation describes audit events generated for export and import operations.
- 3891 • Product generates audit events for all export operations.
- 3892 • Product generates audit events for all import operations.
- 3893 • Export operation audit events include timestamps.
- 3894 • Import operation audit events include timestamps.
- 3895 • Audit events include user identity or account performing the operation.
- 3896 • Audit events include details of what data was exported or imported where applicable.
- 3897 • Audit events indicate success or failure of export operations.
- 3898 • Audit events indicate success or failure of import operations.
- 3899 • Export and import audit events provide sufficient detail to understand the operation performed.
- 3900 • All export and import audit events are recorded and accessible for review.
- 3901 • Audit events are retained according to documented retention policies.

3902 Verdict

3903 Pass if:

- 3904 • Product generates audit events for all export operations;
- 3905 • Product generates audit events for all import operations;

- 3906 • All audit events include timestamps and user identity;
- 3907 • Audit events indicate success or failure of operations;
- 3908 • Audit events are accessible for review.

3909 Supporting evidence

- 3910 • Manufacturer documentation describing audit events for export and import operations;
- 3911 • Audit logs showing export operation events;
- 3912 • Audit logs showing import operation events;
- 3913 • Verification confirming all audit events include timestamps;
- 3914 • Verification confirming audit events include user identity or account;
- 3915 • Verification confirming audit events indicate operation success or failure;
- 3916 • Test results demonstrating audit event generation for export operations;
- 3917 • Test results demonstrating audit event generation for import operations;
- 3918 • Analysis confirming audit event retention and accessibility.

3919 [TRANSFER-1-RQ-1-07] Verify the product stores audit events in persistent memory that survives the reset.

3920 Activities

3921 Verify:

- 3922 • Manufacturer documentation describes audit event storage mechanisms.
- 3923 • Audit events are stored in persistent memory.
- 3924 • Audit events recorded before reset operation are documented.
- 3925 • Reset operation is performed.
- 3926 • Audit events recorded before reset remain accessible after reset.
- 3927 • Audit event storage survives power cycles.
- 3928 • Audit event storage survives factory reset operations.
- 3929 • Audit event storage is not volatile memory.
- 3930 • All previously recorded audit events are retrievable after reset.
- 3931 • Storage mechanism preserves event integrity through reset operations.

3932 Verdict

3933 Pass if:

- 3934 • Audit events are stored in persistent memory;
- 3935 • Audit events survive reset operations;
- 3936 • Previously recorded events remain accessible after reset;
- 3937 • Audit event storage survives power cycles;
- 3938 • Audit event integrity is maintained through reset operations.

3939 Supporting evidence

- 3940 • Manufacturer documentation describing audit event storage mechanisms;
- 3941 • Audit events recorded before reset operation;
- 3942 • Reset operation confirmation;
- 3943 • Audit events retrieved after reset operation;
- 3944 • Comparison showing audit events preserved through reset;
- 3945 • Verification confirming persistent memory storage;
- 3946 • Analysis confirming storage survives power cycles and factory reset.

8 Annex A (informative): Relationship between the present document and the requirements of EU Regulation (EU) 2024/2847 – the Cyber Resilience Act

The present document has been prepared in response to the Commission's standardisation request C(2025)618 [i.3] to provide, in additions to its other uses, one voluntary means of conforming to the essential requirements of Regulation (EU) 2024/2847 [i.2] known as the Cyber Resilience Act (CRA).

Once the present document is cited in the Official Journal of the European Union under Regulation (EU) 2024/2847 [i.2], conformance with the normative clauses of the present document given in the tables in Annex A confers, to products with digital elements in the scope of the present document, a presumption of conformity with the corresponding essential requirements of that Regulation and associated EFTA regulations.

Table A.1: Relationship between the present document and the requirements of Regulation (EU) 2024/2847 – the Cyber Resilience Act

Harmonised Standard ETSI EN 304 627					
Requirement				Requirement Conditionality	
No	Description	Requirements of Regulation	Clause(s) of the present document	U/C	Condition
1	Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks.	Annex I, Part I, (1)	Clauses Error! Reference source not found. and 5.2 implement a risk-based approach through scaled requirements	U	-
2	Products with digital elements shall be made available on the market without known exploitable vulnerabilities.	Annex I, Part I, (2)(a)	Clause 5.3	U	
3	Products with digital elements shall be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state.	Annex I, Part I, (2)(b)	Clause 5.4	U	
4	Products with digital elements shall ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed	Annex I, Part I, (2)(c)	Clause 5.5	U	

Harmonised Standard ETSI EN 304 627					
Requirement				Requirement Conditionality	
No	Description	Requirements of Regulation	Clause(s) of the present document	U/C	Condition
	within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them.				
5	Products with digital elements shall ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access	Annex I, Part I, (2)(d)	Clause 5.6	U	
6	Products with digital elements shall protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by best practice mechanisms, and by using other technical means.	Annex I, Part I, (2)(e)	Clause 5.7	U	
7	Products with digital elements shall protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions.	Annex I, Part I, (2)(f)	Clause 5.7	U	
8	Products with digital elements shall process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital	Annex I, Part I, (2)(g)	Clause 5.7	U	

Harmonised Standard ETSI EN 304 627					
Requirement				Requirement Conditionality	
No	Description	Requirements of Regulation	Clause(s) of the present document	U/C	Condition
	elements (data minimisation).				
9	Products with digital elements shall protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks.	Annex I, Part I, (2)(h)	Clause 5.8	U	
10	Products with digital elements shall minimise the negative impact by the products themselves or connected products on the availability of services provided by other products or networks.	Annex I, Part I, (2)(i)	Clause 5.8	U	
11	Products with digital elements shall be designed, developed and produced to limit attack surfaces, including external interfaces.	Annex I, Part I, (2)(j)	Clause 5.9	U	
12	Products with digital elements shall be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques.	Annex I, Part I, (2)(k)	Clause 5.9	U	
13	Products with digital elements shall provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user.	Annex I, Part I, (2)(l)	Clause 5.10	U	
14	Products with digital elements shall provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner.	Annex I, Part I, (2)(m)	Clauses 5.4.2 and 5.11	U	
...					

3960

3961 **Key to columns:**3962 **Requirement:**3963 **No** A unique identifier for one row of the table which may be used to identify a requirement.3964 **Description** A textual reference to the requirement.3965 **Requirements of Regulation**

3966 Identification of article(s) defining the requirement in the Regulation.

3967 **Clause(s) of the present document**3968 Identification of clause(s) defining the requirement in the present document unless another
3969 document is referenced explicitly.3970 **Requirement Conditionality:**3971 **U/C** Indicates whether the requirement is unconditionally applicable (U) or is conditional upon the
3972 manufacturer's claimed functionality of the equipment (C).3973 **Condition** Explains the conditions when the requirement is or is not applicable for a requirement which is
3974 classified "conditional".3975 Presumption of conformity stays valid only as long as a reference to the present document is maintained in the list
3976 published in the Official Journal of the European Union. Users of the present document should consult frequently the
3977 latest list published in the Official Journal of the European Union.

3978 Other Union legislation may be applicable to the product(s) falling within the scope of the present document.

3979

3980

3981

9 Annex B (informative): Threat landscape and security considerations

9.1 General

This clause provides the threat and vulnerability analysis that informed the risk factor-based security requirements in the present document. The analysis examines threat actors, vulnerability patterns, and attack scenarios relevant to routers, modems intended for connection to the internet, and switches to establish the technical foundation for proportionate security requirements. The evaluation demonstrates how risk factors defined in clause 4.8.2 correspond to different threat exposures and attack surfaces, justifying why certain capabilities trigger enhanced security requirements whilst maintaining baseline protections for all products.

The analysis evaluates threats across three dimensions: threat actor capabilities and motivations, vulnerability prevalence and exploitability, and deployment-specific risk factors. This multi-dimensional analysis produces a threat severity matrix that informs the classification of security requirements as either universal (applying to all products) or conditional (applying only when specific risk factors are present).

The analysis distinguishes between baseline threats affecting all routers, modems intended for connection to the internet, and switches regardless of configuration, and elevated threats emerging only in specific deployment contexts or with certain capabilities enabled. Baseline threats include opportunistic automated attacks seeking default credentials, supply chain compromises affecting firmware integrity, and physical tampering in environments with inadequate access controls. These universal threats justify the core security requirements specified in clause 5.

Elevated threats correspond directly to risk factors defined in clause 4.8.2, with each risk factor introducing specific attack vectors and threat actors. Products with internet-exposed management interfaces (risk factor [MA-RF-4]) face higher threat volumes than those with only physical management access (risk factor [BL-RF-1]). Products under centralised management (risk factor [MO-RF-2]) present different vulnerabilities than individually managed devices (risk factor [MO-RF-1]), though both models introduce distinct security challenges requiring tailored controls.

This threat-driven approach ensures security requirements remain proportionate to actual risk whilst avoiding under-protection of high-risk deployments and over-engineering of low-risk implementations. The mapping between threats and requirements is traceable throughout the document, with each requirement in clause 5 addressing specific threats identified in this analysis.

9.2 Threat agent characterization

Threat agents targeting routers, modems intended for connection to the internet, and switches exhibit predictable patterns of behaviour based on their technical capabilities, resource constraints, and objectives. This characterization employs a capability-intent that maps threat actors against the conditions defined in clause **Error! Reference source not found.**, establishing quantifiable relationships between deployment configurations and threat exposure levels.

The analysis considers both the technical sophistication required to execute specific attacks and the economic incentives driving different threat actors. This economic perspective is critical for understanding why certain deployment configurations attract disproportionate attention from attackers. Products with public network-exposed management interfaces represent targets with favourable attack economics, where single vulnerabilities can be monetized across millions of devices through automated exploitation. Conversely, products accessible only through physical interfaces require threat actors to accept unfavourable economics, limiting attacks to high-value targets or opportunistic scenarios.

9.2.1 Threat distribution across network exposure levels

Four primary threat categories target products within scope, each exploiting different access patterns and vulnerability classes.

Automated exploitation tools generate the highest attack volume. These scripts scan public networks continuously for default credentials, unpatched vulnerabilities, and misconfigurations. Operating without human intervention, they attempt exploitation at scale. Their success depends on basic security failures persisting in deployed products. Products with [MA-RF-4] face this threat most acutely automated scanners identify and exploit vulnerable management interfaces within minutes of internet exposure.

Internal attackers with network footholds threaten products with [MA-RF-3] most directly. After breaching perimeter defences through phishing, supply chain compromise, or internet-facing service exploitation, these adversaries map

internal networks systematically to identify critical infrastructure. Network products with remote management capabilities become priority targets for persistent access and traffic interception. Network boundaries that characterize [MA-RF-3] deployments protect against external scanning but provide limited defence once attackers operate from within the trusted perimeter.

Compromised local systems and insider threats dominate risks for products with [MA-RF-2]. Malicious insiders or malware on compromised workstations within the same network segment interact directly with management interfaces otherwise protected from remote access. These threats bypass network segmentation by operating within the same broadcast domain as the target product. Advanced malware employs lateral movement techniques to target network infrastructure on the local segment, avoiding detection by monitoring systems that focus on routed traffic.

Physical security breaches constitute the sole direct threat vector for products with [MA-RF-1]. Threats range from opportunistic attackers with momentary access attempting password recovery, to sophisticated adversaries installing hardware implants or extracting firmware for reverse engineering. Cleaning staff, maintenance personnel, and others with legitimate physical access but lacking administrative authorization represent insider threats that network security controls cannot mitigate. Complete absence of network-based management interfaces eliminates remote attack vectors but concentrates all risk on physical security controls that many deployment environments cannot adequately provide.

9.2.2 Threat patterns associated with management models

The management model employed for routers, modems intended for the connection to the internet, and switches fundamentally influences their threat exposure and the sophistication of attacks they face. Different management approaches create distinct vulnerability patterns that attract specific categories of threat actors with varying objectives and capabilities.

Products with risk factor [MO-RF-1], where products are administered directly by end users or local IT staff without integration into network management systems, face a threats characterized by inconsistent security practices and limited visibility. These independently managed products attract opportunistic attackers who exploit common misconfigurations resulting from manual administration processes. The absence of centralized management creates environments where security updates may be delayed or overlooked entirely, with each product potentially maintaining different patch levels and security configurations. Insider threats pose risks in these deployments, as the lack of centralized logging and monitoring makes unauthorized configuration changes difficult to detect. Additionally, the reliance on individual product management often results in weaker credential management practices, including password reuse across products and retention of default or weak administrative credentials. Social engineering attacks targeting individual administrators prove particularly effective in these environments, as there are typically no systematic controls to prevent or detect unauthorized access gained through compromised credentials.

Organized cybercrime groups employ more sophisticated techniques, developing custom exploits for zero-day vulnerabilities and maintaining persistent access to compromised infrastructure. Products with risk factor [MO-RF-2] present attractive targets due to their potential for accessing multiple customer networks through compromised management systems.

9.2.3 Threats arising from capability-based conditions

Deployment conditions determine threat exposure. Product configuration and operational context directly affect exploitation probability. This establishes the foundation for applying security requirements proportionally to actual risk rather than theoretical vulnerability severity.

Products with [MA-RF-4] face fundamentally different threats than restricted-access products. Public network-exposed management interfaces endure continuous automated scanning from global threat actors. Published vulnerabilities become immediately actionable worldwide. Exploitation tools incorporate new vulnerabilities within hours of disclosure. Attackers compromise vulnerable products within 24-48 hours of initial deployment when factory defaults remain. This high compromise probability necessitates enhanced authentication, comprehensive logging, and rapid update capabilities.

Products with [MA-RF-3] reflect modern enterprise breach reality: attackers operate from within organizational perimeters. After establishing presence through phishing, supply chain compromise, or other vulnerabilities, adversaries target these products for lateral movement and persistence. Attacks are targeted, not opportunistic. Adversaries invest heavily in reconnaissance and custom exploitation. Network boundaries reduce automated scanning exposure compared to [MA-RF-4] but provide limited protection once attackers breach perimeter defences. These products serve as pivot points for further network compromise, driving monitoring and logging requirements.

Products with [MA-RF-2] face threats primarily from compromised endpoints and malicious insiders within the same network segment. Local network traffic receives implicit trust, creating exploitable assumptions. Adversaries leverage ARP spoofing, broadcast exploitation, and link-local protocol abuse. Exploitations originate from compromised workstations within the same broadcast domain, highlighting local network segmentation and endpoint security importance. Routed access paths do not exist, eliminating most attackers but concentrating risk on threats that establish local network presence.

Products with [MA-RF-1] eliminate network-based attack vectors entirely, limiting threats to physical access. Attack surface reduction significantly decreases exploitation probability compared to network-exposed products. Unique risks emerge: physical tampering, hardware implants, insider threats with building access. Successful compromises require extended physical access or repeated brief access over multiple occasions. This constrains threats to specific adversary categories with operational capabilities and physical proximity.

Management model conditions create orthogonal risk dimensions that interact with network exposure to produce compound effects. Products with [MO-RF-2] benefit from centralized security operations enabling coordinated patch deployment and consistent configuration across multiple devices. This approach substantially reduces vulnerability windows compared to individual management. However, centralized management introduces systemic risks: compromising management infrastructure affects numerous products simultaneously. Successful attacks against [MO-RF-2] platforms result in widespread fleet compromise, fundamentally different from single-device compromises typical of [MO-RF-1].

Temporal vulnerability dimensions vary dramatically by management model. Products with [MO-RF-1] exhibit inconsistent patch deployment: some devices receive updates promptly, others remain unpatched for months or indefinitely. This creates exploitable device populations that adversaries reliably target long after patches become available. Products with [MO-RF-2] demonstrate consistent patch deployment through automated or centrally coordinated updates, fundamentally altering threat exposure timelines.

Compound risk effects justify granular requirement structure. Products with [MA-RF-4] and [MO-RF-1] represent highest risk: maximum network exposure, minimal defensive capability, inconsistent patch management. Products with [MA-RF-1] and [MO-RF-2] benefit from reduced attack surface and professional security management. Exploitation probability varies significantly across condition combinations, validating proportionate security requirements. Uniform security controls would either inadequately protect high-risk deployments or impose unnecessary complexity on low-risk implementations where advanced features provide no measurable benefit.

Threat exposure analysis directly informs security requirements in Clause 5. Unconditional requirements address threats present across all deployment scenarios. Conditional requirements target specific elevated risks for each condition combination. Security controls align with actual exploitation patterns observed in production deployments, not theoretical vulnerability assessments performed in isolation. Deployment conditions clearly justify scaled security requirements, ensuring each product receives protection proportionate to its risk profile while avoiding unnecessary burden for lower-risk configurations.

9.2.4 Advanced persistent threats and emerging attack vectors

9.2.4.1 Nation-state actors and Advanced Persistent Threat groups

Nation-state actors and Advanced Persistent Threat (APT) groups represent the most sophisticated and persistent threat category targeting network infrastructure. These actors possess substantial resources, including dedicated exploit development teams, zero-day vulnerability stockpiles, and the operational capability to maintain presence in target networks for extended periods measured in years rather than days or weeks.

Particularly routers and switches, represent high-value targets for nation-state actors due to their strategic position enabling mass surveillance, traffic interception, and potential disruption of critical services.

The threat from nation-state actors varies significantly based on deployment context and geographic factors. Products deployed in critical infrastructure, government networks, or telecommunications providers face elevated targeting compared to residential deployments. However, nation-state actors increasingly compromise residential and small business equipment to create distributed infrastructure for subsequent operations, making even consumer-grade products potential targets.

Products with risk factor [MA-RF-4] face particular risk from nation-state scanning and exploitation infrastructure that operates at global scale, automatically identifying and cataloguing vulnerable devices for potential future operations. Products with risk factor [MO-RF-2] present attractive targets due to the potential for supply chain compromise of management infrastructure, enabling simultaneous access to numerous managed devices across multiple organizations.

9.2.4.2 Supply chain infiltration threats

Supply chain attacks targeting network infrastructure represent an escalating threat vector that bypasses traditional security controls by compromising products before deployment. These attacks manifest across multiple stages of the product lifecycle, from component manufacturing through distribution channels to ongoing support and update mechanisms.

Hardware supply chain threats include insertion of malicious components during manufacturing, modification of firmware during production or shipping, and substitution of legitimate products with compromised alternatives. The global nature of electronics manufacturing, with components sourced from multiple suppliers across different jurisdictions, creates numerous intervention opportunities for motivated adversaries.

Software supply chain attacks target the development and distribution infrastructure used to create and deliver firmware updates. Compromise of build systems, code repositories, or update servers can result in widespread distribution of malicious firmware to deployed products.

Third-party component vulnerabilities represent another supply chain risk dimension. Network products incorporate numerous third-party libraries, protocols stacks, and drivers, each potentially containing vulnerabilities unknown to the product manufacturer. The lag between vulnerability discovery in upstream components and downstream product updates creates windows of exposure that sophisticated actors actively exploit.

Products under centralized management (risk factor [MO-RF-2]) face elevated supply chain risks as compromise of the management infrastructure or update mechanisms can affect entire product fleets simultaneously. The trust relationship between managed devices and management platforms creates an attractive target for adversaries seeking to maximize impact through single-point compromises.

9.2.4.3 Zero-day exploit markets and commercialization

The commercialization of vulnerability research has created robust markets for zero-day exploits targeting network infrastructure. These markets include legitimate security research, grey market brokers selling to governments and law enforcement, and criminal marketplaces trading exploits for financial gain. The economic incentives driving these markets ensure continuous discovery and weaponization of vulnerabilities in network products.

Exploit prices for network infrastructure vulnerabilities, particularly those enabling remote code execution without authentication, command premium prices exceeding those for endpoint exploits. Router and switch exploits are particularly valuable due to their potential for persistent access, traffic interception, and difficulty of detection.

The proliferation of exploit development frameworks and toolkits has lowered barriers to entry for creating reliable exploits from published vulnerability information. Proof-of-concept code published by security researchers is rapidly weaponized and integrated into automated exploitation tools, reducing the time between disclosure and widespread exploitation to hours or days.

Products with network exposure risk factor [MA-RF-4] face immediate targeting when vulnerabilities are disclosed, as automated scanning and exploitation tools are updated within hours to include new exploits. The global accessibility of public network-exposed management interfaces means that every disclosed vulnerability immediately becomes actionable for attackers worldwide, regardless of their sophistication level.

9.3 Vulnerability analysis

The vulnerability landscape for routers, modems intended for connection to the internet, and switches reflects both the inherent complexity of network protocol implementations and the operational constraints under which these products function. These products process untrusted input at wire speed while maintaining compatibility with diverse network environments. This fundamental tension between performance, compatibility, and security creates vulnerability patterns that persist across vendors and product generations.

Vulnerability analysis for these products requires examination across multiple layers, from hardware-level vulnerabilities exploitable through physical access to application-layer flaws in management interfaces. The analysis has to consider not only the technical characteristics of vulnerabilities but also their exploitability under different deployment conditions. A memory corruption vulnerability in a management interface poses minimal risk when that interface is accessible only through a serial console but becomes critical when exposed to public network-based attacks. This context-dependent risk assessment drives the conditional application of security requirements, ensuring that protective measures align with actual exploitability rather than theoretical severity.

9.3.1 Attack scenario analysis

Threat actors exploit vulnerabilities through attack patterns that vary by product capability and deployment context. Different risk factor combinations create distinct attack profiles requiring proportionate security controls.

Products with [MA-RF-4] and [MO-RF-1] face automated exploitation followed by persistent compromise. Attackers scan public networks, identifying products through banner information or behavioural fingerprinting. Automated tools attempt default credentials. Upon success, attackers immediately modify configuration: disable logging, create innocuous-named administrative accounts, modify firewall rules for continued access. The compromised device downloads malware, enrolls in botnet infrastructure, and maintains normal routing functionality to avoid detection.

Products with [MA-RF-3] and [MO-RF-2] attract targeted attacks focused on lateral movement. Attackers compromise user workstations through phishing or watering hole attacks. From this foothold, they map networks systematically, searching for management interfaces and analysing traffic to identify management protocols. They exploit management interfaces by leveraging misconfigured access controls or protocol implementation vulnerabilities. Success grants traffic monitoring, connection redirection, and persistent backdoor establishment for future operations.

Products with [MA-RF-2] demonstrate risks from compromised local systems and insider threats. Documented incidents show malware on compromised workstations identifying network infrastructure through ARP scanning and service discovery. The malware exploits implicit trust granted to local traffic, bypassing security controls that focus on routed traffic. Authentication uses credentials harvested from the compromised workstation: browser-stored passwords, SSH keys, cached tokens. Success enables traffic interception, DNS manipulation, and covert channels that bypass monitoring focused on north-south traffic.

Products with [MA-RF-1] face sophisticated physical attacks when network access is unavailable. Documented techniques include hardware implants in serial console paths—providing remote access while appearing as legitimate console connections. Attackers with momentary access exploit password recovery procedures, often requiring only a boot-time key sequence for administrative access. Advanced attacks extract and modify firmware flash memory, inserting backdoors that survive factory resets and firmware updates.

9.3.2 Condition-based threat exposure

The correlation between deployment conditions and successful exploitation demonstrates that threat exposure varies significantly based on product configuration and operational context. This analysis establishes the technical foundation for applying security requirements proportionally to actual risk rather than theoretical vulnerability severity.

Products with network exposure risk factor [MA-RF-4] experience fundamentally different threat dynamics than those with more restricted access. Public network-exposed management interfaces face continuous automated scanning and exploitation attempts from global threat actors. Any published vulnerability affecting products with this condition becomes immediately actionable for attackers worldwide, with exploitation tools rapidly incorporating new vulnerabilities as they are disclosed. The automated nature of these attacks means that vulnerable products can be compromised within hours or days of initial deployment when operating with factory default configurations. This high probability of compromise for internet-exposed products necessitates the enhanced authentication mechanisms, comprehensive logging, and rapid update capabilities specified for products with this condition.

The threat exposure for products with risk factor [MA-RF-3] reflects the reality of modern enterprise breaches where attackers operate from within organizational perimeters. Once adversaries establish presence within controlled networks through phishing, supply chain compromise, or exploitation of other vulnerabilities, products with risk factor [MA-RF-3] become high-value targets for lateral movement and persistence. These products typically experience targeted rather than opportunistic attacks, with adversaries investing significant effort in reconnaissance and custom exploitation. The controlled network boundaries that characterize risk factor [MA-RF-3] reduce exposure to automated scanning compared to risk factor [MA-RF-4] but provide limited protection against sophisticated actors who have already breached perimeter defences. Products with risk factor [MA-RF-3] involved in confirmed breaches often serve as pivot points for further network compromise, influencing the monitoring and logging requirements for this condition.

Products with risk factor [MA-RF-2] face threats primarily from compromised endpoints and malicious insiders operating within the same network segment. The implicit trust often granted to local network traffic creates exploitable assumptions that adversaries leverage through ARP spoofing, broadcast exploitation, and abuse of link-local protocols. Successful exploitations of products with risk factor [MA-RF-2] frequently originate from compromised workstations within the same broadcast domain, highlighting the importance of local network segmentation and endpoint security. The absence of routed access paths eliminates most potential attackers compared to public network-exposed configurations but concentrates risk on the subset of threats that successfully establish local network presence.

4234 The most restricted configuration, risk factor [MA-RF-1], eliminates network-based attack vectors entirely, limiting
4235 threats to those with physical access. This substantial reduction in attack surface significantly decreases exploitation
4236 probability compared to network-exposed products, but introduces unique risks from physical tampering, hardware
4237 implants, and insider threats with building access. Successful compromises of products with risk factor [MA-RF-1]
4238 typically require either extended physical access periods or repeated brief access over multiple occasions, constraining
4239 the threat to specific adversary categories with appropriate operational capabilities and physical proximity.

4240 The management model conditions create orthogonal risk dimensions that interact with network exposure conditions to
4241 produce compound effects. Products with risk factor [MO-RF-2] benefit from centralized security operations that enable
4242 coordinated patch deployment and consistent security configuration across multiple devices. This centralized approach
4243 substantially reduces the window of vulnerability exposure compared to individually managed products. However,
4244 centralized management also introduces systemic risks where compromise of management infrastructure can affect
4245 numerous products simultaneously. Successful attacks against management platforms with risk factor [MO-RF-2] can
4246 result in widespread compromise across entire product fleets, fundamentally different from the single-device
4247 compromises typical of risk factor [MO-RF-1].

4248 The temporal dimension of vulnerability exposure varies dramatically based on management model. Products with risk
4249 factor [MO-RF-1] often exhibit inconsistent patch deployment patterns, with some devices receiving updates promptly
4250 while others remain unpatched for extended periods or throughout their operational lifetime. This persistent
4251 vulnerability exposure for individually managed products creates a population of exploitable devices that adversaries
4252 can reliably target long after patches become available. Conversely, products with risk factor [MO-RF-2] demonstrate
4253 more consistent patch deployment patterns through automated or centrally coordinated update mechanisms,
4254 fundamentally altering the threat exposure timeline for these deployments.

4255 The interaction between multiple conditions produces compound risk effects that justify the granular requirements
4256 structure. Products exhibiting both conditions [NE-4] and [MM-1] represent the highest risk category, combining
4257 maximum network exposure with minimal defensive capability and inconsistent patch management. In contrast,
4258 products with conditions [NE-1] and [MM-2] benefit from both reduced attack surface and professional security
4259 management. This significant variation in exploitation probability based on condition combinations validates the
4260 necessity of proportionate security requirements. Applying uniform security controls across all configurations would
4261 either leave high-risk deployments inadequately protected or impose unnecessary complexity on low-risk
4262 implementations where advanced security features provide no measurable benefit.

4263 The analysis of condition-based threat exposure presented here directly informs the classification of security
4264 requirements in clauses 5 and 7. Requirements specified without conditions address threats present across all
4265 deployment scenarios, while conditional requirements target the specific elevated risks identified for each condition
4266 combination. This approach ensures that security controls align with actual exploitation patterns observed in production
4267 deployments rather than theoretical vulnerability assessments performed in isolation from operational reality. The clear
4268 relationship between deployment conditions and threat exposure provides the technical justification for the scaled
4269 security requirements that follow, ensuring that each product receives protection proportionate to its actual risk profile
4270 while avoiding unnecessary implementation burden for lower-risk configurations.

4271

4272

4273

9.3.2.1.1.1.1.1 Annex <L+1> (informative):
Maximum measurement uncertainty

4274

The annex is optional.

4275

The measurements described in the present document are based on the following assumptions:

- 4276
- 4277
- 4278
- the measured value related to the corresponding limit is used to decide whether an equipment meets the requirements of the present document;
 - the value of the measurement uncertainty for the measurement of each parameter is included in the test report.

4279

Table <L+1>.1 shows the recommended values for the maximum measurement uncertainty figures.

4280

Table <L+1>.1: Maximum measurement uncertainty

Parameter	Uncertainty

9.3.2.1.1.1.1.2 Annex <L+2> (normative or informative):
Title of annex

10 <L+2.1> First clause of the annex

10.1 <L+2.1.1> First subdivided clause of the annex

<Text>.

10.1.1.1.1.1.1.1.1 Annex <L+3> (informative):
Bibliography

<Publication>: "<Title>".<Edition>. <Year>, <Issue designation>, <Page location>.

4293

10.1.1.1.1.1.2 Annex <L+4> (informative):

4294

Change history

4295

4296

4297

The "Change history/Change request (history)" annex shall be included in every revised or amended harmonised standard and shall contain information concerning significant changes that have been introduced by it. It shall be presented as a table.

Version	Information about changes

11 History

The following table will automatically be filled in by the ETSI Secretariat.

Document history		

[Last update on 2025-06-19](#)